

CYBER RISK IS BUSINESS RISK



At Marque Publishing, we believe ideas deserve to become reality.

Every project we publish is built on one simple idea:

Our mission is to help bring dreams to life.

We are living it every day, and we invite you to join us on the journey.

www.marquepublishing.com

CYBER RISK IS BUSINESS RISK

You can delegate the decision, but not the liability.

Chris Thatcher

Foreword by Sam Rehman



Marque Publishing

Copyright © 2026 Chris Thatcher

All rights reserved. No part of this publication may be reproduced, distributed, or transmitted in any form or by any means, including photocopying, recording, or other electronic or mechanical methods, without the prior written permission of the author, except in the case of brief quotations embodied in critical reviews and certain other noncommercial uses permitted by copyright law.

Published by Marque Publishing, LLC
Wellington, Florida

ISBN 979-8-951546-03-6 (hardcover)

ISBN 979-8-951546-04-3 (paperback)

ISBN 979-8-951546-05-0 (ebook)

LCCN: [pending]

Printed in the United States of America

First Edition

The information in this book is provided for educational and informational purposes only. It does not constitute legal, financial, or professional cybersecurity advice. Readers should consult qualified professionals for advice specific to their circumstances. The author has made every effort to ensure the accuracy of the information at the time of publication, but laws, regulations, and technology change rapidly. The author assumes no responsibility for errors, omissions, or changes that occur after publication.

Some names and identifying details of individuals and organizations in the case studies have been changed or omitted to protect confidentiality. Where cases are drawn from public record, court filings, or published government advisories, they are cited as such.

To my wife, Dannielle – Thank you for being my partner in life and raising four amazing children with me. I never could have had this career without you taking care of what matters most at home.

To my daughters, Jordan, Lexie and Nicole. I am so proud of the strong women you have become.

To my son Jayden. You are the reason I get out of bed every morning. I love you.

Contents



Foreword

Author's Note

Introduction

Chapter One: Cyber Risk Is Business Risk

Chapter Two: Risk in Plain English

Chapter Three: Welcome to the Wild West

Chapter Four: The Genie Is Out of the Bottle

Chapter Five: It's Not IF, It's WHEN

Chapter Six: Compliance vs. Security

Chapter Seven: Becoming the Sheriff

Chapter Eight: Building the Defenses

Chapter Nine: Budget

Chapter Ten: When Bad Things Happen

Chapter Eleven: Talking to Your Board

Epilogue: The Never-Ending Journey

Acknowledgments

Appendix A: The Regulatory Frontier

Appendix B: Who's on the Hook

Appendix C: Threat Intelligence Resources

Appendix D: The Board Conversation

Appendix E: The AI Tipping Point

Sources and Further Reading

About the Author

Foreword

†

We all like answers.

In fact, we often want them too soon, immediately, and in too much detail. It's human nature. When uncertainty arises, especially regarding safety, our instinct is to resolve it immediately. To move. To react. To do *something*. And sometimes that's absolutely the right thing to do, assuming you have the right training and experience.

But over more than thirty-five years in this business, leading organizations through incidents and helping clients navigate some of the most difficult moments of their careers, I've learned something that seems almost counterintuitive.

The best leaders don't begin with answers. They begin with a pause, however brief, and then questions. They observe. They listen. They separate signal from noise and ask the questions everyone else overlooked.

I've made it a personal objective to study how people react during a crisis. A cyber incident has a way of compressing time. The room fills with emotion, stress, urgency, and instinct. It amplifies everything. Everyone wants to act. Everyone wants certainty. Everyone has an opinion. Yet in those moments, the

most valuable person in the room is often the one who speaks the least.

In many ways, this book is about learning to separate signal from noise, clarity from confusion, and thoughtful leadership from instinctive reaction.



Years ago, while I was serving as a CISO, I was hosting a roundtable dinner for security executives. Before the evening began, I noticed one of the attendees—a CISO I'd known for years—sitting quietly by himself in the corner. That wasn't like him.

I walked over and asked if everything was alright.

He looked up and said, "Actually, no."

Then he asked me a question I've never forgotten.

"Sam, I've spent years building this security program. My GRC team tells me our framework maturity is excellent. Our assessments consistently rank us among the strongest organizations in our industry. Every dashboard tells me we're doing well."

He paused.

"But three days ago, LockBit brought our entire company to its knees. Our operations stopped. Our people couldn't work. I don't even know if I'll still have a job next week."

Then he asked quietly, "How can both of those things be true? How can one part of my organization tell me everything is going well while another reveals we're completely vulnerable?"

That question has stayed with me ever since.

The answer isn't that frameworks are wrong. They aren't. Governance, risk management, and compliance are essential disciplines. Strategy matters. Architecture matters. Boards and the executive team need that view. But that's only one side of the coin.

The other side lives on the ground—in the security engineers and analysts responding to alerts at two in the morning, collecting evidence, orienting the group, calming everyone down, patching systems, containing the attack. I could go on and on. The operational realities never quite fit inside a dashboard.

Great security leadership lives in the connection between those two worlds, a balancing act that never takes its eyes from either side of that coin. Strategy without operational truth creates false confidence. Operations without strategy creates chaos. And the connection between them can't be built once and forgotten. It has to be continuously maintained, challenged, and recalibrated as the organization changes and as the threat landscape evolves.

Reading Chris's book, I found myself thinking back to that conversation. Much of what he writes is really about closing that gap—helping executives understand what the dashboards don't say, asking better questions, and making sure the view from the boardroom reflects what's actually happening on the ground.

That's leadership. That, to me, is what I've always called The Anchor in the group.



That is why this book is worth your time.

There are countless books that explain cybersecurity. Far fewer explain leadership under uncertainty. Chris has written the latter.

What makes this book different is not the technology. Technology will change. AI will evolve. Attackers will find new methods, and regulations will continue to mature. Those details matter, but they are not the lasting lesson.

The lasting lesson is that cyber risk has become inseparable from business leadership. Today's executives are expected to make decisions about resilience, operational continuity, AI governance, and risk tolerance—without needing to become cybersecurity experts. Chris understands that reality. Rather than overwhelm you with technical depth, he gives you a framework for thinking, for asking better questions, and for leading with greater confidence.

I especially appreciate that this book doesn't rely on fear. It relies on perspective.

The stories are real. The lessons are earned. The questions linger long after you've finished each chapter. More than once, I found myself reflecting not on what Chris was telling the reader to do, but on how many of these conversations I've witnessed myself over the years. Different companies. Different industries. The same leadership challenges.

AI has only made that harder. We're heading into an era where decisions have to be made faster, with more uncertainty

and greater accountability than ever before. In that environment, leadership will be defined less by having immediate answers and more by the discipline to pause, understand, and ask the questions that matter most.

As you read these pages, don't focus on finding all the answers immediately. Pay attention to the questions. The right questions expose assumptions, create clarity, build trust, and lead to better decisions. And when the next crisis comes—and someday it will—it may not be the person with the loudest voice or the quickest answer who leads your organization through it.

It will be the Anchor.

Sam Rehman, CEO Hitachi Cyber

Author's Note

†

Between the time I finished writing this book and the time it reached your hands, the next thing arrived. It always does.

In April 2026, Anthropic announced that it had built an AI model capable of autonomously discovering and exploiting software vulnerabilities that had gone undetected for nearly two decades. The model was so capable that Anthropic made the extraordinary decision not to release it to the public. Instead, they gave it to a small group of cybersecurity partners and told them to find as many holes as they could before someone else did. Within weeks, that group had identified more than ten thousand critical vulnerabilities in production software running the world's infrastructure.

By June, the U.S. government had imposed export controls on the technology. Cybersecurity professionals published an open letter arguing that the restrictions were taking the best defensive tools away from the people who needed them most. Competitors scrambled to build their own versions. The policy debate was still unresolved when this book went to press.

I'm not telling you this because this particular model is the story. By the time you read this, there will be a newer model, a

bigger number, a sharper debate. That's the point. The cycle I described in these pages (enthusiasm, adoption, lag, incident, regulation, hard-won discipline, and then the next wave) is already turning again. Faster than the last time.

Appendix E is my field report from inside that turn: what frontier models changed about the work, and the three major investments serious enterprises are funding in response.

The questions haven't changed. The urgency has.

— Chris Thatcher

Wellington, Florida

June 2026

INTRODUCTION

"Son, I Have No Idea What Any of That Means"



The bank president stood up slowly from his chair at the far end of the conference table. He was in his seventies, old school, the kind of man who built a regional bank in North Carolina on handshakes and relationships and the quiet confidence that comes from knowing his business down to the marrow. He had people he trusted to handle the things he didn't understand, and he'd never pretended otherwise.

My team and I had just delivered our final presentation, the capstone of a year-long security engagement. We'd done good work and I was proud of my team. We'd taken his bank from a place of real vulnerability to a defensible posture, and our slides showed it: security metrics, technical findings, remediation timelines, risk assessments. The works.

When I asked if there were any questions, the room went quiet. Then the president looked at me and said:

"Son, that was an impressive presentation. But I have no idea what any of it means to me and my business."

I was taken aback. We'd spent a year on this. But the moment he said it, I knew he was right, and more than that, I knew the problem wasn't his. It was mine.

He smiled and asked me three questions of his own.

"How much did I spend?"

Roughly \$650,000.

"I am a simple country boy. I don't want any of your fancy technical jargon. Give me a letter grade the way they do in school. Where was I when we started?"

I told him the truth: borderline failing. A D-minus.

"Where am I now?"

A solid B.

He nodded. Then he asked the question that changed how I think about every conversation I've had with a senior executive since:

"Do I need to be an A?"

I thought about it. And I told him the truth again: *"No sir. Spending more on the residual risk will give you a diminishing return on investment. Mitigating the risk of unlikely events which would have minimal business impact doesn't make business sense."*

He said thank you, and he walked out of the room.

That was more than twenty-five years ago, and I've never forgotten it. Not because the bank president taught me something about cybersecurity, he didn't know a firewall from a fence post. He taught me something about communication. About the gap between what security professionals know and

what the people who approve budgets, and ultimately bear responsibility for security decisions actually need to hear.

I started as an IT director at a Big Five accounting firm and eventually moved into consulting. Doing the IT audit work is what grounded me in the consulting mindset that has been with me through my entire career. This is also where I developed the questions I asked in every CFO interview at the end of my security controls audit. The roles I have held since, leading security practices, selling security technology, helping large enterprise clients solve complex business problems securely, have allowed me to see things from distinct vantage points. Through all of it, one consistent observation: the executives who make the business decisions about cybersecurity are almost never getting the information they need in a language they can use.

The bank president figured that out in thirty seconds. He didn't need to understand the technical details. He needed to understand what he'd bought, where he stood, and whether he needed to do more.

That's my promise to you with this book.

If you're a CEO, CFO, board member, or any executive responsible for your organization's security and compliance, this book is for you. My intention is not to make you a cybersecurity expert. I will arm you with the right questions and help you frame the answers so you can make informed decisions about the risks your organization faces.

More than twenty-five years later, the questions the bank president asked are still the right questions. Every executive who

carries responsibility for an organization's security posture has to answer some version of them. *How much did I spend? Where was I when we started? Where am I now? Do I need to do more?* The questions are durable. The conditions under which executives now have to answer them are not.

Things are changing faster than at any point in my career. When the bank president asked his questions, the window between a software vulnerability becoming known and an attacker exploiting it was measured in years. Today the typical case is five days. The meantime to remediate known vulnerabilities is still five months. That is the math that has changed. The math problem is confirmation, cybersecurity is not a technology problem, it is a business problem.

The decisions the security team is making about fixing problems carry real business risk, so you need to understand the risk and make the decision about what is acceptable. For a long time the consequences of delegating those decisions were manageable. That is no longer true.

Regulators and courts have caught up. The SEC now requires public companies to disclose material cyber incidents within four business days. Courts have expanded the fiduciary duty of oversight to include cybersecurity as a mission-critical risk. CISOs have been criminally prosecuted. CEOs have been personally sanctioned. The consequences of getting cybersecurity wrong have become personal for the executives in charge, and AI is a big part of what is driving that shift.

The bank president understood his job. He listened to the answers and made the decision. He did not ask his security advisor whether the bank should be an A. He decided. The job hasn't changed. The world you'll be deciding in has.

The World Has Changed

I've been saying that cybersecurity is a business risk, not a technical problem, for thirty years. For most of those years, I felt like I was shouting into the wind. Executives nodded politely and went back to treating security as an IT problem. When success is a non-event, it becomes something to be funded reluctantly, and given serious consideration only after something went wrong.

That is no longer possible.

AI has changed everything. Not in some abstract, futuristic sense. Right now, in your organization and in the bad actor community.

AI is fundamentally transforming how enterprises operate. Every major software vendor has embedded AI into their tools. People across your organization are using AI to boost productivity, many of them without approval, without controls, uploading sensitive data into public models and making business decisions based on outputs that have not been validated. This is shadow AI, and most enterprises have no idea how much of it is running.

Outside your walls, the same technology is being used against you. AI does at machine speed what used to take attackers months: automated reconnaissance, AI-generated phishing and

deepfake attacks that are virtually indistinguishable from the real thing, adaptive and autonomous attacks built to evade your detection technology.

And this is the part that connects everything else in this book. AI is not just changing the threat landscape. It is the catalyst that forced regulators to hastily draft new regulations in an effort to catch up. The speed and scale of AI-driven risk is why the SEC wrote four-day disclosure rules. It is why courts are expanding fiduciary duties to include cybersecurity oversight. It is why enforcement actions are naming individuals, not just institutions. It is why insurers are rewriting their policies with AI-specific exclusions and why seventy-two percent of CISOs now refuse to take a position without personal liability coverage.

And the place where all of it lands is on the desk of the executive who carries responsibility for the organization. That is what this book is about.

What You Can Expect From This Book

You don't need to become a cybersecurity expert, you need to demand information from your security team in terms that allow you to treat cyber risk the way you treat financial, market, and operational risk. That means treating security as a business continuity and organizational resilience question, where the decisions about risk tolerance and operating speed stay in the executive room rather than getting delegated to the security function.

Every chapter is anchored in a real story from my own career or from well-documented public cases. I don't believe in theory without context. These stories include a CFO whose first instinct was to cover it up (it got worse) and a CISO gone rogue by vibecoding his own solutions, and we will go through some real cases where executives faced personal or criminal liability for failures that took place on their watch.

Throughout the book we will come back to a set of questions that I started asking early in my consulting career. I started asking the questions to create tension without fearmongering. They are questions that force you to confront what you don't know, and the potential business impact if your assumptions turned out to be wrong.

The bank president in North Carolina didn't need a cybersecurity degree. He needed someone to translate. He needed letter grades, not acronyms. He needed to know where he stood, what it cost to get there, and whether he needed to do more.

CHAPTER ONE

Cyber Risk Is Business Risk

†

The CFO's first instinct was to make it go away.

I was sitting across from him in his office. A mid-sized, privately held company, hit with ransomware. It was his company. He was one of the principal owners. When we arrived, the attackers still had full access to the network and the company was still connected to the Internet. Nobody had done anything to stop the bleeding, because nobody knew what to do.

The CFO wasn't thinking about containment, he was thinking about his biggest clients. What would they think? What would happen to those relationships if word got out? His instinct, the natural one, was to sweep it under the rug.

I sat down with him privately and gave it to him straight: *"The damage is done. If we don't contain it and figure out what happened now, it will get worse and harder to deal with later."*

He was reluctant. But he agreed. And what followed was three days of hard work and hard conversations: disconnecting from the Internet, preserving forensic evidence, wiping and restoring the compromised systems, and deploying detection on every computer in the enterprise. Then, before we brought

anything back online, we raised one last concern. Their network clearly needed some work. They needed proper network segmentation and access controls. The sort of controls that should have existed before any of this happened. He said thank you, we need to get back online and we can talk about what else we need to do once we are back up and running.

When we were ready to bring the core systems back online, it was time for another hard conversation. To pay or not to pay the ransom. Negotiating with cyber criminals is a tricky thing. You can pay the ransom and they can release your data anyway. Or you can pay and they can breach you again because you missed a back door they created or another vulnerability they identified while they were in your network. They refused to pay the ransom.

The bad guys were not happy that they weren't getting paid for their work, so they did a data dump on the dark web. Among the files they dumped were screenshots of configuration files for the company's edge devices. Those screenshots showed something that made my stomach turn: default passwords. The factory-set credentials that ship with every device. They should have been changed before the device was connected to the production network, but there they were.

That dump led directly to a second breach, because now every threat actor on the dark web who cared to look, had the keys to the front door.

The Cover-Up Is Always Worse Than the Breach

The CFO is still there and the company is still in business, but there were a lot of difficult customer conversations after they recovered from the second breach.

I tell that story because the CFO's first instinct was to hide and hope nobody noticed. He was trying to protect his business. This is the single most dangerous response an executive can have to a cyber event.

Twenty years ago, the consequences of sweeping a breach under the rug were mostly reputational. If nobody found out, you might get away with it. That era is over.

Today, the cover-up carries criminal liability. Not civil, criminal. And the people being held accountable aren't abstract corporate entities paying fines from the company treasury. They're individuals. People with names and titles and careers that can be destroyed by a single decision made in the heat of a crisis.

The instinct doesn't appear from nowhere. The CFO had built a career on handling bad news inside the room before it reached anyone outside it. For most of his career, the bad news was the kind that could be handled that way because it was in his wheelhouse. He knew how to deal with a bad quarter or audit findings. The ransomware attack didn't fit in that category. The cost of putting it there is what the rest of this chapter is about.

Where the Decision Belongs

The spine of the book says cyber risk is business risk. That framing is right but not specific enough. The right kind of

business risk to compare it to is not market risk or financial risk in the abstract. It is business continuity risk. That is the operational discipline your organization already uses to think about what happens when the supply chain breaks down, the financial close gets disrupted, or the manufacturing line goes down. These things are not just technical problems; they can lead to catastrophic business disruption. That is the category cybersecurity sits in. And when you place it there, the implication for who makes the decisions changes.

You have probably seen the industry's breach-cost numbers. IBM puts the global average at \$4.4 million per incident, and about \$10 million in the United States. In my experience, executives hear a number that size and file it under insurance. The number is accurate, and it is misleading. It measures the cost of the response: the forensics, the lawyers, the notifications, the recovery work. For most of the incidents in that study, the business kept running while the cleanup happened. The average tells you nothing about what happens when the business stops.

In August 2025, attackers got into Jaguar Land Rover through social engineering, the same tradecraft criminals have used for decades. JLR shut its systems down to contain the damage, and global production stopped for more than five weeks. The company's disclosed incident cost was roughly £196 million. The UK's Cyber Monitoring Centre modeled the full economic damage at £1.9 billion, spread across more than 5,000 companies in the supply chain, and the British government backed a £1.5 billion loan guarantee to keep those suppliers alive while the lines

restarted. Press reports indicate JLR carried no cyber insurance. Put those two numbers next to each other. The incident-response bill was a tenth of what the event cost. The rest landed where continuity risk always lands: lost production, idle payroll, a supply chain gasping for cash. In the end a government had to step in.

Nothing about that attack required AI. Catastrophic business interruption arrived with yesterday's tradecraft, and the storm is only going to get worse. What AI changes is how often and how severely you will be tested.

A vulnerability your security team has identified but has not yet patched is an operational exposure. The window between knowing about that exposure and closing it is now measured in days. Five years ago, the time from public disclosure to active exploitation by criminal actors was the better part of two years. Mandiant's 2026 M-Trends report puts the average time to exploit at negative seven days. Exploitation now routinely begins before a patch even exists. With the emergence of frontier AI models, that time to exploit will continue to compress. Appendix E covers the drastic changes that compression is forcing, and details the specific actions enterprises are funding.

The average time an enterprise takes to remediate the exposure is five months. Attackers are acting within hours; defenders are still taking months to fix the problems. That is not a security metric, it is a business continuity metric and the math doesn't work. It is the equivalent of identifying a single point of failure in your manufacturing process and leaving it unaddressed

for months when there is a high probability it could go down in a day. If your COO presented that asymmetry at an operational review, the audit committee would call it a governance failure.

When it is framed that way, the decisions that follow shift from your technical team to your leadership team, because they are now measured as business risk. The discussion focuses on the business interruption, the impact and the time to recover. These are business resilience decisions, and they belong to the executives this book is written for.

This is the reframe that matters more than any other in this book. The trusted advisor's job is to provide information in a form the executive can clearly understand. The executive's job is to evaluate the information and decide what to do about it. Everything depends on those roles being clearly defined. In most organizations today, the security team is forced to make decisions it does not have the authority to make because the executives delegate decisions they cannot afford to delegate.

That delegation is what the rest of this chapter is about.

What follows are three executives who learned that the hard way.

Joe Sullivan, Former CISO of Uber

In 2016, Uber was breached. Attackers accessed personal data of more than 57 million riders and 600,000 drivers. Joe Sullivan, Uber's Chief Information Security Officer, made a decision. Instead of disclosing the breach as required, he arranged to pay the attackers \$100,000 through Uber's bug bounty program,

essentially disguising the ransom payment as a legitimate security research payout. He then had the attackers sign non-disclosure agreements.

The breach was concealed from regulators, from Uber's board, and from the public for more than a year.

In October 2022, Joe Sullivan was convicted on two federal charges: obstruction of an FTC investigation and misprision of a felony; specifically, the act of knowing about a crime and actively concealing it. This was not a regulatory action, he was convicted in a federal criminal trial. He was sentenced in May 2023 to three years of probation, two hundred hours of community service, and a fifty-thousand-dollar fine. In March 2025, the Ninth Circuit Court of Appeals affirmed the conviction. There is no path back for him.

Sullivan wasn't a rogue employee. He was a senior executive at one of the most prominent technology companies in the world, making a judgment call under pressure. The judgment was wrong and it cost him his career and his standing in a profession he had spent two decades building.

Timothy Brown, Former CISO of SolarWinds

In 2020, the SolarWinds supply chain attack, which was attributed to Russian intelligence, compromised the Orion software platform that thousands of organizations including U.S. government agencies relied on. In October 2023, the SEC charged Timothy Brown, SolarWinds' CISO, personally. Brown had raised internal concerns about the company's security

posture; the SEC alleged the external-facing statements were misleading.

In July 2024, the Southern District of New York dismissed most of the SEC's claims. In November 2025, the remainder were dismissed with prejudice. Brown was vindicated, but it cost him two years of his life.

James Cory Rellas, Former CEO of Drizly

Two CISOs. Now one CEO.

In 2022, the Federal Trade Commission settled an enforcement action against Drizly, an alcohol-delivery platform that had suffered a 2020 breach exposing the personal data of roughly 2.5 million customers. The settlement bound the company to specific provisions, which is standard practice for consumer-protection cases. What was new was that it also bound the CEO personally. James Cory Rellas, Drizly's chief executive, agreed to a personal consent order that follows him for ten years. If he takes a senior leadership position with any company collecting personal data on more than twenty-five thousand individuals, he is personally on the hook for implementing a comprehensive information-security program meeting the FTC's specifications.

The FTC's own statement explained the rationale: the order follows Rellas even if he leaves the company.

That order is now a template. Marriott's December 2024 consent order carried a twenty-year company term. Forty-nine state attorneys general piled on with a parallel fifty-two-million-

dollar settlement. The pattern is clear: when consumer data is mishandled, the regulators are no longer satisfied with a corporate fine that the company writes off and moves past. They want a senior officer's name on the order.

If you are a CEO reading this, the lesson is direct. Personal exposure is not a CISO problem you can delegate. It is your problem, and it travels with you.

The New Reality: Regulations with Teeth

Sullivan, Brown, and Rellas are not isolated cases. They are the leading edge of a fundamental shift in how cybersecurity failures are treated by regulators, prosecutors, and courts worldwide.

The regulatory frontier is exactly that. The law is being written in real time, by enforcement actions, by court rulings, by new directives entering force. The rules that bind you next year may not be the rules that exist today. You cannot plan around what the law will be. You can only take an approach that holds up regardless of how regulation develops.

Let me walk you through what's on the books right now.

Sarbanes-Oxley has been around since 2002, but its cybersecurity implications are becoming clearer every year. SOX requires that publicly traded companies maintain adequate internal controls, including over information systems. Executives who certify financial statements that rely on compromised systems can face penalties up to 20 years imprisonment. Twenty years. For signing a certification that your internal controls are adequate when your cybersecurity posture says otherwise.

The EU's Digital Operational Resilience Act (DORA) went into effect for financial institutions and sets explicit requirements for ICT risk management, incident reporting, and digital operational resilience testing. Fines against individuals can reach one million euros. Not against the company. Against you.

NIS 2, the EU's updated Network and Information Security Directive, enforced since October 2024, goes even further. It can impose personal fines on senior management and result in individual bans from holding management positions in the future. These are not problems you can make go away by writing a check, they are career-ending sanctions.

In the United States, the regulatory landscape is a patchwork that's evolving by the month. SEC cybersecurity disclosure rules now require public companies to disclose material cyber incidents within four business days. State-level privacy laws (California, Colorado, Connecticut, and more every year) create overlapping compliance obligations. And federal enforcement actions are increasingly targeting individuals, not just institutions.

Under Delaware corporate law, where more than half of U.S. public companies are incorporated, the channel of liability runs from the shareholders rather than the regulators, and it's getting wider. For a generation, directors have had a fiduciary duty to oversee what the courts call "mission-critical" risks. Recent rulings have extended that duty to senior officers within their areas of responsibility and have signaled that cybersecurity now counts as mission-critical for any company that depends on its systems to operate. Which is to say: every company. Shareholders who can show that the board or its officers failed to oversee cyber risk can sue them personally in derivative actions. The cyber-specific cases brought so far have mostly been dismissed at early stages, but the doctrinal door is open and federal courts have proven more receptive than the Delaware courts. A single sustained-failure case that survives a motion to dismiss will rewrite the playbook. The exposure is real.

The profession itself is already responding. Proofpoint's 2024 Voice of the CISO survey found that seventy-two percent of CISOs would not accept a position without adequate Directors and Officers insurance coverage. Nearly three out of four. A year later, Proofpoint's 2025 edition found that sixty-five percent of CISOs reported their organizations had taken concrete steps to protect them from personal liability.

The insurance industry is following the same trajectory: Aon, one of the largest global insurance brokers, now offers Side A D&O policies that explicitly name chief information security officers as Insured Persons. When the people responsible for

protecting your enterprise demand protection for themselves, and the underwriters reorganize their products to provide it, you are looking at two independent industry signals pointing at the same risk.

AI on Top of All of This

And then there's AI on top of all of this. There are currently over 1,000 AI-related laws, regulations, and policy frameworks worldwide. The EU AI Act is the most comprehensive, classifying AI systems by risk level and imposing requirements that range from transparency obligations to outright bans. The penalties for non-compliance can reach tens of millions of euros or a percentage of global revenue, whichever is higher.

Here's the part that connects back to personal liability. Many of these frameworks explicitly assign responsibility to senior management. If your organization deploys an AI system that violates the EU AI Act, after the fines are levied, there will be additional investigation into who did or did not meet their obligation to ensure compliance. Your CIO or CISO may be deposed, but they will not be the only ones facing charges or fines.

Enforcement of the EU AI Act is phasing in now, and the May 2026 omnibus deal pushed the high-risk rules out to late 2027. We have not seen the first case yet. We will.

What This Means for You

If you are a CEO, CFO, board member, or any senior executive with oversight responsibility for your organization's operations, you carry personal exposure for cybersecurity failures. That exposure exists whether you're aware of it or not. Whether you understand cybersecurity or not. Whether you think it's your responsibility or not.

These are not stories about incompetent executives. Sullivan was a former federal prosecutor before he became a CISO. Brown raised internal concerns about SolarWinds' security posture and saw the problems flagged in his own records. Rellas never wrote a line of code or security policy in his life, but he was the CEO. The FTC sanctioned him personally, for ten years, on the theory that responsibility for consumer data sits at the top of the org chart, not in the security team. Each of them made decisions, or failed to make them, under pressure that put them on the wrong side of regulations with real consequences.

The lesson is not that you should live in fear. You should be informed, engaged, and proactive because the worst decisions are made in a crisis.

Here's what informed and proactive looks like in practice. Know your regulatory obligations at the level where you can ask your legal and compliance teams the right questions. Ensure that your incident response plan addresses disclosure obligations, and that the decision to disclose is not made by the wrong person in a panic.

Have counsel confirm that your D&O insurance covers cyber events. Ensure the CISO is named on the personal-liability portion of your D&O policy (the Side A layer), and that your own exposure has been evaluated. Confirm that you have a forensic approach with two separate tracks (one for operational recovery and one for legal defense protected by attorney-client privilege) and that the structure is in place before the breach, not after.

"I left that to the security team" is no longer an acceptable answer when the regulators come calling.

Today, the executives who survive cyber events, both personally and professionally, were engaged before the crisis, not picking up the pieces after it.

Cyber risk is business risk. You can delegate the decision, but not the liability.

The rest of this book is about the questions you need to ask, the disciplines you need to adopt, and the informed decisions you need to make. We start with the questions in the next chapter.

For the role-by-role accountability map, the notification-clock cascade across jurisdictions, the four D&O insurance gaps, the privilege-architecture template, and a working list of questions to take to your General Counsel, see Appendix B.

CHAPTER TWO

Risk in Plain English



Let me take you back to that conference room in North Carolina. I opened this book with the bank president and his question, *"Do I need to be an A?"*

That decision he made, a B is enough, is the decision every executive has to make. What this chapter is going to give you is the language and the questions to manage cyber risk the way you already manage every other risk in your business.

You Already Know How to Manage Risk

This is not new territory for you. What is different is that the rest of your executive team communicates clearly giving you the information you need. The difference with cyber isn't the process for managing the risk, it is getting the right information in a language that is meaningful to you. You need to know if you are doing enough and if you are prepared for a business interruption caused by a cyber event.

Risk management in cybersecurity is conceptually identical to risk management everywhere else. There are four things you can

do with risk. You can avoid it, accept it, mitigate it, or transfer it. Ignoring it should not be an option.

The bank president accepting a B instead of pursuing an A was risk acceptance, done properly. He understood the residual risk, evaluated the cost to eliminate it, and decided the return wasn't worth the investment.

You can transfer risk by shifting the consequences to a third party using insurance, contract warranties and indemnification clauses, but the liability remains. I wrote a caveat emptor article for a trade magazine years ago. The managed security service business was booming. Companies were eagerly handing over responsibility for monitoring their security operations to third parties who were better suited and could do it for less than doing it in house. They thought they were transferring the risk to the service provider.

The problem is, when bad things happened, the service providers were only responsible for notification and triage, not incident response and recovery. Not only that but all of the legal and regulatory blowback as a result of the incident fell on the enterprise, not the service provider.

Avoid, accept or mitigate. Those are your practical options. The consequences of wrong decisions don't disappear, and the liability is on you.

So the question is not how to manage the risk. The question is how do you get the right information framed the right way so you and your executive team can make the right decisions.

The Three Questions

Early in my consulting career, I started closing every executive meeting with a set of questions. I was working in the risk and advisory practice of a Big 5 accounting firm, reviewing IT controls to support financial audits. Most consultants doing this work were junior auditors performing heads-down checklist interviews with CIOs. They were checking boxes and moving on. I'd been an IT director before I moved into consulting. I'd been responsible for the technology and the controls on the other side of the desk. So when I asked the questions on the checklist, I asked follow-ups: *Show me how that works. Show me how you do it.*

After completing an assessment of the overall security posture and controls and disaster recovery plan I'd have a closing meeting with the CFO. Somewhere along the way, I started asking the same three questions:

"Have you ever experienced a breach?"

In the late 1990s, the answer was almost always no. But the enterprises had their critical business systems and data running on networks that were inherently insecure. The "no" gave them a false sense of comfort. They hadn't been breached — or more accurately, they didn't know they'd been breached, which is not the same thing at all.

"How would you know if you had been breached or compromised?"

This is where the room would shift. The CIO might have a technical answer that points to log monitoring, intrusion detection, or whatever tools they had. But the CFO usually

couldn't answer. And the honest answer, for most organizations at that time, was: they wouldn't know. They had no detection capability that would tell them whether an unauthorized party was inside their systems.

"What would be the impact in financial loss, brand reputation damage, or market cap if your critical business systems were compromised and your data was exposed?"

This question turned their gut. Every time. Because now we weren't talking about technology anymore. We were talking about the CFO's world — money, reputation, shareholder value. The question translated cybersecurity risk into business language, and suddenly the abstract became concrete.

The CFOs rarely disclosed anything during those meetings. But I also knew they were on the phone thirty seconds after I walked out of their office.

Why the Questions Work

The power of those three questions isn't technical sophistication. It's the opposite. They work because they are simple and they force the listener to confront things they can't dismiss.

The first question is have you been breached? It establishes the baseline. Most executives answer confidently. No, we haven't. That confidence is often wrong, but the question isn't designed to prove them wrong. It's designed to get them on the record.

The second question is how would you know? This introduces doubt. If the answer to the first question is "no," the second question asks: are you sure? What's your basis for that

confidence? What would it look like if you were wrong? This is where the false sense of comfort starts to crack.

The third question is what would the impact be? That makes it personal. Not personally in the liability sense (we covered that in the last chapter), but personal in the business sense. This is your company. Your revenue. Your customers. Your reputation. If the answer to question two is "we're not sure we'd know," then the answer to question three is the cost of that uncertainty.

The questions create productive tension without fear-mongering. We live in a world where breach has to be assumed inevitable, but I've never used scare tactics or worst-case scenarios designed to panic someone into opening their wallet. That's not how I operate, and it's not how this book operates. The tension comes from the executive's own realization that their confidence and their capability don't align. I didn't create the gap. I just made it visible.

That's the consulting mindset that shaped my career. I didn't invent anything. I just learned, early on, that the right questions are more powerful than the right answers. The bank president used his questions to make the communication problem mine. He reframed the conversation to get the information he needed in a language he understood.

The Three Questions in the Age of AI

I've been asking some version of those three questions for over twenty-five years. The world has changed dramatically since the late 1990s. The threats are different and the technology has

evolved. The regulatory environment has become infinitely more complex and introduced personal liability for leadership failures. I have reframed the questions over time to maintain the desired outcomes as technology and our reliance on it have evolved. They force executives to confront what they don't know.

Here's how I'd update them for the conversation you need to be having today:

"Do you know where AI is being used across your entire organization; both authorized and unauthorized?"

This is the shadow AI question. In the 1990s, "have you been breached?" exposed a gap most executives didn't know they had. Today, this question does the same thing. Most executives will answer yes, they know where AI is deployed. And most of them will be wrong.

The marketing team's ChatGPT account, the product manager's vibe-coded AI tool. We haven't talked about vibe coding yet, but for now, let's say AI enables non-programmers to build applications on their own. Don't forget the financial analyst who is putting your non-public financial data into a model that isn't yours. AI is everywhere, and you almost certainly don't have full visibility.

"How would you know if an AI system was making a bad decision with your data, your customers' data, or your reputation?"

This is the detection question, updated. It's not just about attackers anymore. Your own AI systems can cause harm through bias, hallucination, data poisoning, or drift. A model that was

accurate six months ago may be producing subtly wrong outputs today, and nobody's caught it because nobody's checking. The "how would you know?" question now applies to your own tools, not just the adversary's.

"What would be the financial, regulatory, and reputational impact if your AI adoption went wrong, and who in your organization is accountable?"

This is the accountability question. I added "who is accountable?" because AI risk doesn't fit neatly into any one executive's portfolio. It crosses product, legal, operations, technology, HR, and compliance. If nobody owns it, nobody's managing it. And unmanaged risk, as we've established, doesn't go away because you've chosen not to look at it.

Ask them in your next leadership meeting and watch the room. The shift in body language will tell you everything you need to know about where your organization stands.

The "Do I Need to Be an A?" Framework

The bank president's question deserves its own section, because it captures the most important concept in cybersecurity budget decisions. And it's a concept that most security professionals are terrible at communicating.

There is a point of diminishing returns in cybersecurity investment. Not because security doesn't matter, but because risk exists on a curve, not a line. The first dollar you spend on security buys you the most risk reduction. You're patching the gaping holes, fixing the default passwords, building the basic controls.

Going from a D-minus to a C is relatively inexpensive and eliminates the most catastrophic exposures.

Going from a C to a B costs more per unit of risk reduction, but it's usually still a good investment. You're building layered defenses, implementing detection capabilities, creating incident response plans. The threats you're mitigating are real and the impact is significant.

Going from a B to an A costs significantly more, and the risks you're eliminating are less likely and less impactful. You're hardening against sophisticated, targeted attacks. You're building redundancy into redundancy. The security is genuinely better, but the business case for the incremental investment is harder to make.

And going from an A to an A-plus is the pursuit of perfection. It is almost never justified. The cost is enormous and the residual risk you're chasing is minuscule. Perfect security doesn't exist, and the attempt to achieve it will bankrupt your budget while other, more productive investments go unfunded.

The bank president understood this instinctively. "Do I need to be an A?" was his way of asking: is the additional investment justified by the additional risk reduction? And my honest answer is no, a B is right, earned his trust precisely because I didn't try to sell him something he didn't need.

This is the conversation every executive should be having with their CISO. Not "how much should we spend on security?" but "what level of risk are we willing to accept, and are we spending enough to get there?" The question lets us make the

decision with eyes open rather than throw money at security out of fear or underfund it out of ignorance.

What you need to do is create your own set of questions that work for you. I created mine sitting across from CFOs as a young auditor. The bank president had his own and they were rooted in his perspective as a bank president. The questions will evolve over time. Their purpose will not.

Demand the Translation

The bank president taught me that the problem is rarely a lack of security. It's a lack of clarity and translation. The security team has the information. The executive team has the authority. The gap between them is linguistic, not technical.

The dirty secret of the cybersecurity industry is that we've built an entire profession around making complicated things sound even more complicated. We have acronyms for our acronyms and dashboards and metrics that measure activity but don't communicate risk. And then we wonder why executives can't make good decisions about cybersecurity. They can't make good decisions because we haven't given them good information. We've given them our information, in our language, and then blamed them for not understanding it.

Your job as an executive is not to become a cybersecurity expert. It's to demand that cybersecurity be communicated to you in the language of business risk which is the same language you use for every other decision you make. Letter grades and

business impact with clear recommendations so you can make a decision.

If your CISO can't explain your security posture in a sentence you understand, that's not your failure, but it is your problem. You are the one who owns the risk, whether you can articulate it or not. And the regulators, as we saw in the last chapter, are not going to accept "my security team didn't explain it clearly" as a defense.

Demand the translation. Ask the questions. And when someone gives you a B, have the wisdom to ask whether you need to be an A, and the courage to act on the answer.

First, though, you need to see the territory you're managing that risk in. It is wilder than you think.

CHAPTER THREE

Welcome to the Wild West



The AI gold rush is bigger than the Internet boom.

That's not hyperbole. The Internet changed how businesses communicated, sold, and operated. AI is changing how businesses *think*. It is rewriting decision-making, customer engagement, product development, and operational efficiency at a pace that makes the dot-com era look leisurely. The promise is real: fundamental transformation of every industry and the way we approach work. Enterprises large and small are racing to deploy AI solutions. Everyone is looking for ways to use AI to automate workflows and do things that weren't possible even a year ago.

And just like every gold rush in history, the people charging ahead the fastest are the ones most likely to get hurt.

In the original Wild West, fortune seekers flooded into lawless territory with nothing but ambition and a pickaxe. Some struck gold. Many lost everything. Those who survived understood that the frontier required discipline, not just courage. Rules came later. Sheriffs came later. But the damage done in the lawless years took decades to undo.

That's where we are right now with AI.

Enterprises are venturing into uncharted territory without a map or a rulebook. The fear of being left behind is driving a new breed of AI cowboys. They are the individuals and teams that are deploying AI systems at breakneck speed without the planning or oversight they'd apply to any other IT initiative. They rationalize the decisions without considering the consequences.

Welcome to the Wild West of AI adoption.

In a moment I'll tell you about a CISO who became a cowboy. But first, let's cover some specific terms that will help you understand the story clearly.

Shadow AI: The Crisis You Can't See

Shadow AI is the unapproved, unauthorized adoption of AI tools outside the visibility of IT, security, and compliance teams.

Think it isn't happening in your organization? Think again.

Every major AI platform is available to anyone with a web browser and a credit card. Every one of your enterprise tools has an AI agent embedded and you don't get to opt out. Your employees and contractors are using them and you have no idea what data they are feeding these public models. The questions you need answers to now are: do you know where it is, who's using it, and what data is flowing through it?

Here's what's happening right now, in organizations just like yours: A marketing analyst uploaded the customer database into an AI tool to generate segmentation insights without realizing the data is now part of someone else's training set. Not only is the

data now in someone else's model, it is unlikely anyone will ever know it happened.

A product manager uses an AI coding assistant to build a quick prototype. It works well enough that it gets deployed to a staging environment and then to production. The code never went through QA, but it's live, handling data, and nobody besides the product manager knows it exists.

What if someone from finance feeds quarterly earnings data into an AI tool to help draft a board presentation? If you are a public company, you may have a securities disclosure problem.

These are not hypothetical scenarios, they are happening every single day. And the people doing it aren't bad people. They are trying to be productive and innovative. Their managers told them to move fast, find efficiencies, and embrace new technology. The problem is they were never given guardrails.

Vibe Coding and the Enterprise

There's a particular form of shadow AI that deserves its own attention, because it's the one most likely to create serious enterprise risk with the least visibility: vibe coding.

Vibe coding is the practice of using AI tools to write software, not in the context of developers using AI to accelerate coding, but non-developers using AI to build things they couldn't build on their own. It's the product manager or finance director from the previous examples. Worse yet, it is a CISO trying to build his own solutions to save on projects that are already budgeted and approved. Without policy and controls over these activities,

organizations are exposing themselves to risk disguised as good intentions.

For personal productivity, vibe coding can be powerful. If you want to automate your own workflow, organize your own data, or build a tool that only you use, more power to you. That's the promise of AI democratizing technology.

But there's a hard line between personal productivity and creating risk to the enterprise. When vibe-coded (pronounced unsanctioned) solutions touch your systems and data or make business decisions based on outputs that have not been validated, you've crossed it. The people crossing that line every day in your enterprise are some of your best employees. They want to contribute and the tool they built on their laptop last weekend works so well that they want to use it and share it with their peers.

The result is software running in your enterprise that was never authorized or tested. It was certainly never approved. These apps are being developed by people who don't understand the risk and consequences of what they are doing. This is the new shadow IT. It's orders of magnitude more dangerous than the old version, because the old version required at least some technical skill. Vibe coding requires none. The barrier to entry has dropped to zero, which means the volume of ungoverned technology in your enterprise is exploding under your watch.

The Sheriff Who Became the Cowboy

I want to tell you a story I can't attribute. I can't name the company, the industry, or the people involved. But I can tell you

this: it's a multi-billion dollar enterprise, and what happened there is not unusual. I am sure it is happening behind the curtain everywhere.

Our team had been working with this client to implement AI business use cases across their organization, carefully architected projects involving multiple business units, technology teams, and compliance stakeholders. The approach was deliberate: security and compliance were involved at every step, from architecture and design through go-live. Security was treated as table stakes, not an afterthought. The result was AI solutions that actually made it to production, with the proper controls in place for the organization to stand behind them.

Then the CISO started cutting back the scope of the projects.

Not because they were the wrong projects or because budgets or priorities changed. The CISO (the Chief Information Security Officer, the person whose entire job description is to protect the enterprise from risk) had been vibe coding in his spare time. He'd been experimenting with AI tools, building things on his own, and he decided he could do it himself. Why pay for carefully orchestrated AI deployments when he could build it himself?

Let that sink in. The sheriff became the cowboy.

The person responsible for ensuring that every technology initiative in the enterprise meets security and compliance standards was now bypassing the very disciplines his own role exists to enforce. No architecture review. No cross-functional coordination. No security assessment of his own work. He was deploying AI solutions with access to enterprise data, customer

data, operational systems on the strength of his own enthusiasm and a few weekends of tinkering.

This was finally addressed at the right level, but every day that passed while it was an active situation created unmeasured risk, and the person who should be measuring and managing it was instead contributing to it.

I tell this story because it shines a light on a problem most companies don't even know they have. The CISO ignored the rules and did what he thought was right to save the company money. If he can go cowboy, anyone in your organization can.

The Speed of Adoption

What makes the AI frontier different from previous technology shifts is the speed.

Cloud computing took a decade to move from early adoption to mainstream enterprise deployment. Mobile took nearly as long. Even the Internet, which felt fast at the time, had a multi-year runway where enterprises could evaluate, pilot, and gradually adopt.

AI isn't giving you that runway. The tools are available now to anyone with a credit card or access to your enterprise applications. That means your employees are already using them. Your competitors are racing to be early adopters of AI so they don't get left behind. And while all the good guys are using AI for good, there are bad actors at work, weaponizing AI for nefarious purposes.

Adoption speed varies by industry with insurance and banking showing caution and risk aversion when it comes to new technology. Born-digital companies and tech startups are moving fast and looking for ways to disrupt markets. Unfortunately, even those exercising caution are finding their employees aren't waiting for official policy. Shadow AI doesn't care about your adoption timeline.

Operating without visibility and AI governance is risk to your data, your compliance posture, your reputation, and increasingly, your personal liability as an executive. The clock is running.

Tribalism on the Frontier

There's one more dimension of the AI frontier that most executives never see, and it may be the most insidious: tribalism.

Inside large organizations, technology teams operate in silos. Always have. The networking team doesn't talk to the application team. The data team doesn't talk to the security team. Most organizations have learned to work around it, imperfectly, but functionally.

AI has turned that imperfection into a crisis, because an AI use case touches every one of those silos at once. A legitimate, well-planned use case dies waiting for a security review that never comes, while two floors up an unsanctioned AI tool is running and nobody in security even knows it exists.

Tribalism turns the AI governance problem from a technology challenge into an organizational one. And organizational problems don't get solved with better tools. They

get solved with better leadership. In Chapter Six, we'll look at what happens when the compliance team and the security team are solving different problems and nobody in the room knows it. In Chapter Seven, I'll show you how to break through the silos by putting a sheriff on the frontier.

Three Questions for Monday Morning

Before you turn to the next chapter, here are three questions for your next leadership meeting. I don't expect you to know the answers. The purpose of the exercise is for you to see how confident your team is with theirs.

First, if a marketing analyst uploaded our customer database into ChatGPT yesterday, would anyone have caught it by this morning? Not "would IT eventually notice." Not "would a quarterly audit catch it." Today. By this morning.

Second, is there a vibe-coded application anywhere in our organization that is processing production data?

Third, are we confident that the output of every AI model we are using is being validated before we make decisions based on the output?

If they can't answer with confidence, you have a problem.

The Wild West of AI adoption is not a metaphor. It is the operating reality of most enterprises today. The cowboys are already riding. The question is whether you're going to keep watching from the window, or whether you're going to put a sheriff on the frontier. Because when something goes wrong out there, it's your name on the filing.

CHAPTER FOUR

The Genie Is Out of the Bottle



In the last chapter, I told you about the cowboys. They are the people inside your own organization creating risk through ungoverned AI adoption. That's one side of the equation. Now let me tell you about the other side.

The people trying to break into your house just got a set of tools that would have made a nation-state intelligence agency jealous five years ago. And they didn't need a billion-dollar budget to get them. They needed a laptop and an Internet connection.

What we are seeing in AI adoption by bad actor groups is unprecedented. And the bad guys are moving at machine speed. The entire attack chain, from the first moment an adversary starts researching your organization to the moment malware is living inside your network, has been supercharged by artificial intelligence.

Let me walk you through it. You can't ask the right questions if you don't know where to start, and you can't evaluate what your team is doing if you don't understand the scope and scale of the problem.

The cybersecurity industry uses a framework called the Cyber Kill Chain, developed by Lockheed Martin, to describe the stages of an attack from beginning to end. There are seven stages: reconnaissance, weaponization, delivery, exploitation, installation, command and control, and actions on objectives. AI has transformed every single one of them.

Stage One: Reconnaissance

Every cyberattack begins with research. Before anyone tries to breach your network, they study you. They look at every bit of open source intelligence available and anything they can find on the dark web. Using automated search tools and purpose-built AI agents, they can compile and study your entire online presence — literally, anything that is externally visible about you and your company. In the old world, this was labor-intensive work that would take months to compile and organize. Today it is fully automated with agentic AI.

The data is not only compiled in minutes, but the attack plan is built and ready to execute.

Artificial intelligence can automate reconnaissance across vast quantities of open source intelligence: publicly available information that, individually, seems harmless but collectively paints a detailed portrait of your attack surface. How many job openings do you post that require experience with some specific technology or enterprise application? That is information they can use.

None of that information is secret. All of it is useful. And AI can correlate thousands of these data points across dozens of sources faster than any human team ever could. The intelligence that used to take a sophisticated threat actor group weeks to assemble can now be generated in minutes, not by a team of analysts, but by a single person with access to the right AI tools.

While nation-state actors have gotten faster, the barrier to entry has collapsed. The level of reconnaissance that used to require the resources of a well-funded intelligence operation is now available to anyone with moderate technical skill and a weekend to spare. Not only has the playing field changed, but the players have too.

Stage Two: Weaponization

Before an attacker can use any of that intelligence, they need a way in. They need a flaw to exploit somewhere in your stack, a vulnerability in your software, your infrastructure, or your supply chain. For most of the history of cybersecurity, finding usable flaws was specialist work. It was what nation-state intelligence agencies did with rooms full of researchers, and what a small number of criminal groups bought from the people who had done it.

That changed in 2025.

In November 2024, Google's Big Sleep AI agent discovered the first verified security flaw ever found by an AI. That is a flaw nobody knew existed, which means no fix existed either. This one

was buried in SQLite, the most widely deployed database engine in the world, and human researchers had missed it.

That was the opening shot.

Through 2025, Big Sleep continued finding flaws in production software at a steady rate. In parallel, the AI security firm AISLE found more than one hundred and eighty confirmed vulnerabilities in the open-source software most enterprises depend on.

Then the scale jumped.

In August 2025, DARPA ran the AI Cyber Challenge finals at DEF CON, the world's largest hacking conference. Seven autonomous AI systems processed fifty-four million lines of code in about a hundred and forty hours and surfaced eighteen previously unknown real-world vulnerabilities.

In April 2026, Mozilla and Anthropic disclosed two hundred and seventy-one bugs in a single evaluation of the Firefox browser's code. Mozilla shipped the patches in Firefox 150. The previous year, Mozilla had handled roughly seventy-three Firefox vulnerabilities total. One AI evaluation found more bugs in a single pass than human researchers found in twelve months.

If you read that and assumed it requires a cutting-edge AI model the average attacker cannot access, the news is worse than that. In April 2026, AISLE tested the same flaws against twenty-five smaller and cheaper AI models from every major lab. The smallest models found the same bugs. The cost was roughly one hundredth of what the most expensive model charges. That equates to pennies, not dollars. The capability is not gated by

money or by access. It is gated by knowing how to build the system that points the AI at code, and that knowledge is now publicly published.

In May 2026, Google's Threat Intelligence Group reported the first documented case of an AI-built attack tool being used against a real target. The code was clean, well-organized, and structured like a textbook exercise, which is exactly how Google's analysts recognized it as AI-generated. In the same report, the group noted that exploiting software flaws had overtaken stolen passwords as the primary way attackers broke into cloud systems for the first time. Forty-four and a half percent of investigations versus under three percent the year before.

The systems built around the old assumption are visibly buckling. On April 15, 2026, NIST formally acknowledged that the National Vulnerability Database had fallen behind the volume of submissions. Submissions had grown two hundred and sixty-three percent between 2020 and 2025 and were forecast to grow another forty-five percent in 2026. The reference data your defenders depend on to decide what to fix first has been quietly retreating from the universal coverage it offered for the last twenty years.

An entire stage of attack work, finding usable vulnerabilities and building weapons around them, has moved from specialist craft to commodity capability on both sides at the same time. Defenders are using AI to surface and patch bugs at a pace no human team could match. Attackers are using AI to find new ways in faster than the patches can ship. The defender's stack was

built for the world where finding bugs was hard. That world ended somewhere in 2025.

Stage Three: Delivery

Armed with that intelligence and those weapons, the attacker has to get them to the target. That is delivery. And this is where AI has done the most visible damage.

Social engineering is the art of manipulating people into giving up information or access. People have always been the weakest link in the security program, so it remains one of the most used and effective attack vectors. Forget the Hollywood image of a hacker furiously typing code. Most breaches start with a person and a legitimate-looking email with an embedded link that they are compelled to click on, or a phone call from the help desk or a senior executive that sounds legitimate.

For decades, we did end user training so they could spot the obvious tells of poor grammar and requests that didn't quite make sense. We told them to trust their instincts and report anything that looked suspicious. It was good advice and reduced the number of incidents, because most phishing attempts had rough edges that an alert person could catch.

AI erased those edges.

Today's AI-generated phishing emails are grammatically perfect, contextually relevant, and personalized to the recipient using the reconnaissance data gathered in Stage One. They reference real people and projects. The email that used to scream

"this is a scam" now reads like a perfectly normal message from your boss.

And it's not just email anymore.

Vishing, or voice phishing, has been transformed by AI voice cloning. An attacker can take a few minutes of publicly available audio from a conference keynote, a podcast interview or an earnings call and generate a synthetic voice that is virtually indistinguishable from the real person. When the CFO picks up the phone, he hears the CEO on the other end demanding an urgent wire transfer, "trust your gut" doesn't work anymore. Your gut says that's the CEO. Your gut is wrong. The wire transfer that goes out is on the CFO who authorized it, not on the AI that made the call.

Deepfake video has crossed the same threshold. Video calls that appear to show a real person, maybe a colleague, a client, a board member. They can be generated in real time. We are approaching a point where seeing and hearing are no longer believing. The basic human instincts we've relied on for thousands of years to determine who we're talking to are being systematically undermined by technology.

These attacks are already working against well-defended organizations. The social engineering that used to require a skilled con artist with deep knowledge of the target can now be executed by anyone with an AI tool and the output of an automated reconnaissance scan or access to the dark web and cryptocurrency to pay someone else to do it. The volume of attacks that can be generated is exponentially larger than it was

even a year ago, and the quality of each individual attack has improved dramatically at the same time.

Stage Four: Exploitation

Let's say your people don't click the link. Let's say your training held, your email filters caught the phishing attempt, and the attacker's social engineering play failed. That doesn't mean delivery failed. It means one delivery method failed. The attacker still has the weaponized exploit from Stage Two and dozens of other ways to get it into your environment.

Exploitation is the moment the weapon fires. The attacker triggers the vulnerability, and the payload executes on your system.

AI is being used to craft the payloads, the malicious code itself. The newest ones are specifically designed to evade your security tools. Not generically designed. Specifically designed. For your tools. Based on the reconnaissance from Stage One.

Traditional security tools work on pattern recognition. They've seen a million pieces of malware, they know what malware looks like, and they flag anything that matches known patterns. It's the same principle as an immune system. When you get exposed to a virus, your body learns to recognize it, and the next time it shows up, your defenses activate.

AI-crafted payloads don't match known patterns. They're generated fresh, designed to look like legitimate traffic, legitimate files, legitimate behavior. They're built to slip past the specific

detection tools the attacker knows you're running because they did their homework in Stage One.

We have been playing a cat-and-mouse game with attackers for years. We build a better mousetrap, they build a smarter mouse. The problem is, their mouse just got a lot smarter and can adapt to avoid our traps.

This is where the arms race gets serious. Security vendors are using AI to improve detection. Attackers are using AI to improve evasion. The tools are getting smarter on both sides, but here's the uncomfortable truth: the attacker only needs to get it right once. The defender needs to get it right every time. That asymmetry has always existed in cybersecurity. AI has amplified it.

Stage Five: Installation

Once the exploit fires and the payload executes, the attacker's first priority is to establish a permanent foothold in your environment. Installation is where the breach becomes a persistent presence.

Traditional malware was relatively straightforward. An infection vector like a corrupted file would leave a malware executable that ran every time the computer booted up. Users would report the problem, their security provider would analyze it and come up with a signature to detect it and a removal tool. The cycle was predictable, and defenders could keep up.

Modern malware no longer works that way. It relies on droppers and downloaders that distribute malware modules in

stages, making it far harder to detect the full scope of an intrusion. Fileless malware operates entirely in memory, leaving no files on disk for traditional antivirus to scan. AI has made these techniques adaptive so the malware can assess the environment it has landed in, determine which persistence mechanisms are least likely to be detected, and modify its installation approach on the fly.

Polymorphic malware is code that can rewrite itself to avoid detection. It has moved from research papers into the wild. The malware changes its own signature every time it copies itself, so no two instances look the same to your detection tools. The signature-based scanning your team has relied on for twenty years was built for malware that looked the same twice. This doesn't.

Stage Six: Command and Control

With a persistent foothold established, the attacker needs to maintain communication with the compromised system. The command and control stage is where the malicious software calls home to receive instructions: what data to exfiltrate, where to spread, what to do next.

For decades, this was the defender's best opportunity to stop an attack in progress. If you could identify and sever the connection between the malware and its command and control server, you could often contain the damage. Cut the puppet's strings and the puppet stops moving.

AI-powered malware doesn't need to call home.

This is the stage that keeps security professionals up at night. Fully autonomous malware that can assess the environment it's in, determine the best path to its objective, and make decisions on the fly without relying on a human operator for instructions. There are no strings to cut. The malware is its own decision-maker, adapting in real time to the defenses it encounters. Unlike a human attacker, it never sleeps.

Think about what that means operationally. Traditional incident response playbooks assume there's a human on the other end making decisions. You cut the command and control channel to slow them down and force them to adapt manually. Against autonomous malware, that playbook doesn't work. The response framework your team has drilled on was built for an adversary that needs to phone home. That adversary is being replaced.

Stage Seven: Actions on Objectives

This is the endgame and the reason the attacker went through every previous stage. The objective depends on who is behind the attack, but the categories are predictable: steal data, deploy ransomware, disrupt operations, or establish long-term access for future exploitation.

We are entering an era where the malware inside your network may be smarter in the narrow operational sense than the tools you deployed to stop it. Not because your security team isn't talented or you haven't invested in the right tools, but the attacker's AI doesn't have the same constraints your security tools

do. Your tools are tuned to avoid false positives and protect legitimate business operations. The attacker has one mission: get in and avoid detection. After that, it is focused on stealing anything it can exfiltrate and sell on the dark web or ransom back to you.

And the speed at which this final stage executes has changed. What used to take an attacker days or weeks of careful lateral movement and data staging can now happen in hours. AI-powered attacks can identify the highest-value targets in your network, move laterally across systems, and exfiltrate data at a pace that most security operations centers cannot match with human analysts alone.

The Democratization of Sophisticated Attacks

Every stage of this attack chain has one thing in common: AI lowered the barrier to entry.

Five years ago, the kind of attack I just described — automated reconnaissance, AI-generated social engineering, evasion-optimized payloads, autonomous malware — used to be the exclusive province of nation-state actors. The resources required to execute this kind of campaign were measured in millions of dollars and dozens of specialized personnel. If you weren't a government target, you probably weren't facing this level of adversary.

That world is gone.

AI has democratized advanced cyberattacks the same way it's democratizing everything else. A mid-tier cybercriminal group

that used to send out bulk spam and hope for a few hits, can now execute targeted campaigns against specific enterprises with a level of sophistication that used to require a military intelligence budget. AI gave the weakest attackers the same capabilities as the best ones.

This has profound implications for how you think about your own defenses. If you're a mid-sized company, you cannot assume that the top bad actor groups limit their attacks to Fortune 500 targets. With AI and automation, they are now offering their services for hire. That means criminals don't need to know how to build the attacks to use them. They need some cryptocurrency and access to the dark web.

Everything you did yesterday is already stale. The assumptions you have been operating under about who is targeting you and how to defend against them were probably wrong when they were written. They are definitely wrong now.

The Only Answer

I don't want to leave you in a dark place. The picture I've just painted is real, but it's not hopeless. Because there's a fundamental truth on the other side of this equation:

The only tool we have to combat AI in the hands of bad actors is AI in the hands of sophisticated defenders.

The same artificial intelligence that powers the attack chain also powers the defense. With AI-driven behavioral analytics, we can detect anomalies and malicious patterns in network traffic that human analysts would never see. With automated response

systems, we can contain threats in seconds rather than the hours or days it would take without them. The thirty-year struggle to find the needle in the haystack has been to process and correlate the vast amounts of data flowing across an enterprise network and find the signal in the noise. We finally have a tool that's up to the task.

But, and this is the essential point, those tools require investment. They require skilled people to deploy and manage them. They require a security approach that uses AI to do the work that wasn't possible to do with people, not one that's running on twenty year old architecture. The defenders need the same caliber of tools as the attackers, and right now, in most enterprises, they don't have them.

Underfunding your security team in 2026 isn't just negligent. It's bringing a knife to a gunfight.

The genie is out of the bottle.

CHAPTER FIVE

It's Not IF, It's WHEN



I got the call on a Tuesday.

A large retail and e-commerce enterprise with more than a thousand employees. All of their revenue was generated online, so every hour of downtime had a dollar figure attached to it. They were down hard. Their primary storage array, which hosted all of their websites, applications, and data, was completely offline. Nobody could tell me exactly what had happened yet, because nobody inside the organization could figure it out. By the time I arrived, the panic had already set in.

What I found was a perfect storm.

It wasn't a single failure, it was a cascade of configuration errors, unapplied patches, and multiple hardware failures that were statistically improbable. When it came crashing down, the thing that turned a bad day into a catastrophic week was they hadn't prepared for this. There was no disaster recovery plan and nothing to fail over to. They thought the redundancy in the storage array was enough. They never expected multiple drive failures at one time. There was no documented procedure for what to do when the unthinkable happened because the

unthinkable, by definition, was something they'd never considered.

They were completely offline for six days. By day seven, they had their e-commerce site back online, but it took another week to get everything fully restored.

It was six days without revenue or communications with their customers and partners because not only were all of their apps and data on the local storage array, they had just finished moving to a Voice over IP (VoIP) system. It could not have been much worse. During that time, the leadership team sat in one conference room and the technical team sat in another. They were staring at each other and the best they could come up with was *this can't be happening*.

But it was happening. And the reason it was happening wasn't because they'd been targeted by a sophisticated adversary or hit by some novel zero-day exploit. It was happening because of the most mundane failures in IT: poor hygiene, deferred maintenance, and the assumption that because nothing bad had happened yet, nothing bad was going to happen.

The Probability Trap

Here's what I see over and over again with enterprise leadership. They understand risk conceptually. They deal with risk every day in other domains: financial risk, market risk, regulatory risk, operational risk. They hire actuaries, they buy insurance, they run stress tests. They are not naive people.

But when it comes to cybersecurity, there's a cognitive trap that even smart executives fall into. I call it the probability trap: because a serious breach hasn't happened to us yet, the probability must be low. And if the probability is low, we don't need to invest in preparing for it.

The retail enterprise that was down for six days had fallen squarely into this trap. The convergence of failures that brought them down was more than unlikely. But unlikely is not impossible. When you're running a business that depends on technology for every dollar of revenue, you have to prepare for catastrophic events and have a plan for recovery.

When success is a non-event, the probability trap is self-reinforcing. Every day nothing bad happens is another data point that confirms the bias. *Since we haven't been breached and our systems are running, the business is fine and we were right not to worry about it.* This conversation takes place between CFOs and CISOs all the time.

The thing about cybersecurity risk is that you usually don't see early warning signs. By the time you notice there is a problem, it is already too late. Financial risk gives you signals (declining revenue, contracting margins, market shifts) that tend to follow trends. Cybersecurity risk is unpredictable. Everything is running as usual and then the help desk starts lighting up and users are reporting their systems are locked and there is a message on the screen demanding ransom. Or you go from normal baseline traffic to detecting unusual patterns that turn out to be an attacker in your network. The transition from "we're good" to

"we're down" can happen in minutes, and without the warning signs executives are used to working with.

That's what makes the probability trap so dangerous.

Denial Is Not a Strategy

When I walked into that enterprise on day one, the first thing I encountered wasn't a technical problem. It was a human one.

The leadership team was in denial. Not the quiet, private kind. The active, out-loud kind. "This can't be real." "This doesn't happen to companies like us." "How is this possible?" They were spending their mental energy on disbelief rather than response. And every minute they spent asking how it could have happened was a minute they weren't spending on making it stop.

I've seen this reaction more times than I can count, and I want to be clear about something: I don't judge it. These are capable, accomplished people who built a successful enterprise. Denial in the face of a catastrophic, unexpected event is an entirely human response. It's the same reaction you see in any crisis: natural disaster, medical emergency, financial collapse. The mind resists the new reality because the new reality is worse than the old one.

But denial has a cost, and in a cybersecurity event, the cost compounds by the hour. While leadership was processing their disbelief, the systems were still down. Customers were still locked out. Revenue was still hemorrhaging. And in many breach scenarios (though I'm simplifying this particular case) the attackers may still be inside, still exfiltrating data, still expanding

their foothold. Every hour of inaction is an hour the damage gets worse.

The enterprises that survive cyber events still get breached, they are prepared and have a plan. When the call comes on Tuesday, leadership knows who to call, what to do first, and how to shift from "this can't be happening" to "let's stop the bleeding" in minutes, not days.

The retail enterprise didn't have that. From the time the systems went down to the time a coherent response began was days. And every one of those days cost them: in revenue, in customer trust, in reputational damage, and ultimately in leadership positions. People lost their jobs. Not because they caused the failure, but because they hadn't prepared for it and couldn't respond when it came.

The Dwell Time Reality

The six-day outage was dramatic: visible, painful, impossible to ignore. But most cyber events don't announce themselves that loudly. Most of them don't announce themselves at all.

Here's one of the uncomfortable truths of modern cybersecurity: most attackers are already inside your network before you know anything is wrong. The industry calls this "dwell time," the period between when an attacker gains access and when the organization detects their presence. And the numbers are sobering.

The median dwell time across industries has historically been measured in months. You read that correctly, months. An

attacker gets in, establishes a foothold and multiple back doors. Then they start moving laterally, mapping your network, escalating their privileges, accessing and exfiltrating your data while your security dashboards show green across the board.

The disconnect between executive confidence and operational reality is enormous. I have sat in rooms where the CISO presents a clean security dashboard with no alerts, incidents or red flags, and there were nods of approval around the room and they moved on. I've sat in those same rooms six months later, after a breach is discovered and everyone asks, "How did this happen? We thought we were fine."

You thought you were fine because you were relying on your tools. The tools were looking for known threats, while the attacker was using unknown methods. Your dashboard showed no alerts because the attack was specifically designed to avoid triggering them.

A clean dashboard doesn't mean you're clean. It might mean your detection capabilities aren't good enough to see what's already inside.

A Sophisticated and Determined Attacker Will Always Find a Way In

This is the sentence that nobody in a leadership position wants to hear, and it's the sentence I've been saying for thirty years: a sophisticated and determined attacker, given enough time and motivation, will always find a way in.

Always.

I don't say that to frighten you. I say it because understanding it is the foundation of every good security decision you'll ever make. If you believe that perfect prevention is possible (that you can build a wall high enough that nobody will ever get over it) you'll invest everything in the wall and nothing in detecting the people who are already on the other side of it. And that's exactly the mistake most enterprises make.

Security is not a single line of defense. A properly architected approach to security is layered. Think of it less like a castle with a moat and drawbridge and more like a series of checkpoints, alarms, and containment zones. Modern networks are distributed cloud environments, so there is no single defensible perimeter anymore. The best we can do is make it difficult enough that the attacker needs time, and to use that time to detect and contain them before they reach anything that matters.

This is what the retail enterprise was missing. When the cascade of failures hit, there was nothing between "everything is fine" and "everything is down." No early warning, just a binary switch.

Enterprises that handle cyber events well, and many do, accept the inevitable. They know they can't prevent everything, so they prepare with contingency plans and practice. They invest in the things that matter when prevention fails: detection, response, containment, and recovery.

The question isn't if it will happen. It's will you know when it does and will you be ready.

AI Compresses the Timeline

Everything I've just described (the probability trap, dwell time, the layered defense model) existed before AI entered the picture. These are foundational truths of cybersecurity that have been true for decades. But AI changes the math in a way that makes every one of them more urgent.

In Chapter Four, I walked you through the AI-powered attack chain. Every stage of that chain is faster than its human-driven predecessor. Reconnaissance that took weeks now takes hours. Social engineering campaigns that required a skilled operator can now be automated at scale. Payloads that needed manual customization are generated on demand. Malware that relied on human command and control now operates autonomously.

What this means for you: the timeline between an attacker choosing your organization as a target and being inside your network has collapsed. So has the timeline between disclosure of a new vulnerability and the first attempt to exploit it. Five years ago, industry research measured the median time between a security flaw being publicly reported and an attacker building a weapon around it at seven hundred and forty-five days. By 2025 it was forty-four. By early 2026, the time between disclosure and active exploitation had collapsed to five days. The average enterprise still takes five months and ten days to apply the fix.

Read those numbers again. Five days to exploit. Five months to patch.

And it cuts both ways inside your network. An AI-powered attacker is not going to spend months quietly mapping the environment the way a human operator did. The dwell time numbers you read about in last year's reports are already too generous for this year. If your leadership's first response to a crisis is still a day of denial (the way it was at the retail enterprise) you have lost ground you may not get back.

AI doesn't change the fundamental truth that a determined attacker will find a way in. It changes how fast they get there, and how little time you have to respond. The playbook is the same. The tempo isn't.

The Questions You Need to Answer

I want to leave you with three questions. Same format as the last two chapters. Same intent: not to scare you, but to make you think honestly about where you stand.

If a critical system went down today, do you have a documented, practiced incident response plan, and does your leadership team know their role in it? Not a plan that exists in a binder somewhere. A plan that's been tested, practiced, and updated within the last year. If you don't have one, the six-day outage story is your future.

How long would it take your organization to detect an attacker who was already inside your network? Not to detect a known attack. To detect a sophisticated adversary who is deliberately avoiding your security tools. If you don't know the

answer, or if the answer is "we assume our tools would catch it," you have a dwell time problem you can't see.

Have you stress-tested your assumptions about what "can't happen" to your organization? Every enterprise that ends up in a crisis had a reason to believe it wouldn't happen to them. The retail enterprise thought the probability was too low. The probability was low. It happened anyway. What's your version of "it can't happen to us," and what if you're wrong?

The world described in these first five chapters is the world you're operating in right now. The cowboys are inside your organization. The attackers have AI. And the difference between what you think you know about your security posture and what's actually true may be greater than you realize.

In the next chapter, we're going to start closing that gap, starting with the difference between compliance and security, and why passing the audit doesn't mean you're safe.

CHAPTER SIX

Compliance vs. Security



Remember the company that got hit with ransomware twice, back-to-back? We talked about them in Chapter One. There was one detail in that case that bothered me more than anything else. The first breach could have happened to anyone. The second was totally self-inflicted.

Even though we were able to contain the attack and recover the systems and data from backup, we were certain that attackers had copied most of the company's data out before we got there. It was a hard conversation with the CFO, because the ransom demands were very clear: *Pay us or we will release your data*. The company decided not to pay.

When the data dump landed on the dark web, we reviewed it all. The files included screenshots of the configuration pages for all of their routers and firewalls. Every one of them still had the default passwords, the ones that ship in the manual and get changed before the device ever touches a network. But there they were, on production boxes connected to the Internet.

It was totally avoidable. But the part that should bother you the most is they had just passed an audit. They may not have

passed every auditor's examination; they would not have passed mine. But if they had a junior auditor working off a checklist reviewing controls, he was asking questions and checking boxes.

Here's the thing, depending on the audit, the scope should be based on industry-standard frameworks that outline specific control areas and controls required for compliance. They all include requirements for passwords and all of them specify that default passwords must be changed. The auditor probably asked them if they have a password policy and if passwords are required to be changed on a periodic basis. Nowhere in that interview was that auditor instructed to verify the answers to the questions he was asking.

The vulnerabilities that live between the checklist and reality are where breaches happen.

The Floor, Not the Ceiling

Compliance and security are not the same thing. They're related, and in a well-run organization they reinforce each other. But they serve different purposes, they measure different things, and confusing one for the other will get you in trouble.

Compliance tells you what you must do. It's the minimum standard defined by an external authority. That could be a regulatory or industry body or a contractual requirement. We will cover regulations more in the appendix, but there are a lot of them and more appearing every year. SOX tells you what controls you need around your financial reporting systems, HIPAA tells you how to protect health information. In May of

2026, the EU reached agreement to amend the EU AI Act with the Digital Omnibus on AI. Every one of these should be considered floors, not targets. They define the minimum acceptable standard, and falling below them carries penalties.

Security is not the checklist. It's the actual measured performance of your defenses against the real-world threats you face. Security is about understanding your attack surface and the most likely types and vectors of attack and preparing for them. Understanding no defenses are one hundred percent effective, you need effective detection systems in place to identify anomalous events and detect intruders before they can cause real damage.

The floor and the ceiling are never in the same place. A company that meets every compliance requirement and stops there has met the minimum. An attacker who targets that company doesn't care about the minimum. The attacker cares about the gaps, and they are almost always above the compliance floor.

I've seen this play out dozens of times. A company passes its annual audit with flying colors. The board receives the report, notes the clean bill of health, and moves on. Six months later, the company is breached. The board asks, reasonably: how is this possible? We passed the audit.

The answer is simple. Audits measure compliance, attackers exploit security vulnerabilities.

The Checkbox Mentality

The checkbox mentality deserves deeper treatment because it's so pervasive and so dangerous.

It works like this: the organization has compliance requirements which are translated into a list of controls. The security team (or more often, the compliance team) verifies that each control is in place. A report is generated and presented to leadership, who see green across the board and conclude that the organization is secure.

Every step in that process is reasonable and the conclusion is still wrong.

Here's why. Compliance frameworks are designed to be broadly applicable. They need to work for a fifty-person startup and a fifty-thousand-person enterprise. Global companies with distributed cloud infrastructure are not the same as a small manufacturing business running all of their servers in a closet in their own building. To achieve that breadth, the frameworks have to be general. They define categories of controls (access management, encryption, monitoring, incident response) without specifying exactly how those controls should be implemented for your specific environment.

That generality creates wiggle room. A password policy exists, but nobody checks whether it's enforced. An incident response plan is documented, but it's never been tested. The list goes on. Each of those controls checks a box. None of them actually protects the enterprise.

Audit-Driven Security

There's a related pattern that I see in organizations where compliance has become the primary driver of security investment. Let's call it audit-driven security, the practice of only fixing what the auditor found.

It works like this. The auditor documents findings in their report. They capture gaps, weaknesses, areas of non-compliance. The organization prioritizes remediation of those findings because they're documented, they're tracked, and the auditor will check on them next year. The security budget flows toward fixing audit findings. Other security work that addresses real risk but wasn't flagged by the auditor gets deprioritized or unfunded.

Over time, the organization's security posture becomes shaped entirely by the audit, not by the actual threat landscape. You're secure against the things the auditor checks. You're potentially wide open to everything else.

This is like studying for a test by memorizing last year's questions. If the test is the same, you'll pass. But the threat landscape isn't a test with a fixed set of questions. The attackers didn't read the audit framework and they don't limit themselves to the categories the auditor evaluates. They look for any gap, anywhere. And in these organizations, the gaps outside the audit scope are the ones nobody's watching.

The company with default passwords is the perfect example. Was "change default passwords on edge devices" a line item on their audit checklist? Probably not in those specific terms; so,

nobody checked. And the attackers walked right through the front door with the factory key.

Where Compliance Helps

I don't want to leave you with the impression that compliance is just for the auditors. It's not. A well-designed compliance program creates real value.

Compliance establishes a baseline. Even if the floor isn't the ceiling, having a floor matters. Organizations with no compliance requirements and no external pressure to maintain security standards often have no standards at all. The floor gives you something to stand on.

Compliance creates accountability, because when you have to report to an auditor, a regulator, or a board committee, you have a forcing function. Processes get formalized and people are held accountable. That accountability, even when imperfect, is better than the alternative, which is nobody being responsible for anything.

Compliance drives investment. In many organizations, the compliance requirements are the only reason the security budget exists at all. The CISO who can point to a regulatory requirement has a stronger case for funding than the CISO who can only point to a valid, documented risk. This shouldn't be the case. Security investment should be driven by business risk, as I argued in Chapter One. Unfortunately, in the real world, compliance requirements open wallets that risk arguments alone don't.

Compliance does provide a common language, so when your team is engaged with the auditor or regulator, everyone is working from the same framework. That leads to productive conversations about security. The framework gives you a shared vocabulary and a shared set of expectations. It's imperfect, but it's better than everyone speaking their own dialect.

The mistake is not using compliance requirements as a lever to drive security, it is equating compliance with security. Remember, the compliance requirements are the floor, and passing the audit doesn't mean you have done enough. Do you want to settle for a C or do you want to be a solid B?

Testing What the Checklist Doesn't

So how do you think about the difference between compliance and security? How do you know whether your organization has crossed the line from meeting the minimum to actually being protected?

Start here: compliance measures the controls you have. Security measures the effectiveness of the controls against relevant threats.

A compliance assessment asks whether a control exists. A security assessment asks whether it would hold up against a real attack. One is a checklist, the other a stress test. Your organization needs both, and the second one should scare your security professionals more than the first.

Penetration testing is hiring someone to break into your systems. It is the most direct way to test your security. The test

doesn't check your compliance report. All that matters is whether your defenses hold. If you pass your audit and fail your pen test, the test is telling you the truth. The problem is that pen tests are point-in-time assessments that are only as good as the people who conducted them and the things they did during the test.

If a new vulnerability is reported the day after you sign off on the report and nobody checked to see if you were vulnerable, that risk exposure might exist for a year before the next one. And it gets worse. Pen testing has been highly commoditized over the last 20 years and there are a lot of companies buying cheap tests that are no more than automated scans with boilerplate reports. They fall into the check box category.

Tabletop exercises are walking your leadership team through a simulated cyber event. This is part of business continuity or incident response planning. They are testing a different weakness. Being prepared has nothing to do with testing your controls. You aren't prepared until you are sure your people know what to do when bad things happen. The six-day outage I described in Chapter Five wasn't caused by a technology failure alone. It was caused by an organization that had no plan, no practice, and no muscle memory for responding to a crisis. A tabletop exercise would have exposed that long before the real event did.

Red team assessments are sustained, multi-vector simulated attacks conducted over weeks or months to test you most comprehensively. A red team doesn't just check whether the firewall is configured correctly, it tries to get past the firewall the way a real attacker would, using the same techniques described in

Chapter Four. If the red team succeeds, you know exactly where your compliance program ends and your actual exposure begins.

AI Compliance: The Fastest-Moving Target

Everything I've said about the difference between compliance and security applies doubly to AI.

AI compliance frameworks are emerging, but they're lagging far behind adoption. The NIST AI Risk Management Framework provides useful guidance. The EU AI Act sets regulatory requirements for systems operating in the European market. Industry-specific guidance is developing in financial services, healthcare, and other regulated sectors.

But the current reality is most enterprises are deploying AI faster than the regulations that govern it. And even if they could keep up, the compliance frameworks that exist today were written for AI capabilities that existed when the frameworks were drafted. The capabilities have already moved beyond them. A company that is fully compliant with every existing AI regulation might still be deploying AI systems that create risks no regulator has addressed yet. And that is the best case. Reality is most enterprises aren't even in reach of the floor. AI governance is a crisis waiting to happen and nobody is talking about it.

The world is changing before our eyes. The pace of change is unprecedented and impacting every aspect of our lives.

The AI compliance landscape is evolving faster than any compliance domain in history. Regulators are introducing new regulations and new enforcement actions. ISO and NIST are

releasing new guidance and updating frameworks as fast as they can. If your compliance team is working from a checklist that was current six months ago, it's already stale. And if your team isn't evaluating AI systems for risks that go beyond what the regulators currently require, you're building on a floor that's being raised under your feet.

The Question to Take with You

I'll close this chapter with a distinction that should frame every conversation you have about your organization's security posture:

Compliance requirements dictate what you must do. Security is the measurable effectiveness of what you do. The space between them is where breaches happen.

Your job as an executive isn't to close that gap yourself. It's to make sure someone in your organization knows the gap exists, knows how big it is, and is advising you of the risks. It is up to you to prioritize the work required to close the gaps. Demand more from your teams. Don't settle for checking more boxes, test whether the defenses actually work against the threats you face.

The next time someone presents you with a clean compliance report, say thank you. Then ask: "What does this not tell us?"

The answer to that question is where the real work begins.

CHAPTER SEVEN

Becoming the Sheriff — AI Governance



In Chapter Three, I told you about the CISO who became the cowboy, the senior security executive at a multi-billion dollar enterprise who started cancelling carefully architected AI projects so he could vibe code solutions himself. The sheriff became the gunslinger.

That story is an extreme case, but the underlying problem is universal. Every enterprise that's deploying AI, which is pretty much every enterprise, should be asking the same fundamental question: who's in charge? Who is making sure AI doesn't destroy the enterprise while everyone's busy trying to transform it?

In the Wild West, the answer was the sheriff. You need one. What you don't need is another committee or a framework document that nobody reads. You need a person or a team with the authority, and the mandate to impose order on the frontier. If you don't have one, everything else in this book is academic.

The Governance Gap

Let me describe what I see in most enterprises today.

The CEO has declared AI a strategic priority. The board has asked for an AI roadmap. Business units are submitting use cases. Technology teams are evaluating platforms. Pilots are launching. Excitement is high.

And somewhere in the background, the security team is trying to get someone's attention.

Everybody is racing toward business transformation while the security team is raising the caution flag. Let's unpack what they are worried about. Your data is your company's life. They know that model drift and data poisoning are real things that could corrupt it. So, you should listen when they tell you that governance and validation are necessary before you start relying on AI-generated outputs.

They are telling you that enterprise data is flowing into tools that have not been validated for security, privacy or compliance, and without guardrails, bad things will happen. You delegated business decisions without even realizing it. Now nobody is paying attention to the flags your team is raising because they aren't nearly as exciting as the AI demos that keep landing in the leadership meetings.

This is the governance gap. The enterprise has the accelerator pressed to the floor, and nobody's checked whether the brakes work. Not because they don't care, because the organizational structure hasn't caught up to the technology.

In most organizations, AI governance is nobody's job. Or more accurately, it's everybody's job, which means it's nobody's job. You might be thinking you have all the right people in place, so the job is getting done. But you would likely be wrong. All the players are on the field. The CTO owns the technology, the CIO owns the data and the apps and the CISO owns the security. The General Counsel owns the legal risk and the business units own the use cases. The problem is, nobody owns the intersection of all of those things, which is exactly where AI risk lives.

The results are not what you'd expect. You think you are in good shape, but without the connective tissue at the intersection of all of the functions, decisions get made without the right people in the room and risks get accepted without being measured and evaluated. In the name of "business transformation," the enterprise is running on AI outputs that no one has validated. And that is where it is supposed to be working. Don't forget, shadow AI is rampant, because the absence of governance creates a vacuum that individual initiative rushes to fill.

The data on this metric is no longer hypothetical. As of February 2026, Microsoft's security research reported that approximately eighty percent of Fortune 500 companies have active AI agents embedded in business operations, software systems with permissions to act on the company's behalf in production. Only ten percent of those companies have a governance model for those agents.

The implication is concrete: a supply chain exposure that does not require an outside attacker. It is already inside the wall, and most boards do not know the number. The audit committee that has been worrying about third-party vendor risk for the last decade is now worrying about the wrong perimeter. The risk has come inside.

The insurance industry has noticed. In early 2026, major carriers including Chubb, Travelers, and Berkshire Hathaway received state regulatory approval to add explicit AI exclusions to directors and officers liability policies. The underwriting model is shifting from asset-based to governance-based, meaning your AI governance posture now directly affects whether your board's D&O coverage will respond when something goes wrong.

Carriers are introducing AI Security Riders that require documented evidence of model-level risk assessments and specialized safeguards as prerequisites for coverage. If you don't have governance, you may not be able to get insured. If you can't get insured, your directors are personally exposed.

The Sheriff's Job

What does an AI governance function actually look like? It doesn't have to be complicated. In fact, if it's too complicated, nobody will follow it, and governance that isn't followed is worse than no governance at all, because it creates the illusion of control.

The sheriff's job has four parts.

Visibility. Before you can govern AI, you have to know where it is. That means finding every AI tool, platform, model, and integration in your enterprise. That includes the ones you deployed intentionally and the ones your people adopted on their own. Shadow AI, as we discussed in Chapter Three, is the iceberg beneath the surface. You can't manage what you can't measure.

This isn't a one-time inventory, it is an ongoing process. New AI tools appear every week. Employees find new ways to use them every day. The visibility function needs to be continuous, not annual.

Assessment. Every AI use case needs to be evaluated for risk before it goes into production, not after. The time to prepare for things to go wrong is before they do. The assessment doesn't need to be a six-month exercise. For most use cases, it can be done in a matter of days, if the right people are involved and the right questions are asked.

We are talking about the same questions we've been asking throughout this book, applied to the AI use cases running in your enterprise right now. The problem isn't that they are hard, but that nobody's asking them.

Policy. The organization needs clear, enforceable rules about AI use. Not a hundred-page document that nobody reads. A short, clear set of principles that every employee can understand: what's allowed, what's not, what requires approval, and who to call when you're not sure.

The policy needs to be clearly communicated to every employee and it has to have teeth. If the policy says "no enterprise

data in unapproved AI tools" and someone uploads a customer database into ChatGPT, there have to be consequences. A policy without consequences is a suggestion, and suggestions don't govern behavior.

Ongoing oversight. AI governance isn't a project. It's a function. The only thing you can expect to be constant is change. The tools, technology, and threat landscapes will evolve over time along with the use cases driven by the needs of the business. The regulatory landscape will evolve as major incidents become front page news. The governance framework needs to evolve with all of it in concert. Someone needs to own that evolution as their primary responsibility.

The Tribalism Problem

If the governance gap is the structural challenge, tribalism is the cultural one. And it may be harder to solve.

Inside large organizations, technology teams operate in silos. This isn't news. But AI has turned the normal friction of organizational silos into something more dangerous, because AI use cases cut across every silo simultaneously.

Here's what I see on the ground. One business unit wants to deploy an AI use case. They've done their homework. They have a legitimate need, a viable approach, and they're ready to move. But the security team, different silo, different executive, different priorities, blocks it. Not because the use case is inherently risky, but because security hasn't built the process to evaluate it. They

can't say yes because they don't have a framework for yes. So they say no, or worse, they say nothing, and the project dies in limbo.

Meanwhile, in another part of the building, a different team is running an unsanctioned AI tool that nobody in security knows about. No assessment. No controls. No governance. They haven't been blocked because they never asked permission.

The wrong projects get stopped. The wrong projects proceed. And the people on each side have no visibility into what's happening on the other. The business unit doesn't know about the shadow AI upstairs. Security doesn't know they're blocking a project that would have been fine with basic controls. The CEO doesn't know any of it.

This is tribalism in action. It's not malicious. It's structural. Each silo is optimizing for its own objectives, innovation for the business unit, risk reduction for security, and nobody's optimizing for the enterprise as a whole.

The sheriff's job is to break through that tribalism. Not by eliminating the silos. That's organizational redesign, and it takes years. By creating a governance layer that sits across the silos and forces the right conversations to happen. The security team needs a process for evaluating AI use cases efficiently, so legitimate projects don't die in limbo. The business teams need a clear path to approval, so they don't resort to shadow AI. And someone at the executive level needs visibility into both sides, the projects being proposed and the risks being evaluated, so that the enterprise is making informed decisions rather than letting the silos make decisions by default.

The CISO cowboy story from Chapter Three is tribalism taken to its extreme. When the person responsible for security starts bypassing security processes, it sends a message to the entire organization: the rules don't apply if you're important enough. If the sheriff is the one robbing the bank, the entire concept of law enforcement collapses. That multi-billion dollar enterprise is still dealing with the fallout: cancelled projects that need to be restarted, vibe-coded solutions that need to be assessed and probably rebuilt, and broken trust between the technology services team and the client that will take years to repair. All of it could have been avoided with a governance structure that no single person could override.

This is why the governance function needs to be independent of any single executive, including the CISO. The sheriff reports to the mayor, not to himself. AI governance needs executive sponsorship at the CEO or board level, with clear authority that supersedes any individual leader's preferences. The CISO should be an essential input to the governance process, but not the sole arbiter of it.

Vibe Coding: The Governance Challenge

I spent some time on vibe coding in Chapter Three, but it deserves deeper treatment here because it represents the hardest governance problem in the AI frontier.

Traditional shadow IT was manageable because it required technical skill. If someone wanted to run an unauthorized server or deploy an unapproved application, they needed to know what

they were doing. The barrier to entry limited the volume of shadow IT, and most of it was visible to the network team eventually.

Vibe coding obliterates that barrier. When anyone with a browser can build a functional application using AI, the volume of ungoverned software in your enterprise doesn't grow linearly. It explodes. And much of it is invisible to traditional IT management tools, because it's running in SaaS environments, personal accounts, and browser-based platforms that never touch your corporate network.

The governance challenge is this: how do you maintain control without killing the productivity gains that AI coding tools provide?

The answer, I think, is a clear bright line. AI coding tools for personal productivity, automating your own workflow, processing your own data, building tools that only you use, are fine. Encourage them. The productivity gains are real.

But the moment a vibe-coded solution touches enterprise data, connects to enterprise systems, or makes decisions based on unvalidated outcomes, it crosses the line. It needs to go through the same assessment process as any other technology deployment. This should not be interpreted as a blocker, but this is where the sheriff needs to consider the risks on the other side of that line. In other words, what happens if things go wrong? There are a number of potential outcomes, none of them good: data corruption, data exposure, compliance violations, security

vulnerabilities, legal liability. These are business risks that require enterprise governance.

The bright line won't be easy to enforce. People will cross it without realizing they have. The product manager who builds a quick tool for herself will share it with her team, and then with the department, and then it's running in production before anyone notices. That's the nature of the problem. But having the line, and communicating it clearly and enforcing it consistently, is the difference between managed risk and chaos.

The Path Forward

The path forward starts with an honest conversation that most leadership teams haven't had yet. How much AI is actually running in our enterprise right now? If you don't know the answer, that's the answer.

Find out. Conduct an inventory, and be prepared for the number to be larger than anyone expects and that will be uncomfortable. That's a good thing. Discomfort shows up when governance catches up to reality.

Once you know what you're dealing with, build the governance framework around it. Do not turn it into an auditor-ready binder. This can't be a policy that lives on a shelf or the intranet. It has to be a living document that is referenced. It needs to cover assessment, policy, oversight, and a clear path from "I have an AI use case" to "it's approved and deployed with appropriate controls." Make that path fast enough that people

use it instead of going around it, because if it's easier to skip the process than follow it, they will skip it every time.

Then put the sheriff in place. Not a committee. A person with authority, reporting at the executive level, whose job it is to make this work. AI governance is not optional, temporary, or subordinate to any single executive's enthusiasm for the next demo.

If the business case for governance doesn't move you, the regulatory trajectory should. The EU AI Act imposes fines of up to thirty-five million euros or seven percent of global annual turnover for prohibited AI practices. Italy, the first member state to implement the Act, went further in September 2025: fines up to 1.55 million euros, disqualification from public contracts for up to two years, and a broad delegation to define criminal liability for individuals responsible for AI-related offences. The direction is clear: organizational fines today, personal criminal liability tomorrow.

And as we discussed earlier in this chapter, the D&O insurance market has already moved. If your governance is absent and something goes wrong, your carrier may decline the claim. That means the liability lands on you personally. Not the company. Not the insurance policy. You. The governance gap is no longer an abstract operational risk. It is a personal liability exposure for every executive and board member in the room.

I know this feels like you are pumping the brakes. The pressure to move fast is intense and the fear of being left behind is real. But stop and consider the alternative: an enterprise full of AI

cowboys, riding hard in every direction, creating risk that nobody's measuring and nobody's managing, with regulations closing in and attackers getting smarter by the day.

AI is here. You are not going to uninvent it. But you can put a sheriff on the frontier. The enterprises that do that and find the discipline to govern AI as seriously as they govern financial risk will still be standing when the dust settles.

CHAPTER EIGHT

Building the Defenses



Let me take you back to the ransomware incident, the one with the CFO who wanted to sweep it under the rug.

When we arrived, the company was still connected to the Internet. The attackers still had full access. Nobody had taken the most basic step of disconnecting from the network to stop the bleeding because they didn't know what to do. There was no playbook.

So, we built the defenses during the crisis. And everything we built, every control we put in place over those three desperate days, should have existed before we ever walked through the door.

We disconnected from the Internet. We isolated the encrypted systems and removed them from the network. We created forensic backups of the infected machines, because you need to understand what happened before you can be sure it won't happen again. We wiped the compromised systems and restored from clean backup through an out-of-band channel, so the recovery itself couldn't be intercepted. In parallel, we

deployed endpoint detection agents on every computer in the enterprise to catch any lateral movement we hadn't found yet.

Then we built what the company never had: proper network segmentation and access controls. Walls inside the house, so that even if an attacker gets through the front door, they can't walk freely through every room.

Three days. Core systems back online. The company survived.

But here's what I want you to understand: everything we did during that crisis was more expensive, more stressful, and more dangerous than it would have been if those controls had existed beforehand. Building the fire escape during the fire is possible. It's harder than it would have been to prepare for the fire ahead of time.

Defense in Depth

The fundamental principle of cybersecurity defense is layered security. No single control is going to stop every attack. You build multiple layers, each one serving a different purpose, so that an attacker who gets past one runs into the next. The goal isn't to keep a determined attacker out. A capable adversary will always find a way in. The goal is to slow them down enough that you detect them and respond before they reach anything that matters.

Think of it like a building. The perimeter fence keeps most people out. The locked door stops intruders that get past the fence. The security camera catches the ones who get past the door. The alarm alerts you when someone's where they shouldn't

be. The vault protects the most valuable assets even if everything else fails.

Your security team will describe these layers in terms of network defenses, endpoint protection, identity management, data protection, monitoring, and incident response. You don't need to understand how each of those works. What you need to understand is whether your organization has all of them, whether they're current, and whether they've been tested against real-world scenarios, not just checked off on an audit form.

The company in the ransomware story had a firewall and nothing else. One layer. Once the attackers got past it, there were no internal walls, no monitoring, and no response plan. That's the difference between a security program and a security checkbox.

Know Your Enemy

Every sheriff knew which gangs were operating in their jurisdiction. That's not a vintage detail. It is the foundational principle of defense dating back to Sun Tzu.

In my experience, most executives can't tell me, without checking with their security team, which threat groups are most likely to target their industry, or what those groups do once they get in. The advisories are public. The information is free. The homework hasn't been done.

This matters because cybersecurity defense is not generic. The groups that go after a regional hospital are not the groups that go

after a defense contractor. If you're defending against a generic catalog of threats, you're defending against the wrong thing.

In September 2023, MGM Resorts and Caesars Entertainment were hit within ten days of each other by a group that CISA and the FBI track as Scattered Spider. The entry point in both cases was a phone call to the IT help desk. The attacker had researched the target employee on LinkedIn, called pretending to be them, and talked the help-desk technician into resetting their multi-factor authentication credentials. From there into identity infrastructure, then into the cloud. MGM disclosed cash-flow impacts of roughly \$100 million in its subsequent SEC filing. Caesars reportedly paid a ransom in the range of \$15 million.

The joint advisory that came out afterward told every other hospitality operator exactly what to expect. The ones that read it tightened their help-desk verification procedures. The ones that didn't were more susceptible to attack.

Tell your CISO's team you want to know, by name, the three groups most likely to come at your industry, what they do, and what you are doing about it. I've put the operational details, the ISACs by sector, the case studies, and the questions to take to your CISO, in Appendix C. If your team can't answer that question, the homework hasn't been done.

AI Changed the Equation

For thirty years, the central challenge of cybersecurity defense has been finding the signal in the noise. An enterprise network

generates vast quantities of data, and somewhere in that ocean are the handful of indicators that tell you something is wrong. We built platforms to correlate the data and hired analysts to review the alerts, and for decades we were drowning. The data was too vast and the analysts were too few.

AI changed that. It's the most significant advancement in defensive cybersecurity since the invention of the firewall, and I don't say that lightly. AI can establish a baseline of normal behavior and detect deviations that would be invisible to rule-based systems. It can correlate events across systems and time zones in real time, identifying patterns that would take a human team days to find. When it detects a threat, it can initiate containment automatically by isolating a compromised endpoint or revoking compromised credentials in seconds. That same sequence used to take hours: page an analyst, work the alert, execute the response manually.

But here's the part that matters for your budget. In the last eighteen months, the bottleneck shifted. AI has made finding vulnerabilities cheap and abundant, for both sides. Google, DARPA, and multiple AI security firms have demonstrated that AI can discover zero-day vulnerabilities in production software faster and cheaper than any human team. In May 2026, Google confirmed the first criminal use of an AI-generated zero-day exploit in the wild. The adversary has the same tools.

The thing that is now hard is fixing what gets found at the speed the new discovery rate demands. Mean time to patch a complex enterprise vulnerability stands at over five months. The

median time from vulnerability disclosure to active exploitation is five days. If you are recalling the negative-seven-day figure from Chapter One, both are right. The average has gone negative because a growing share of vulnerabilities are attacked before the fix even exists. The five-day median is the typical case. Your risk lives in that space.

The practical consequence is straightforward. Investing in tools that find more vulnerabilities is investing in a problem you already have. The defensive dollars need to go into the capacity to fix things at speed: treating your patching and remediation pipeline as a first-class investment, knowing exactly what software is running in your environment so you can act fast when a new vulnerability drops, and having the people or partners in place to sort through what AI is finding and decide what matters for your business. Any vendor selling you a tool that helps you find more issues without helping you decide which to fix first is widening the space, not closing it.

The True-Up

In the spring of 2026, Project Glasswing, a coalition of a dozen of the largest technology companies in the world, pointed a frontier AI model at the open-source software everyone depends on and found more than ten thousand high- and critical-severity vulnerabilities in the first month. The initiative settled the question of whether AI could find the flaws. It raised the question nobody wanted to ask out loud: now that the flaws are visible, who is going to fix them?

That question is about to define the next several years of security investment, and it lands on your desk on three fronts.

The first front is the debt you already know about. Every enterprise has a security backlog. These are findings from years of scans and pen tests and audits that were logged, prioritized, and quietly carried forward, because no human team was ever going to chip through them. For decades the honest plan was to fix the high-priority items and live with the rest. AI and automation change that math. The backlog that was impossible to pay down with people is payable with machines. Carrying debt you could not retire was a defensible decision. Carrying debt you can retire is a choice you can act on. After a breach, how you chose will be relevant in the action against you.

The second front is the one most executives have not considered, and it is the one that worries me most. Every large enterprise is carrying legacy systems. This is the code that has run reliably for twenty or thirty years, often unsupported and sitting at the center of the most critical financial processing systems the company has.

We left them alone because they worked, and because they were protected by obscurity. Nobody was hacking COBOL because nobody was writing COBOL. The handful of people who could still read that code were retiring, not attacking. AI ended that protection. A frontier model can read forty-year-old code as fluently as last week's, which means the problem you kicked down the road for the last twenty years just caught up with you.

The systems we have comfortably ignored for two decades are now reachable, and most of them are processing the crown jewels. The forklift upgrade we have deferred since the nineties is no longer optional, it is a business imperative. I have seen this presentation made to boards and executive leadership teams in several of the largest companies in the world. When presented with the current reality, boards aren't asking how much, they are asking when can you start? So, have you started? Will you start it before or after someone demonstrates why you should have?

The third front is where this ends up once the debt is paid and the legacy estate is modernized. A defense that depends on humans finding and fixing flaws will always run at human speed, while the attackers they are defending against are running at machine speed. The end-state is agentic AI continuously scanning your code repositories for new vulnerabilities, creating, testing, and applying the fixes through automated processes, with your people supervising the pipeline instead of being the pipeline. It is the same capability the attackers are already using, but turned in the other direction. It is the only tempo that keeps pace with bad actors armed with frontier models.

None of this is cheap, and none of it happens in a quarter. But the sequencing matters less than the recognition: "there are not enough humans to fix what we find" excused thirty years of accumulated exposure. That excuse is gone. What remains is a decision about whether to use the machines first. Appendix E takes these three fronts to the program level: what funding them looks like, what it costs, and the questions to ask before you start.

The Defender's Disadvantage

I need to be honest about the asymmetry, because understanding it is essential to making smart investment decisions.

Remember the asymmetry from Chapter Four: the attacker needs to succeed once; the defender, every time. AI has given defenders better tools, but it's also given attackers better weapons. The race continues. Your attack surface is expanding: cloud infrastructure, remote workers, AI tools, third-party integrations. The attacker only needs to find the one vulnerability you missed. AI-powered attacks operate at machine speed, and if your defenses still rely on a human reviewing an alert before anyone responds, you will lose that race.

The cybersecurity talent shortage makes this harder. There aren't enough skilled security professionals to staff every organization that needs them. AI-powered tools help your teams do more, but they don't eliminate the need for skilled people.

Building the defenses is essential. But building them and then assuming you're done is as dangerous as not building them at all. If your board treats cybersecurity as a project with a completion date, that assumption needs to be corrected.

The Human Layer

There's one more layer I haven't talked about yet, and it's the one where the game has changed the most.

The person at the keyboard.

For twenty years, cybersecurity awareness training has been built around a simple premise: teach people to spot the signs of a

phishing attack. Look for misspellings. Check the sender's email address. Be suspicious of urgent requests.

That advice was decent when phishing emails looked like they were written by someone who learned English from a dictionary and a prayer. An alert person could spot them. Training improved detection rates. The human factor was manageable.

AI erased the tells.

I walked you through this in Chapter Four: phishing that is grammatically perfect, personalized from reconnaissance, arriving at the right time in the right tone. There are no rough edges left for your gut to catch.

And it's not just email. AI can clone a person's voice from a few minutes of publicly available audio and produce real-time synthetic faces in a video call.

In 2019, the UK chief executive of an energy firm received a phone call he believed was from the CEO of his German parent company, instructing him to wire 220,000 euros to a Hungarian supplier within the hour. He recognized the accent and the melody of the voice and complied. The funds were routed from Hungary to Mexico and never recovered. It was the first publicly reported corporate wire fraud widely attributed to AI voice cloning.

Five years later, the technique had been productized. In January 2024, a finance employee at the Hong Kong office of Arup (the engineering firm behind the Sydney Opera House) received an email purporting to be from the UK-based CFO requesting secret transactions. He was suspicious. He thought it

was phishing. His doubts were dispelled when he joined a video conference call in which deepfake re-creations of the CFO and several colleagues appeared to confirm the instructions. He made fifteen wire transfers totaling \$25.6 million. None of the stolen funds have been recovered.

The FBI's 2025 IC3 Annual Report broke out AI-facilitated fraud as a standalone category for the first time: 22,364 complaints and \$893 million in attributed losses. The bureau noted that most victims don't recognize AI involvement, so the real number is higher.

When the attack is indistinguishable from legitimate communication, "trust your gut" isn't a defense anymore. Your gut evolved to assess face-to-face interactions with real humans. It didn't evolve to detect synthetic media.

This doesn't mean training is useless. It means training alone isn't enough. The human layer needs the same AI-powered defenses you're building everywhere else: email security that detects AI-generated phishing, voice authentication that identifies synthetic speech, and verification protocols that don't rely on a single channel.

The mental model is simple: verify before you act, not spot the fake. If your finance team confirms any wire transfer above a threshold through a separate, authenticated channel, regardless of how convincing the request looks, the deepfake CEO is defeated by the protocol, not by the human's ability to detect the deepfake.

In July 2024, scammers ran a deepfake voice attack on a Ferrari executive. They had CEO Benedetto Vigna's accent, the urgency, an acquisition story. The executive asked one question: what book had the CEO recently recommended to him? The caller couldn't answer, and the scam collapsed. A piece of shared context no scraper can find. The protocol doesn't ask the human to detect the deepfake. It asks the deepfake to do something it can't.

Everything I've described so far is about the human as victim, the person who gets fooled. There's another dimension to the human layer that most executives don't think about until it's too late: the human as threat.

In 2014, an adviser to Saudi Arabia's crown prince recruited two Twitter employees to access the personal information of Saudi dissidents: phone numbers, IP addresses, email addresses. One of them, a media partnerships manager named Ahmad Abouammo, received at least \$300,000 and a luxury watch. A second, an engineer, accessed thousands of user profiles before being confronted, and then fled to Saudi Arabia with his family, despite being under FBI surveillance. Abouammo was convicted on six federal counts in 2022 and sentenced to forty-two months in prison. That wasn't a hack. That was a foreign government recruiting vetted employees at a global technology company.

In July 2024, cybersecurity firm KnowBe4 hired a software engineer who passed four video interviews and a full background check. The check came back clean because the applicant was using a stolen American identity. He was North Korean. The

moment the company laptop arrived, it started loading malware. KnowBe4's security team caught it within twenty-five minutes. Most companies wouldn't have. The Justice Department indicted fourteen North Korean nationals in December 2024 for infiltrating more than sixty American companies through the same playbook: fabricated identities, remote work, laptop farms in sixteen states. The scheme generated at least \$88 million over six years, funding weapons programs.

And in May 2025, Coinbase disclosed that overseas support contractors had been bribed to steal customer data. The attackers demanded a \$20 million ransom. Coinbase refused. Estimated remediation cost: \$180 million to \$400 million.

Foreign intelligence recruitment, identity-fraud infiltration, contractor bribery, and none of them were stopped by a firewall or a phishing simulation. The threat walked in with a badge.

The question for your board is the same one from every chapter of this book: how would you know? How would you know if a trusted employee was accessing records they had no business reason to see? The tools exist: user behavior analytics, data loss prevention, privileged access monitoring. They work if someone is watching.

Your biggest vulnerability has a name badge and a parking spot. AI made that vulnerability harder to defend against, and the insider threat means it's not only outsiders you're defending against. The answer isn't to replace the humans. It's to build the systems around them that catch what they can't.

What You Should Be Asking

You don't need to understand the technical details of every defensive tool. That's your team's job. But you need to understand enough to ask the right questions and know whether the answers make sense.

Do we have layered defenses, or are we relying on a perimeter? If a firewall is the only defense you have a problem. Ask what your team is doing to slow down and detect intruders before they can do real damage.

Are we using AI-powered security tools, and do those tools cover the human layer too? If not, ask why. The attackers aren't waiting for your evaluation to conclude.

How long would it take us to detect an attacker inside our network? If the answer is vague, that's your answer.

Can we patch a critical vulnerability faster than an attacker can exploit it? If the answer is no, and for most enterprises it is no, ask what the plan is to improve the time to remediate.

What happens when our primary defenses fail? The resilience of your defenses isn't measured by whether every layer holds. It's measured by what happens when one of them doesn't.

Building the defenses is the foundation of everything else in this book: the governance framework from Chapter Seven, the budget decisions in Chapter Nine, and the incident response capability in Chapter Ten. Build them before you need them. Because building them during the crisis is always more expensive and more dangerous than building them before.

CHAPTER NINE

Budget is the "Do I Need to Be an A?" Conversation



Every year, the same fight happens in organizations all over the world.

The CISO presents a budget request. It's larger than last year's, because the threats are larger than last year's. The CFO pushes back, because every department's budget request is larger than last year's and the money has to come from somewhere. The CEO mediates, usually by splitting the difference, giving the CISO more than last year but less than they asked for. Everyone walks away unsatisfied, and the decision that was actually made was how much risk is the organization willing to accept.

Unfortunately, it was never explicitly discussed.

That's not a budget process. That's a negotiation with no shared understanding of what's at stake.

The bank president in North Carolina had a better approach, and he figured it out in about thirty seconds. "How much did I spend? Where was I? Where am I now? Do I need to be an A?"

Four questions. No jargon. A clear decision made by the right person with the right information.

The Wrong Question

"How much should we spend on cybersecurity?"

This is the question I hear most often from executives, and it's the wrong question. It's wrong because it treats cybersecurity as a line item or a cost to be minimized, rather than a risk management function with a definable relationship between investment and risk reduction.

You wouldn't ask "how much should we spend on financial risk management?" without doing a risk assessment to determine the likelihood and impact of loss. The answer to "how much" depends entirely on the risk assessment.

Cybersecurity is the same. The right question is: **"What level of risk are we willing to accept, and are we spending enough to get there?"**

That question changes the entire conversation. Which scenario do you think lands better with you and your CFO? The CISO submits a budget request for more tools? Or the CISO approaches you with a clearly defined risk analysis and a plan to close the gap? With the former, your natural question is can we afford this? The latter changes the focus to risk management and the question becomes can we afford not to? Same budget request framed differently and giving you the information you need to make a good decision based on how much risk the enterprise is willing to carry.

The Diminishing Returns Curve

The bank president's instinct about not needing to be an A was exactly right, and it reflects a concept that every executive should understand: cybersecurity investment follows a curve of diminishing returns.

The shape of this curve is the one I walked through in Chapter Two, and it matters most here, in the budget conversation. The first dollars you invest buy the most protection. If your network is flat, there is nothing in the way of an intruder moving freely with minimal chance of detection once they are in. Proper segmentation and access controls don't require spending on more tools, but they do take time to plan and implement. That is bringing your D up to a C, and the return is significant because the cost and level of effort are low compared to the risk mitigation.

From C to B, you're building the layered defenses I described in Chapter Eight, and the investment is still clearly justified by the risk it mitigates. The B to A range is where the calculus changes. Each additional dollar buys less risk reduction than the dollar before it, and this is where the "Do I need to be an A?" question becomes essential, because the answer depends on your specific risk profile, your industry, your regulatory environment, and the value of what you're protecting. Beyond A is the pursuit of perfection, and it is almost never justified from a business perspective.

The bank president understood this curve intuitively. He didn't need a graph or a formula. He needed to know where he

stood, what it cost to get there, and whether the next level of investment was worth it. The answer was no, and that was the right answer for his bank. For a different organization like a defense contractor, or a healthcare system with life-critical data, the answer might have been yes.

The Sales Problem

I need to tell you about a pattern I've seen from the other side of the desk during my years on the vendor and integrator side of the business, because it directly affects how much you end up spending and what you get for it.

Account managers peel security off competitive bids to reduce cost.

It happens constantly. A large technology initiative like a cloud migration or a digital transformation goes out to bid. The integrator's solution team builds a proposal that includes security embedded throughout: secure architecture, access controls, monitoring, compliance validation. The proposal is solid but not the cheapest.

The account manager looks at the competitive landscape and says: "We need to sharpen the pencil." So security gets stripped out. The pitch becomes: "We'll do the migration first, then come back and layer security on top." The client likes the lower number. The deal closes.

Then one of two things happens. Either the security never gets layered on because it wasn't included in the budget or the team has moved to the next project, and "layer it on later" never

happens. Or the security does get layered on, months or years later, at three times the cost it would have been if it had been built in from the start, because retrofitting security into a production system is dramatically more expensive than building it in during design.

This is selling on price, not value. And it's one of the most persistent, damaging patterns in the technology industry.

As an executive, you need to be aware of this pattern because you're the one being sold to. When a proposal comes in that's significantly cheaper than the alternatives, ask yourself what's missing. If the answer is security, the proposal isn't cheaper. It's more expensive, you just don't know it yet.

The AI Investment Calculus

AI changes the budget conversation in two important ways.

First, the attack surface is expanding faster than at any point in history. Every AI deployment creates new risks that need to be assessed and monitored. The cybersecurity budget that was adequate before your AI adoption began is not adequate now.

If your AI spending is increasing but your security spending is flat, you're taking on additional risk with every new deployment.

Second, the cost of an AI-driven security failure can dwarf the cost of a traditional breach. A traditional data breach exposes records, while an AI failure like data model drift can corrupt decision-making at scale. A biased or corrupted model can do more than alienate customers. It could result in regulatory violations or legal action against you. A data poisoning attack on

a key AI system can undermine the reliability of decisions your entire operation depends on. The impact isn't measured in records compromised. The stakes are much higher.

This doesn't mean you should spend unlimited money on AI security. The diminishing returns curve still applies. But the curve has shifted and the baseline investment needed to achieve an acceptable risk level is higher than it was before AI entered the picture, and the consequences of underinvestment are more severe.

Compressing the Time to Remediate

When the threat landscape changes this fast, the temptation is to buy every new tool vendors are positioning as "AI security." That is the wrong instinct.

Here is the problem in plain terms. We are getting better at finding vulnerabilities, which are the weaknesses in your systems that attackers can exploit. AI has made finding them fast and cheap, for both sides. What has not gotten faster is fixing them. The average enterprise takes over five months to fix a complex vulnerability once it's found. Attackers start exploiting them in five days. Your risk lives in that space.

So the budget question is not "what new tools should we buy?" It is "can we fix what we already know is broken before someone uses it against us?" That means investing in the speed of your response. Prioritize fixes by what actually matters to the business. Know exactly what software is running in your

environment. Have enough people to sort through what the tools are finding.

Make sure your vendors are holding up their end. Your CISO can walk you through the specifics. What matters at your level is whether the space exists, how wide it is, and what it costs to close it. One part of that case deserves its own line item: the legacy estate. The forklift upgrade across systems that have run unsupported for twenty years is not an IT project, it is a capital investment that requires board support. This doesn't get pushed down, it gets pushed up. Appendix D has the script for making that case to your board.

Security as Investment, Not Cost

I keep coming back to the same concept: security, positioned properly, is not a cost. It's an investment that enables the business.

Let me tell you about a project that almost died waiting for a signature. An enterprise client had a formal AI adoption initiative running. It was six months of solid work across the business units, use cases well defined, ready to move into vendor selection. Then it hit a dead stop. The security team would not sign off, because the project team couldn't answer even simple questions about controls and project risk. Six months of work and millions of dollars sat in limbo, and teams on both sides were panicking.

That's when someone thought to bring in our security practice. One of my peers sat down with the project team for an hour and found the real problem. It wasn't that security had been

left out of the plan — both sides had done their jobs. There was a clear disconnect between the project team and the security function. Both knew what they needed, neither was able to clearly communicate it to the other. Once our people were in the room translating between the two worlds, the project was unblocked in thirty minutes.

Thirty minutes. The blocker was communication, not security. It was the same problem the bank president put his finger on twenty-five years earlier. Nobody ever measured what the stall cost in delayed value and burned momentum, but it was real money, and a translator in the room from the start would have cost almost nothing.

That was the price of a communication gap. Here's the price of ignoring the message entirely, with a name and a number.

In March 2017, the Apache Software Foundation released a patch for a critical vulnerability in Apache Struts, a widely used web application framework. Equifax was told to apply it. They didn't. The breach started the next day. Over the following weeks, attackers moved freely through the network and exfiltrated the personal information of 147 million Americans. The defenses that should have caught them had gaps including poor network segmentation and an expired security certificate that had blinded the monitoring system. The settlement cost Equifax \$700 million. The CEO, CIO, and CISO all lost their jobs.

The cost of applying that patch was essentially zero. The cost of not applying it was \$700 million and three executive careers. That is the budget argument in one case.

The Insurance Conversation

There is one more budget conversation that most organizations are having whether they planned to or not: cyber insurance.

Insurers have stopped writing policies on faith. The days of answering a questionnaire and getting coverage are over. Carriers now require specific controls as conditions of coverage.

Companies that can't demonstrate those controls face premium increases of fifteen to twenty percent, or outright denial of coverage. Companies with documented, tested controls in place see premiums stabilize or drop.

The security budget and the insurance premium are the same conversation. Every dollar you invest in the controls your insurer requires reduces your premium, and the insurer's requirements are a free second opinion on where your gaps are. If your CISO's budget request and your insurer's requirements are pointing at the same gaps, that's two independent assessments telling you the same thing. Listen. And notice the pattern across this book: carriers naming CISOs on D&O policies, writing AI exclusions into coverage, pricing controls into premiums. The insurance industry is telling you where the risk lives.

Having the Conversation

Here's how the budget conversation should work. Not how it usually works, but how it should work.

The Three Questions translate to the budget conversation too. How much are we spending? What are we getting for it? How would we know if it's not enough?

Start with a baseline that frames the ask. The risk exposure should be clearly articulated and quantified. Once the risk has been defined, you need to define what good looks like based on the potential loss and organizational tolerance for risk.

The target should be set by leadership, informed by the CISO's assessment.

Now you actually have a basis for a discussion and an informed decision to select the right course of action. Insist on options that map investment to risk reduction. "For \$X, we close the three most critical gaps. For \$Y, we address the urgent and high-priority gaps. For \$Z, we reach the target."

If you are approaching your budget conversations this way, you are taking the guesswork out and making better decisions.

Unfortunately, you are never done. The budget conversation isn't annual, it's ongoing. The investment that was right last year may be insufficient today, and the target that made sense before your AI adoption may need to be raised. Regular reassessment ensures the decision stays calibrated to reality.

One more thing. Document the decision. The board that reviews a clearly articulated risk assessment, makes a deliberate investment decision, and revisits it regularly has demonstrated the

oversight duty that Caremark requires. Caremark is the Delaware standard for board oversight liability, and it is the benchmark a court will use if your shareholders ever ask whether the board was paying attention. The board that rubber-stamps a number without understanding what it buys has created an exhibit for the plaintiff's attorney.

The Bank President's Wisdom

I've thought about that conversation in North Carolina hundreds of times over the years. What made it work wasn't the letter grades, but they were brilliant in their simplicity. What made it work was that the right person made an informed decision about risk.

The bank president didn't delegate the decision. He didn't ask his IT person to figure it out. He sat in the room, asked the questions that mattered to him, got honest answers in language he understood, and made a call. He accepted a B. He decided the incremental investment to reach an A wasn't justified by the incremental risk reduction. And he did it with confidence, because the information he had was clear, relevant, and trustworthy.

That documented, informed decision is also what protects you. The liability isn't in the breach, it's in the decision you can't explain afterward.

That's the budget conversation every organization should be having. Not "how much can we spend?" but "how much should

we spend, given the risk we face and the risk we're willing to carry?"

The answer will be different for every organization. But the process should always be the same. Simplify your message so your audience can understand it.

Your bank president is waiting for someone to talk to him in his language. Make sure you have that person, and make sure you're in the room when the conversation happens.

CHAPTER TEN

When Bad Things Happen — Incident Response



Let's begin with two stories about two organizations that I was involved with after significant incidents. They had two fundamentally different outcomes. The difference was leadership and decisive action. A plan would have been better.

The Organization Without a Plan

The retail and e-commerce enterprise from Chapter Five. More than a thousand employees were impacted and millions in online revenue lost. The failure was the result of a cascade of configuration errors, unpatched systems, and converging failures that took everything offline on a Tuesday.

For the first twenty-four hours, leadership did almost nothing productive because they didn't know what to do. There was a lot of finger pointing. A lot of how did this happen? There were lots of questions, but no good answers. What they were missing was an incident response plan. They had failed to prepare, so in the

moment of crisis they were negotiating all of the things that should have already been decided.

The questions that consumed those first critical hours weren't tactical: they were pragmatic. Who's in charge? Who do we call first? What do we tell the board, employees, customers, regulators? Do we need outside help? Every one of those questions should have been answered before the event happened. Instead, they were debated in real time, under stress, with the clock running and the damage compounding.

Six days offline. Millions in lost revenue. Customer trust shattered. Leadership positions eliminated.

The absence of a plan turned a serious incident into a catastrophe.

The Organization With a Cool Head

Now let's look at the mid-sized company from Chapter One. They got hit with a ransomware attack and the attackers were still active inside their network when we arrived. The CFO had taken charge and his first instinct was to keep it quiet.

This organization didn't have a plan either. They thought insurance was enough. But in the absence of a plan, they had the sense to bring in someone who had actually done this before. Once the decision was made to act and engage professionals, the response was disciplined. They had an anchor.

You know the technical sequence from Chapter Eight: disconnect, isolate, preserve the evidence, wipe and restore from clean backup. Fortunately, the backups were not impacted and

we were able to restore everything with minimal loss. Once the primary systems were restored, we created a remediation plan to reduce the likelihood of this happening again and coached leadership on communication with employees and customers. Ultimately, they refused to pay the ransom so they had to prepare for the data dump.

The timeline was five days from detection and three days offline to restoration of core systems. The company survived. Given what happened, it could have been worse.

The difference between six days and three days wasn't the technology or the capabilities of the people involved. Both organizations had the technical capability to recover. The difference was decision-making speed. One organization spent days figuring out what to do. The other started doing it immediately, because the CFO knew they were in over their heads and put someone in the room who deals with cyber incidents every day. They had a playbook.

Build the Playbook You Need Before You Need It

Incident response is the chapter of this book that I hope you never need, but if you have followed along this far, you know that hope is not an effective strategy.

You can have a great team with the best tools. You can do everything right and pass all of your audits. But a sophisticated and determined attacker will always be able to find a way in.

AI has compressed the timeline and accelerated the pace that bad actors are moving at. Worse than that, AI has enabled less

sophisticated bad actors to use the same tactics, techniques, and procedures the most sophisticated groups use. So, the question isn't whether it will happen, it's will you be ready when it does. That statement is not intended to scare. It is the world we live in today.

A good incident response plan doesn't need to be complicated. In fact, the simpler it is, the more likely people will actually maintain it and follow it under stress. Here's what it needs to cover.

Roles and responsibilities. Before the event happens, everyone needs to know their role. Who is in charge? Who briefs the board? Who manages communication? What is disclosed when and to whom? Who leads the technical response? Who authorizes spending? These are the business decisions that need to be made in advance. When the alarm goes off is not the time to figure out who's in charge and what to do first. The worst communication failures I've seen during cyber events aren't the result of bad messaging. They're the result of no messaging, because nobody knew whose job it was.

The most consequential decisions happen in the first sixty minutes. The plan should spell out exactly what happens: who can declare an incident, who gets called, in what order, who needs to be on the call, and what actions are taken immediately. Two streams need to be started simultaneously. The business stream outlined above and the technical stream described next. The technical lead focuses on containment actions, isolating affected systems, severing network connections and preserving evidence.

This course of action should be pre-authorized so the response team can execute without waiting for a conference call that takes an hour to organize.

If you aren't running tabletop exercises and updating the plan after each one, you aren't prepared.

The Leadership Problem

The plan is your playbook. The human factor shows up when you mobilize it. That's the part you can't write down and why practice is so important. Every story in this book focuses on a leadership decision: the CFO who wanted to cover up the ransomware attack, the CISO who cancelled security projects to save code, the retail enterprise whose leadership spent days in denial, the project that hit a dead stop because nobody thought to put a security translator in the room. The technology was there in every one of them. What failed was a person at the top making a decision they hadn't been prepared to make.

I'm not blaming any of the people involved. They all thought they were doing the right thing. The CFO who wanted to hide the breach wasn't a bad person, he was scared. He had built a career on controlling bad news before it became somebody else's. The other two stories aren't really different. Untrained people, untrained reflexes, no rehearsal. The solution isn't better people, it is leaders who've already seen the situation, in a conference room during a simulated exercise, before the real crisis strikes.

Where Leaders Go Wrong

In my experience, the leadership failures cluster around two reflexes, with a third hiding behind them.

Denial is the one that costs you time. This is what I saw at the retail enterprise. The likelihood of all of the cascading events occurring in sequence to cause the failure was so remote, they couldn't believe it actually happened. In the face of what had just happened, they even said this could never happen again. But it did happen.

If your whole career has reinforced the belief that serious cyber events happen to other companies, your first response when one hits yours is going to be disbelief. And every hour of disbelief is another hour of inaction.

The cover-up is the one that ends careers. When something goes seriously wrong, a certain kind of leader's first instinct is to control the narrative: minimize, buy time, figure out how bad it is before anyone outside the room finds out. That instinct works in plenty of business contexts. It does not work here. The cover-up is important enough to dig deeper into because it's the failure that turns a survivable incident into a career-ending one.

Behind both of those sits the quietest failure, the one that may actually be the most common in managing cyber risk. The default by leadership is to delegate. It is the CEO who says "handle it, keep me posted" and goes back to their other priorities. The event gets handed to the CISO, the CIO, or whoever picked up the phone, and the leadership team disengages. The trouble is that the decisions that drive a cyber response involve disclosure,

business continuity, customer communication and legal strategy. These are not technical decisions, they are leadership decisions that impact the business and the share price. The regulators don't care that you delegated. The shareholders don't care that you delegated. You are the one with the fiduciary responsibility, regardless of who's actually executing the response.

The Cover-Up: Why It's the Deadliest

Of the three failure patterns, the cover-up is the scariest because it's the one that takes a bad incident and turns it into a career-ending one. I keep coming back to the CFO who wanted to sweep the ransomware under the rug, because his instinct represents the single biggest threat to effective incident response: the impulse to hide instead of act.

This is the internal conflict you don't want to be wrestling with in the heat of the moment. Your containment instinct says: stop the bleeding, understand what happened, limit the damage, and recover. The other side of the argument is the cover up. That side of you is thinking: minimize, delay, control the narrative, and hope nobody finds out. These are decisions you need to make with a clear head and commit to before you end up in a position where a bad decision could cost you your career.

I've covered the legal reasons in Chapter One. There are consequences for concealing a breach. If your company is subject to regulatory requirements, you may have personal liability or be subject to criminal charges. Joe Sullivan wasn't convicted for the

breach. He was charged and convicted for the cover-up. The practical reasons are just as compelling.

While you're hiding the breach and the wrong people are scrambling to figure out what's going on, the attackers are still inside. Every hour of concealment is an hour of delayed action. The breach gets worse while you're pretending it isn't happening.

When the concealment is discovered, and it almost always is, through leaked data, forensic investigation, or a whistleblower, the resulting blowback is always worse. The original breach was bad. The cover-up becomes the story. When the news comes out, customers could choose to vote with their dollars. Even a temporary loss of customers adds to the financial impact of the incident. Then there is the personal blowback. Regulators rarely show leniency for delayed notification of reportable incidents and boards don't retain executives who conceal material events.

The incident response plan needs to explicitly address notification and disclosure timelines. The key regulatory disclosure requirements are covered in Appendix B. The decision to disclose should not rest with a single executive acting under stress. It should be a documented process that addresses everything the company is required to do, reviewed by legal and approved by the board. The plan should include all of the difficult decisions made in advance. This is important because under stress, people tend to make poor decisions and those decisions have consequences.

The Speed Problem

AI has compressed the attack timeline, and accelerated attacker capability. That compression and acceleration have direct implications for incident response.

Traditional defenses, security operations and incident response playbooks were built for human-speed attacks. An attacker gets in, spends days or weeks establishing a foothold, moves laterally through the network, and eventually reaches their objective. We build layered defenses to give the defenders time to detect the intrusion and respond before the worst damage is done.

AI-powered attacks compress that time window. Automated reconnaissance, AI-generated social engineering, evasion-optimized payloads, and autonomous malware can compress the attack timeline from weeks to hours. An AI-powered attacker inside your network isn't methodically mapping the environment the way a human operator would. It's moving fast, making decisions in real time, and adapting to your defenses as it encounters them.

If your incident response plan depends on a human analyst detecting the attack, convening a call to brief the team and debate what to do, and then executing, you are operating at human speed against a machine-speed attack. By the time you've completed step one, the attacker has already won.

This means two things for your incident response plan.

First, the detection and initial containment should be automated wherever possible. AI-powered security tools that can

detect and respond to threats in near real time buy you the time that human-speed response can't. The automation takes immediate steps to contain the intrusion in the first critical minutes while the human team mobilizes.

Second, the human response needs to be faster. In the military, whenever we learned a complex skill, we were told: *slow is smooth, smooth is fast*. That means take your time and get it right. Each time you practice, you will get better and faster. Take the time to build the plan but keep it simple, and don't forget the practice. The response team should be able to activate in minutes, not hours. Have the debate and make the decisions in advance. Support those decisions with templated documents that have been through legal review and board approval.

Practice, Practice, Practice

I cannot overemphasize this: a plan that hasn't been practiced isn't a plan, it's a document. As an auditor I saw too many binders of disaster recovery plans that were prepared for people like me, but upon examination hadn't been updated in years. You don't need an auditor-ready document. You need a lean, well-organized plan that accelerates the human response through preparation and advance decision-making, and puts the hard decisions on the right people in the organization.

Tabletop exercises are the minimum. Walk your leadership team through a simulated incident at least twice a year and make sure they are realistic enough to hurt. A good tabletop exercise puts the CEO, CFO, General Counsel, CISO, and head of

communications in a room and says: "It's Tuesday morning. You've just been told your customer database is on the dark web. What do you do?" Then the facilitator adds complications every fifteen minutes. The press is calling, a regulator is asking questions. A major client wants a briefing. The board chair is on the phone. All the while the attackers are still inside your network.

The first time a leadership team goes through this exercise, the response is almost always messy. People don't know their roles. Decisions get delayed. Communication breaks down. Someone tries to delegate and discovers there's nobody to delegate to. It's uncomfortable, and that's exactly the point, because it's infinitely better to be uncomfortable in a simulation than in a real crisis. In the military we said *the more we sweat in training, the less we bleed in combat*.

Each time the team goes through the mock scenario, the performance improves. By the time a real event hits, and it will, the team has practiced the response enough that the denial phase is measured in minutes instead of days, and the cover-up instinct is overridden by the muscle memory of disclosure protocols they've already rehearsed. The three failures from earlier in the chapter become much harder to fall into when you've spent time in the room together rehearsing the alternatives.

Technical drills go deeper. Your security and IT teams should practice the actual execution (disconnecting systems, activating backups, deploying containment measures, restoring from backup) on a regular basis. The ransomware victim survived

because the response team executed a clean, disciplined recovery. They did it well because they brought in experts who had a playbook and used it.

After every exercise and every real incident, it is important to conduct a thorough after-action review to identify what worked and what didn't. What decisions took too long and where did communication break down? What do we do differently next time? The after-action review is where the plan improves. Skip it, and you are likely to make the same mistakes next time.

The Executive's Role

I never thought I would be paraphrasing Kipling in a business book about cybersecurity, but: *"If you can keep your head when all about you are losing theirs and blaming it on you, if you can trust yourself when all men doubt you..."* This cool head and confidence under pressure comes from preparation. Your role during a cyber event is not to run the technical response. That's your CISO's job, supported by the response team. Your role is to make the decisions that only you can make.

Do we disclose? When? To whom? What do we tell the employees? Do we engage law enforcement? What do we spend on the response? These are leadership decisions that directly affect how your company comes out on the other side of the incident. If you've prepared, if you've participated in tabletop exercises, if you know your role in the response plan, if you've thought through the decision frameworks in advance, you'll make these decisions quickly and well. If you haven't prepared,

you will likely waste precious time and make mistakes, or you'll delegate decisions to people who don't have the authority to make them.

The Board's Role When the Alarm Goes Off

Your role isn't the only role at the top of the org chart. The board has its own role, and it's a role that has to be defined before the event, not created during it.

Three things belong to the board specifically, and they don't transfer to the CISO no matter how good the CISO is.

The first is the materiality call. When a breach is confirmed, someone has to decide whether it rises to the level of an event that has to be disclosed: to shareholders, to regulators, to customers, to the market. That is not a technical question. The CISO surfaces the facts. The CFO models the financial impact. The General Counsel reads the disclosure rules. The board, usually through the audit or risk committee, makes the call. If the board hasn't already agreed on what "material" looks like for this company before the event, they will be debating the answer under stress.

The second is the disclosure decision tree. The minute a breach is confirmed, clocks start. Multiple clocks. The SEC gives publicly traded companies four business days from the materiality determination to file. European data-protection regulators expect notice within 72 hours, sometimes 24. Financial-services regulators want to hear from you within hours.

Health care, education, every state and country where you collect personal information has its own clock and its own reporting threshold. A single incident routinely triggers seven or eight of them at once. The clocks most likely to apply, by jurisdiction and trigger, are mapped out in Appendix B. So is the role-by-role accountability behind these decisions.

The board doesn't notify anyone. The board owns the decisions about what gets disclosed, in what sequence, by whom, and over whose signature. Work out the decisions and approval before the alarm goes off, not after.

The third is regulator engagement at the strategic level. Sometimes the call to a regulator goes through outside counsel. Sometimes a regulator wants to talk directly to the chair of the audit committee, or to an independent director. Sometimes a director receives a subpoena and an interview request before the lawyers can finish triaging. The board needs to have decided in advance who speaks to which regulator, with what counsel in the room, and with what guardrails. Trying to figure that out in the middle of a 72-hour notification window is how directors end up making statements they later wish they hadn't.

Behind all three is a quieter point: the board is on the hook for these decisions whether they prepared for them or not. Regulators and shareholders don't grade on effort. They grade on results. A board that delegates the call and walks away will discover that the delegation didn't transfer the accountability, it transferred the workload.

Three Questions Before You Need Them

Do we have an incident response plan that addresses the most likely threat scenarios we face? Who owns and maintains it? Are we running regular practice sessions with all of the relevant stakeholders? When you can answer these questions in the affirmative, you have exercised due care.

CHAPTER ELEVEN

Talking to Your Board



The bank president in North Carolina understood something that most executives don't: if you can't understand the security briefing, the problem isn't you, it's the briefing.

I've sat in on dozens of executive briefings over the course of my career and seen CISOs present forty-slide decks full of technical metrics that mean nothing to the people in the room. The executives nod politely, ask no questions, and move to the next agenda item with zero understanding of what was just presented or the organization's actual risk exposure. When the breach happens six months later and the board asks "how did this happen?", how are you going to answer? You were in the briefing, but the communication failed.

The board's job is governance and oversight. They need to understand the organization's cybersecurity risk posture well enough to make informed decisions about funding, strategy, and executive accountability. They don't need to understand how a firewall works, but they do need to understand whether their perimeter defenses are adequate for the threats the organization

faces. Insist that your team refrains from the geek speak and communicates clearly.

This chapter is about how to present the information they need so they can understand it.

The Current State of Board Engagement

Most boards treat cybersecurity as a quarterly agenda item. The CISO gets twenty minutes. The presentations all look and feel the same. Dashboards show all of the positive metrics. Incident reports are minimal and not material. The emphasis is on compliance because the compliance bar is low. The board asks a few softball questions and everyone moves on.

This is theater, not governance.

The board walks away believing the organization is in good shape because they saw a clean audit report and green on every metric. The CISO walks away frustrated because they couldn't communicate the real risk in twenty minutes of slides nobody engaged with. And the distance between the board's understanding and the organization's actual exposure grows wider with every quarterly meeting.

Most board members take their oversight responsibilities seriously. Unfortunately, the information they're receiving is not presented in a way that helps them make informed decisions. It is filling the allotted time.

Reframing the Question

The communication problem is the surface symptom. The structural problem is one layer down. When the board treats cybersecurity as a quarterly report-out from the CISO, it is treating cybersecurity as a technology issue managed by the technology function. That framing puts the decisions where the authority is not. The CISO can tell the board what is at risk. The CISO cannot decide how much risk the organization tolerates. That is a decision that belongs to the room the CISO is briefing, not to the CISO.

This is the reframe boards need to make explicit before any of the other tools in this chapter (the letter grades, the Three Questions, the AI questions, the standing-priority cadence) will do what they are designed to do. As long as the board behaves as if cybersecurity is a technology issue delegated to the CISO, the communication tools amount to better window dressing on a structural problem. As soon as the board behaves as if cybersecurity is a business continuity and organizational resilience issue requiring executive decisions, the conversation in the room shifts. The dashboard becomes the starting point for the actual conversation rather than the substitute for it. The CISO becomes the trusted advisor to the room rather than the person carrying the risk on behalf of it.

The board does not have to redesign its agenda to make this shift. It only has to be willing to ask, on the first agenda item where cybersecurity comes up, the question that names the reframe: *"What decisions are we being asked to make today that*

the security team cannot make on their own?" Once that question is on the table, the rest of the cybersecurity governance follows from it. Appendix D contains a five-minute script for delivering the reframe and the supporting ask. The remaining sections of this chapter are about what the conversation looks like once the reframe has been made.

Letter Grades, Not Dashboards

The bank president's approach works at the board level for the same reason it works everywhere else: it translates complexity into a decision framework that non-technical leaders can act on.

What if, instead of a forty-slide deck full of metrics, the CISO walked into the board meeting and said:

"Our overall security posture is a B-minus. We were a C-plus at the start of the year. The investment you approved in Q1 closed our three most critical gaps. We still have exposure in two areas, AI governance and endpoint detection for remote workers, and addressing both would move us to a solid B. The cost is \$X. If we don't address them, here's the risk we're carrying."

How different would that be? You get a two minute summary with no jargon and a clear picture of where the organization stands. You have a clear picture of what has changed since the last meeting and what decisions need to be made. Armed with this information, you can ask questions that matter: What does a B-minus mean in practical terms? If we do nothing, what is the exposure? Are there other options that we should consider?

It's the conversation the bank president wanted, the conversation every board should be having but isn't. The CISO has been trained to present in the language of security, not the language of business risk.

The Three Questions as a Board Tool

The three questions I've been using throughout my career translate directly to the boardroom.

"Have we been breached, and how confident are we in that answer?"

This question does two things at the board level. First, it forces an honest assessment of detection capability. If the answer is "we believe we haven't been breached," the follow-up is: "What's that belief based on? What would we miss?" The board should understand that the absence of detected incidents is not the same as the absence of incidents. Dwell time (the months an attacker can sit inside your network undetected) means the honest answer is often "we don't know for certain."

Second, it establishes the tone for the rest of the conversation. If the board accepts "we haven't been breached" at face value and moves on, the rest of the briefing becomes a formality. If the board probes the confidence level, the conversation becomes real.

"If we were breached tomorrow, how would we know, and how would we respond?"

This question tests both detection capability and incident response readiness. The board should hear a specific, practiced answer, not a theoretical one. "We would know through our

monitoring systems within X hours. Our response plan activates with these roles and these actions. We last practiced this plan on [date]." If the answer is vague, the board has learned something important.

"What would be the financial, regulatory, and reputational impact of a serious breach, and are we comfortable with that level of risk given our current investment?"

This is the decision question. It connects security posture directly to business impact and asks the board to make a judgment call. Not a technical judgment. A business judgment. Are we spending enough? Are we carrying too much risk? Is the residual risk acceptable given our industry, our regulatory obligations, and the value of what we're protecting?

These three questions can structure an entire board security briefing. They're simple enough that every board member can engage with them, and deep enough that the answers reveal the real state of the organization's defenses.

The AI Questions for the Board

Everything in this book has argued that AI is the defining cybersecurity challenge of this era. The board needs to engage with it at the same level of seriousness they bring to financial risk.

Here are the AI-specific questions the board should be asking:

"Where is AI being deployed in our organization? Are we tracking both approved and unapproved?"

The board should receive a regular accounting of AI adoption across the enterprise. Not just the official AI strategy. The shadow AI reality. If the CISO can't answer this question with confidence, that's the most important finding of the briefing.

"What are we doing to ensure we are only uploading data into approved models and that we are validating outputs before relying on them? What are we doing about shadow AI?"

AI systems often process the organization's most sensitive data: customer information, financial data, intellectual property, strategic plans. The board needs to understand what data is at risk and what controls are in place to protect it.

"What are our regulatory requirements in every jurisdiction where we operate and what are we doing to ensure compliance?"

With over a thousand AI-related laws worldwide and growing, this is no longer a theoretical question. The board should understand the organization's compliance exposure and the plan for staying current as regulations evolve.

"Who in our organization is accountable for AI risk?"

If the answer isn't clear, the board has identified a governance gap that needs to be closed before the next meeting.

The CISO-Board Relationship

The quality of the board's cybersecurity oversight depends almost entirely on the quality of the relationship between the CISO and the board.

In a healthy relationship, the CISO has direct access to the board (not filtered through the CIO, the CTO, or another executive who may have competing priorities). The CISO communicates in plain language, presents risk in business terms, and is comfortable delivering bad news. The board asks probing questions, engages with the answers, and treats cybersecurity as a strategic issue rather than a compliance checkbox.

In a dysfunctional relationship, the CISO's message gets filtered, softened, or deprioritized before it reaches the board. Or worse, the CISO communicates in technical language the board doesn't understand. Nobody wants to disrupt the meeting, so the board treats the security briefing as a formality and moves on without understanding the actual risk.

The dysfunctional version is more common. And the consequences are predictable: the board doesn't have the right information to make good decisions and is blindsided when something goes wrong.

If you're a CEO, the single most impactful thing you can do for your organization's cybersecurity governance is to ensure that your CISO has a direct, unfiltered line to the board. Not once a year. Every quarter, at minimum. And the expectation, communicated clearly to both the CISO and the board, is that

the briefing will be honest, it will be in plain language, and it will end with a clear recommendation that the board can act on.

If you're a board member, the most impactful thing you can do is ask questions. Not technical questions, business risk questions. The three questions I outlined above are a starting point. Push for answers that are clearly communicated. If the CISO can't explain the risk in terms that make sense to you, that's a communication problem, not an intelligence problem. You don't need to become a cybersecurity expert, you need your expert to be able to deliver information you can understand and act on.

Making It a Standing Priority

Cybersecurity should be a standing agenda item at every board meeting, not something triggered by an incident.

The threat landscape and regulatory requirements are changing continuously while the organization's AI adoption is accelerating.

A standing agenda item sends a signal to the CISO, the leadership team, and the organization as a whole, that cybersecurity is a governance priority at the highest level. It normalizes the conversation so that security briefings aren't associated with bad news and creates a regular cadence for the questions, assessments, and decisions that keep the organization's risk posture calibrated to reality.

It also ensures that when a breach happens, and the regulator comes calling because customer data ended up on the dark web,

the board isn't hearing about cybersecurity for the first time. They've been engaged, asking good questions and making informed decisions. They are prepared to respond, not because they understood the technical details, but because they understood the risk.

The Translation Problem, One More Time

This chapter is where the translation problem either gets solved or it doesn't.

The gap between cybersecurity professionals and business leaders is not knowledge, it's language. The knowledge exists on one side of the table. The authority exists on the other. The translation between them is what makes governance possible.

The bank president didn't need to understand cybersecurity. He needed someone to talk to him in his language: letter grades, business impact, honest answers to direct questions. Every board deserves the same.

If your CISO can't explain your risk posture to the board in plain English, either the CISO needs coaching or the board needs a translator. That translator might be an external advisor. It might be the CEO. It might be a board member with technology experience who can bridge the gap.

Whoever it is, someone has to own the translation. If they don't, there is a disconnect between the people delivering the briefing and the ones who need to make informed decisions. Nobody should be surprised when bad things happen.

EPILOGUE

The Never-Ending Journey



The first time I asked the Three Questions, I was sitting across a conference table from a CFO at a wholesale distribution company in the late 1990s. I was a senior consultant at Grant Thornton, still finding my voice, still working out how to talk to executives about technology risks they didn't believe applied to them. The questions weren't a framework yet. They weren't on a slide. They were three things I'd started asking because I'd noticed that direct questions worked better than presentations.

Have you ever been breached?

How would you know if you had?

What would the impact be to the business if you had?

The CFO answered the first one quickly and confidently. No, of course not, we have IT for that. He paused on the second one. He didn't have an answer for the third. Twenty minutes later, we were having a different conversation than the one he'd expected to have. By the end of the meeting, he'd authorized work that he would have rejected in the first ten minutes. Not because I'd scared him. Because the questions had done what no amount of

slides could have done: they'd made him think about security risk as business risk.

That was almost thirty years ago.

†

The technology has changed past recognition since then. The Internet was still becoming what it would become. Cloud computing didn't exist as a category. Mobile devices were Palm Pilots if you were ambitious. Cybersecurity as a profession was a small subset of IT, not a board-level function with its own budget cycle and its own legal exposure. The threats were different. The defenses were different. The vocabulary was different.

The questions were the same.

I've watched four major technology shifts cycle through the industry since I asked that CFO whether he'd been breached. The Internet changed the way we do business. It changed the attack surface and our exposure to bad actors a world away. The cloud completely changed network architecture and data residency. It also broke the perimeter security model we had been operating under for years. Mobile and BYOD changed the way we access systems and data.

All of these things added to the risk and complexity of the enterprise. These are real business problems, not IT problems. The decision to throw more technology at the problem was never the answer. It only provided a false sense of security to the people

making the decisions. And now AI, which is the largest and fastest change to the world by every measure that matters.

Each shift produced the same pattern. A wave of enthusiasm swept through the business, and early adopters scrambled to get ahead of the curve. Security and governance lagged behind, because almost nobody understood how fundamentally the risk exposure had shifted. Then the first generation of incidents arrived and surprised everyone except the people who'd been warning about them. The demand for someone to do something produced hastily drafted regulation that was difficult to comply with and didn't really address the root of the problem. And the hard-won discipline that took years to bake into how organizations operated and managed risk had to be refreshed for the new landscape. We updated the rules and approval processes to ensure decisions on risk were being made by the right people in the business with the right information.

And then the next shift would arrive and the cycle would start again.

I've been on every side of that cycle. IT director early in my career, watching from the inside as my own organization wrestled with what was coming. Auditor, watching from the outside as other organizations wrestled with the same things. Integrator, building the systems that would carry the workloads. Vendor, selling the tools that were supposed to defend them. Solutions architect, designing the controls that would have to hold under conditions nobody had quite seen before. The view from each seat is different, and the view I have now is different again, but

the shape of the cycle is the same one I first saw at Grant Thornton.

This is why I keep coming back to the same questions. They survive every evolution because they're not about the technology. They're about the relationship between the people running the enterprise and how they think about the risk they are carrying.

†

The Internet evolved quickly, but over years. The cloud was complex, but we had a decade to figure it out.

AI is different. AI is changing the way we think. We don't have ten years to figure it out. It is here now and accelerating.

I want to be honest about that, because I've spent the last two hundred pages telling you that the discipline doesn't change. It doesn't. But AI is not just another iteration of the same cycle. It is changing the world we live in, the regulatory landscape, the way we think about work, and the pace of decision-making, all at once and at a speed we haven't seen before.

All of the previous waves were revolutionary, but we had time to consider the risk of adoption and adapt to new ways of doing things. AI is changing everything at once. And to make matters worse, it's adding something new to the equation: it's putting decision-making capability in the hands of every person and every system in your enterprise without them knowing how it works and the consequences of their actions.

Take one example of what that step change looks like. For thirty years, finding security flaws in production software was

specialist work, the kind nation-state intelligence agencies did with rooms full of researchers and tooling nobody else had. By the middle of 2025, AI was doing it. By April 2026, a small, cheap AI model was finding the same flaws as the most powerful ones. The cost was pennies.

The infrastructure couldn't keep up. The federal agency responsible for cataloging known vulnerabilities formally pulled back from universal coverage because it could not keep up with the volume being submitted. Median time from disclosure to exploitation is now five days. Mean time to patch in most enterprises is five months. The security stack most enterprises run assumes a gap that no longer exists.

The product manager who builds an AI tool over the weekend isn't writing code in any meaningful sense. She's describing what she wants and getting it. The same is true of the attacker who is using AI to be more efficient in planning and perpetrating an attack. The barrier to creating something powerful has collapsed.

That collapse is what makes AI different. The cycle is the same. The pace of the cycle is not. And unfortunately, traditional approaches simply cannot keep pace.

†

So here's what I want to leave you with. Not a recap of what I've argued. You can flip back to the chapters if you need the arguments. What I want to leave you with is a posture for the journey.

Security has no final destination. There is no point at which you arrive. There is no certification, audit report, or maturity model that says you're done and 100% secure. Anyone who tells you otherwise is selling you something, and the thing they're selling you will be obsolete before you get it implemented.

The posture is simple: ask the right questions, of the right people, at the right time. Demand the information you need so you can make good decisions for your business. The cycle never ends. Technology changes, the questions evolve. The discipline does not change.

The cowboys will always exist. There will always be people inside your organization who want to move faster than the controls allow, who see governance as friction, who are convinced that the rules don't apply to their particular use case. That's not a failure of culture. It's a permanent feature of any organization deploying powerful technology.

We will never fully eliminate rogues in the organization. But we can make sure that everyone understands the rules, and do what is necessary to rein in the ones who are operating outside them. We can make sure that the people moving fast are doing it within a structure that catches them when they fall.

AI is in your enterprise. That is not reversible. You can only decide how seriously you intend to govern it, how honestly you intend to assess it, and how prepared you intend to be for the moment when something goes wrong. That moment is coming. The only variable is whether you've done the work before it arrives or whether you'll be doing it during the crisis.

The path forward is simple, but not easy. It's a phrase I use a lot because it's true. The principles are not complicated. The execution is hard. Both halves matter.

†

The questions I asked that CFO in the late 1990s are still the right type of questions. They've earned their second iteration for the AI era, and I'll leave you with them as the working tools you can take into your next executive offsite, your next board briefing, your next conversation with your CISO.

Do you know where AI is being used across your entire organization, sanctioned and unsanctioned?

How would you know if an AI system was making a bad decision with our data, our customers' data, or our reputation?

What would be the financial, regulatory, and reputational impact if our AI adoption went wrong, and who in the organization is accountable for that outcome?

If you can answer those three questions confidently, you're further along than most. If you can't, you've found your starting point.

More than twenty-five years ago, a bank president in North Carolina stood up at the end of an impressive technical presentation and told me he had no idea what any of it meant to him and his business. It would have been easy to hear that as a confession. It was an instruction. He made me translate. He asked his questions, got answers he could use, made his decision, and owned it.

Everything in this book has been preparing you to be the person he was in that room. Not a cybersecurity expert, but the executive who demands the translation, asks until the answers make sense, decides with eyes open, and carries the decision. You carry it either way.

The frontier will keep moving. The technology will keep changing. The questions will evolve, the way they have for the thirty years I've been asking them. The job does not, because the work is not the answers. The work is asking the right questions and demanding the right answers even if you don't like them.

So I'll leave you where my education started. How much did you spend? Where were you when you started? Where are you now?

Do you need to be an A?

You're ready to answer that now.

Be vigilant. Be the anchor.

Acknowledgments

†

No book gets written alone, and this one has thirty years of debts behind it.

Sam Rehman is a mentor, friend, and the person I call when I need someone to tell me I'm wrong. Thank you for the foreword, and for years of conversations that sharpened every idea in this book.

Early in my career, a bank president in North Carolina listened to my best technical presentation and told me he had no idea what any of it meant to him and his business. He changed the way I think about cybersecurity and communication, and he's the reason this book is written for executives, not technologists.

Over the last thirty years, more people than I can name here saw something in me before I saw it in myself. You gave me opportunities I hadn't yet earned and trusted me to figure it out. I did my best to earn that trust. This book is part of that effort. Thank you.

APPENDIX A

The Regulatory Frontier



A note before you read this.

The regulatory landscape for cybersecurity and artificial intelligence is moving faster than any printed material can keep up with. By the time this book is in your hands, some of what I write here will already be out of date: a new EU directive will have entered force, a U.S. state will have passed a privacy law that didn't exist when I wrote this sentence, the SEC will have reversed itself on a disclosure rule, a federal AI bill will have advanced or stalled.

That is the nature of the territory. So what I'm offering you in this appendix is not a snapshot. It's a map and a posture. The map shows you the shape of the terrain and the named voices who are surveying it. The posture is how to stand on it without getting knocked over by the next thing.

If you want a snapshot, ask your General Counsel. If you want to know which way the wind is blowing on the frontier, read on.

The shape of the landscape

A handful of bodies of regulation touch most enterprises. You don't need to be an expert in any of them. You do need to know they exist, and where they overlap, so you can assess whether your house is in order with respect to each.

U.S. federal regulation

U.S. federal regulation is a patchwork rather than a unified framework. There is, as I write this, no comprehensive federal privacy law and no comprehensive federal AI law. Both have been talked about for years. Either could change before this book is reprinted. What does exist is a set of overlapping regimes that you have to assemble into a coherent picture yourself.

Sarbanes-Oxley applies to public companies and reaches cybersecurity through internal-controls requirements. The SEC's cybersecurity disclosure rules, in force since late 2023, require public companies to disclose material cybersecurity incidents on Form 8-K within four business days of determining materiality. The materiality determination itself has become its own discipline: when does an incident cross from operational issue to material event requiring board attention and public disclosure?

The answer is judgment-laden, and getting it wrong has consequences in both directions: disclose too aggressively and you create panic and legal exposure; disclose too late and you create different legal exposure plus the regulatory presumption of concealment.

Sector-specific regimes overlay industry-specific requirements on top of all of this. HIPAA governs the protection of health information and reaches anyone in the chain of healthcare data: providers, payers, business associates. Gramm-Leach-Bliley applies to financial institutions and imposes safeguards rules that have been enforced with growing vigor by the FTC. CMMC (the Cybersecurity Maturity Model Certification) applies to defense suppliers and is the framework that determines whether you can hold a contract with the Department of Defense. Each of these has its own audit cadence, its own findings categories, and its own enforcement teeth.

U.S. state regulation

The state level is where most of the action is, and the trajectory tells the story. Stanford's 2026 AI Index Report tracked 1,208 AI-related bills introduced across all fifty state legislatures in 2025, with 145 enacted into law, up from 131 enacted the year before, 49 in 2023, and just one in 2016. The picture for state privacy law is different but not less complex: as of January 2026, the IAPP counts nineteen states with comprehensive consumer privacy laws in effect, covering more than half of the American population.

A nuance worth holding: privacy actually slowed in 2025. For the first time in five years, no new comprehensive state privacy bill passed. But the AI gap filled in fast: every state that had a privacy law in 2024 has either added AI legislation or has it pending in 2026. Texas, Utah, and Tennessee have passed

targeted AI laws focused on specific use cases. California is layering AI-specific provisions on top of CPRA. Colorado's AI Act, the first comprehensive state AI law, takes effect in 2026 and will likely become a template for other states.

The operational reality for an enterprise: if you operate in multiple states, you face a compliance matrix, not a checklist. The matrix changes every legislative session. Most of these laws have extraterritorial reach: California's privacy law applies to any business processing California residents' data regardless of where the business is located, and other states are following that pattern. You don't get to opt out by locating your headquarters elsewhere.

The European Union

The European Union is the most demanding regulator in the world for both data and AI, and it operates as a coherent legal system across twenty-seven member states. Four major regimes matter for most enterprises.

GDPR has been in force since 2018 and shapes how every multinational handles personal data. It established the global template for data protection rights, breach notification obligations, and the principle of extraterritoriality: if you process EU residents' data, GDPR applies to you whether you have a European office or not. The penalty regime tops out at four percent of global annual revenue, and that ceiling has been hit in several cases.

NIS 2, the updated Network and Information Security Directive, expands cybersecurity obligations far beyond the

original 2016 directive, reaching into supply chains and adding governance requirements for management bodies. Enforcement began in October 2024, and DLA Piper's February 2026 update notes that the EU is now actively moving to harmonize NIS 2 implementation across member states and add new in-scope entities. The directive is still evolving even after entering force, which means a compliance posture that was current in 2024 may be inadequate in 2026.

DORA, the Digital Operational Resilience Act, sets specific requirements for financial institutions covering ICT risk management, incident reporting, third-party risk, and operational resilience testing. DORA's penalty regime is where the fragmentation problem becomes vivid. Member states transpose the directive into national law, and the resulting individual penalties under Article 50 range from one hundred thousand euros in Finland to five million euros in Germany, a fifty-fold gap for the same underlying violation depending on which member state's regulator is enforcing.

The EU AI Act is the most comprehensive AI regulation in existence. It classifies AI systems by risk tier: unacceptable, high, limited, and minimal. It imposes obligations that range from transparency requirements to outright prohibitions. The penalty regime mirrors GDPR's percentage-of-revenue structure but with higher absolute caps for the most serious violations. The Act applies extraterritorially, the same way GDPR does. If your AI system serves EU residents, the Act applies to you.

Other major economies

Beyond the U.S. and EU, the OECD's AI Policy Observatory currently tracks more than 900 national AI policies and initiatives spanning over seventy countries, and the OECD's policy navigator reaches into more than eighty jurisdictions. EY's Global AI Law Guide compares regulatory frameworks across thirty-seven of those jurisdictions, and the gaps between them are not academic.

The UK has its own data and AI approach post-Brexit, broadly aligned with GDPR but diverging in specific areas as the Information Commissioner's Office charts an independent path. China has the most aggressive AI governance regime in the world, with mandatory algorithm registration for any AI system that influences public opinion or makes recommendations to consumers.

Japan has taken a lighter-touch approach focused on industry self-regulation backed by sector-specific guidance. Brazil's LGPD mirrors GDPR in structure and is enforced by the ANPD. Canada is in the middle of overhauling its federal privacy framework. Australia has updated its Privacy Act and is working through AI-specific reforms.

For a multinational, the operational consequence is straightforward. You align to the most demanding set of requirements in any market you serve and build a plan to handle any divergence as part of your compliance burden.

Industry frameworks and standards

Industry frameworks and standards sit alongside the laws. NIST's Cybersecurity Framework and AI Risk Management Framework are voluntary in most contexts but treated as the de facto baseline by U.S. regulators. When an enforcement action follows a breach, the question of whether the organization was operating consistent with NIST guidance is one of the first that gets asked. ISO 27001 sets an international information security standard. PCI DSS governs payment card data and remains, in my experience, one of the most operationally rigorous frameworks in industry use. SOC 2 reports are demanded by every enterprise customer in the technology supply chain. None of these are laws, but ignoring them creates business consequences that look very much like regulatory ones.

That's the shape of the terrain. Organizations defining standards and regulators defining compliance requirements and penalties. They are evolving together and have a symbiotic relationship. They dictate what you need to do and impose penalties on your enterprise and, increasingly, on you personally for failure.

A gap the frameworks don't yet reach

There is one specific gap in the frameworks I walked you through worth surfacing on its own, because it has come into view very recently. AI agents have been finding software vulnerabilities at industrial scale since the middle of 2025. Google's Big Sleep agent

has been reporting verified zero-day bugs in production software since November 2024.

The AI security firm AISLE has accumulated more than one hundred and eighty externally validated CVEs against open-source projects most enterprises run, Linux kernel and OpenSSL among them. In May 2026, Google's Threat Intelligence Group confirmed the first criminal use of an AI-generated zero-day exploit in the wild.

None of the regulatory regimes I described above tell you how fast you must patch a vulnerability disclosed against your supply chain that an AI agent found. NIST's AI Risk Management Framework, finalized in 2023, governs how you deploy AI inside your own enterprise. NIST released a draft Cybersecurity Framework Profile for Artificial Intelligence in December 2025, known as NISTIR 8596. It is still in public comment as I write this. It adds a focus area for AI-enabled attacks but is non-prescriptive on response timelines. The EU AI Act regulates AI systems by risk tier and obligates transparency for high-risk deployments, but it does not address the case where someone else's AI agent finds a vulnerability against software you run.

The infrastructure most enterprise vulnerability management depends on is itself under structural strain. On April 15, 2026, NIST formally acknowledged that the National Vulnerability Database could no longer keep up with the volume of submissions and moved to a risk-triaged enrichment model: only CVEs in CISA's Known Exploited Vulnerabilities catalog or tied

to critical federal software under Executive Order 14028 will be enriched going forward. CVE submissions grew two hundred and sixty-three percent between 2020 and 2025 and are forecast to grow another forty-five percent in 2026. The vulnerability management workflows your team relies on were built for a world in which NVD enrichment was universal and timely. That world stopped existing in April.

Cyber insurance is where this lands first. Insurers do not wait for regulators. They price what they expect. Industry analysts widely anticipate new exclusions specifically for AI-discovered, unpatched-within-window issues and a repricing event after the first high-profile post-discovery enterprise loss. If your cyber insurance broker has not put a written position in front of you on coverage of AI-disclosed vulnerabilities specifically, ask for one. The answer will tell you more about where the regulatory frontier is moving than any framework document currently published.

The pace problem

I want to be specific about why this is harder than other compliance work.

Traditional compliance domains move at a pace that compliance teams can absorb. Tax law changes annually with the budget. Accounting standards change every few years through formal processes that get telegraphed for years before they take effect. Even employment law, which evolves at the state level

constantly, follows recognizable patterns that experienced lawyers can anticipate.

AI regulation moves at the pace of the technology, which is to say, faster than any annual review cycle. The Stanford AI Index trajectory I cited bears repeating because the slope tells the story: one state-level AI law in 2016, forty-nine by 2023, one hundred thirty-one in 2024, one hundred forty-five enacted in 2025, and that's just the United States. The OECD's count of more than 900 active national AI policies worldwide includes many that target capabilities that did not exist eighteen months before the policy was drafted.

KPMG's 2026 Cybersecurity Considerations report frames it bluntly: rising geopolitical tensions, fragmented regulations, and data sovereignty requirements are forcing organizations to redesign technology architectures and compliance approaches. Not adjust them. Redesign them. KPMG's Board Leadership Center put it this way in a 2026 piece on regulatory fragmentation: "Regulatory fragmentation across federal, state, and global jurisdictions has become a defining feature of the global business environment, directly impacting decisions on where to grow, how to structure products and data, and how to design governance and control frameworks."

This is the pace problem. The laws are not unusually complex, the cadence of legislative activity has eclipsed the pace at which most enterprises are equipped to track and respond. The companies that will get caught have been relying on compliance

for the last twenty years and assuming it will keep working for the next five.

It won't.

The cross-border operating reality

If you operate in a single jurisdiction, the regulatory burden is real but bounded. If you operate globally, which most enterprises of meaningful scale now do, the burden compounds in ways that are easy to underestimate from headquarters.

There are three patterns worth calling out here.

Data residency requirements are multiplying. We see a growing list of jurisdictions that require certain categories of data to be stored within the country's borders, processed only by local entities, or transferred internationally only under specific approval regimes. China, India, Russia, and a number of Middle Eastern countries have aggressive residency requirements. The EU's data transfer regime under GDPR (Standard Contractual Clauses, adequacy decisions, the Schrems rulings) has been re-litigated multiple times and is still evolving. For a global enterprise, the question of where your data physically sits is now a regulatory decision, not just an architectural one.

It is not uncommon to see conflicting requirements and it is increasingly possible to be subject to two regulatory regimes that demand opposite things. A breach disclosure that satisfies the SEC's four-business-day window may exceed the EU's seventy-two-hour notification requirement under GDPR. An AI governance approach that meets China's algorithm registration

requirements may conflict with the EU AI Act's transparency obligations. A data retention practice required by U.S. financial services regulation may violate a foreign country's data minimization principle. There is no central authority that resolves these conflicts. Each enterprise has to navigate them individually, usually by aligning to the most demanding requirement and documenting the rationale.

The talent problem is structural. ISC2's 2025 Cybersecurity Workforce Study found that ninety-five percent of organizations report at least one skills gap on their cybersecurity teams, and fifty-nine percent describe those gaps as critical or significant, up from forty-four percent the year before. The skills gap in regulatory and compliance roles, specifically for cyber and AI, is even more acute. The expertise required to track multiple jurisdictional regimes simultaneously is rare and getting rarer relative to demand. If your General Counsel's office is staffed for the regulatory landscape of 2018, it is dangerously understaffed for the landscape of 2026.

This is the operating reality for any enterprise that has crossed national borders. It does not get easier as you grow.

Personal liability — the handle

I covered the personal liability shift in Chapter One, including the asymmetry between Joe Sullivan's affirmed conviction and Tim Brown's dismissed case as the two-cases lesson on unsettled law. The point in this appendix is narrower: every body of regulation I walked you through is increasing the surface area of

personal exposure, not decreasing it. The Brown dismissal narrowed the SEC's reach over disclosure characterizations that a CISO did not personally approve, but it did not eliminate it, and the EU and member-state regimes are moving in the opposite direction entirely.

NIS 2 Article 32 allows competent authorities to ban senior management from holding executive positions for non-compliance. Germany's transposition includes personal fines up to five hundred thousand euros against named individuals. DLA Piper's October 2025 analysis of DORA penalty regimes shows individual penalties under Article 50 ranging from one hundred thousand euros in Finland to five million euros in Germany, divergence among member states that itself becomes part of the compliance burden for any institution operating across borders. The legal principle that an executive can be personally fined or banned from management for a corporate compliance failure is now embedded in EU law, and the implementation differences across member states are not narrowing.

The market is responding to this exposure with its wallet. Proofpoint's 2024 Voice of the CISO survey found that seventy-two percent of CISOs would not accept a position without D&O coverage; in Proofpoint's 2025 edition, sixty-five percent of CISOs reported that their organizations had taken concrete steps to protect them from personal liability. The insurance industry is following the demand: Aon, one of the largest global insurance brokers, now offers Side A D&O policies that explicitly name chief information security officers as Insured Persons.

When two independent industry signals, what executives demand and what insurers underwrite, point in the same direction, the underlying risk is real.

Boards are responding too. The National Association of Corporate Directors published the fifth edition of its Director's Handbook on Cyber-Risk Oversight in April 2026, and its companion 2025 Public Company Board Practices Survey found that seventy-seven percent of directors are now actively discussing the material and financial implications of cyber incidents, a twenty-five-point jump from 2022, and seventy-two percent have taken individual cyber-risk training. The conversation that used to happen once a year as a compliance briefing is becoming a standing topic of board engagement, and the directors who participate in it are protecting themselves while protecting the enterprise.

You are not insulated from this by your title, your tenure, or your good intentions. The regulatory frontier is the legal architecture that turns a failure to prepare into a personal one.

A posture, not a checklist

You cannot personally track this landscape, and you should not try. What you can do — what you must do, given the stakes — is make sure someone at your enterprise has been named, by name, as responsible for tracking it. Not "part of legal." Not "compliance handles it." Someone whose specific job is regulatory radar for cyber and AI, with budget, authority, and a reporting line into the executive team.

This person or function has three jobs. The first is monitoring of the regulatory pipeline globally, reading the proposed rules, tracking the enforcement actions, and translating what's coming into language the business can act on. The second is maintaining a current picture of which laws apply to your enterprise across every jurisdiction you operate in, and knowing when that picture changes. The third is delivering the quarterly briefing for the executive team and the board that answers two questions: where are we currently exposed, and where are the regulators moving next.

Practically, what does this function look like inside an organization? In a smaller enterprise, it can be a single named person, often a senior compliance officer who has been given an expanded charter and a small budget for external monitoring services. In a larger enterprise, it is typically a small team reporting into the General Counsel's office or directly to the Chief Risk Officer, with dotted lines to the CISO, the Chief Privacy Officer, and the AI governance lead. The team uses a combination of subscription services (the major law firms, the IAPP, OECD AI Observatory, NIST publications), participation in industry associations, and direct relationships with outside counsel in the major jurisdictions. The output is not raw monitoring. That drowns the executive team in noise. The output is curated, prioritized, business-relevant analysis.

PwC's 2026 Global Digital Trust Insights surveyed nearly four thousand executives across seventy-two countries and found that the top three regulatory barriers organizations face are third-

party risk management, AI governance, and the cybersecurity of their own technology products, each cited by more than a third of respondents. That is the actual workload your regulatory radar function should be sized for. It is not a part-time job and it is not a checkbox.

Tie this function to the AI governance work I outlined in Chapter Seven. The sheriff's office should not be a single hat; it should include the regulatory radar as one of its core duties, because AI governance and AI compliance are converging into the same conversation. If your governance function doesn't have a clear handle on the regulatory frontier, you've built a sheriff who can't read the wanted posters.

Make compliance and security talk to each other. They are not the same function, Chapter Six made that case at length, but they have to be in the same conversation. Compliance tells you the floor the regulators are setting. Security tells you the ceiling the threats are raising. The distance between them is real exposure, and it is where the next breach will happen.

Build a board cadence around this. Cybersecurity should be a standing board agenda item, as I argued in Chapter Eleven. The regulatory landscape should be part of that briefing every quarter. The good news is that boards are catching up. The NACD numbers cited above tell that story. Your board should be part of that majority, and the regulatory frontier should be on the agenda when they convene.

A short list of questions to take to your team

If you want a single concrete action coming out of this appendix, take these five questions to your General Counsel, your CISO, and your Chief Risk Officer at the next executive offsite. Their answers, or their inability to answer, will tell you where you stand.

First: Who is named, by name, as responsible for tracking cyber and AI regulation at our enterprise? If the answer is more than one name or a department rather than a person, the function is not actually staffed.

Second: In how many jurisdictions are we currently subject to regulatory obligations for cyber, privacy, or AI? If the answer is approximate rather than specific, the mapping function does not exist.

Third: What changed in the regulatory landscape that affects us in the last ninety days, and what decisions does that require from this team? If the answer is "nothing significant," verify that against the OECD AI Observatory and the IAPP tracker before accepting it.

Fourth: What is our personal exposure as named officers under the regulations that apply to us? If your General Counsel cannot give you a clear answer with reference to specific provisions, you need outside counsel to do that analysis.

Fifth: When did we last brief the board specifically on regulatory landscape changes, and when is the next briefing scheduled? If the answer is "during the annual compliance

briefing," cybersecurity regulation has not yet been treated as the standing board topic it needs to be.

Closing

The regulators are the closest thing the AI gold rush has to a sheriff, and the laws are evolving in real time. You are not going to outrun them. The enterprises that fare best in the next five years will clearly demonstrate they made the effort. It is a bit of a balancing act, anticipating what's coming, and treating compliance not as an inconvenience they are forced to deal with, but as one input into the larger question of whether the enterprise is actually prepared for the world it's operating in.

Know the shape of the landscape. Name the person who watches and reports to you on it. Brief the board regularly and tie it into your governance function. Remember that the regulators are not your adversary on this frontier. They are trying to bring some order to a territory where the cowboys are riding hard and the stakes keep rising.

Sources cited in this appendix

For readers who want to verify or follow these sources directly:

- Stanford HAI, *2026 AI Index Report*, Chapter Six (Policy and Governance)
- OECD AI Policy Observatory, oecd.ai (live database, accessed May 2026)
- IAPP, *US State Privacy Legislation Tracker* (January 2026 update)
- KPMG Board Leadership Center, *Regulatory Fragmentation: From Anomaly to Strategic Focus* (2026)

- KPMG, *Cybersecurity Considerations 2026* (April 2026)
- DLA Piper, *NIS2 Update: EU Moves to Harmonise Cyber Controls* (February 2026); *DORA Penalty Regimes: Overview of Divergence Among Member States* (October 2025)
- EY, *Global AI Law Guide* (2024–2025 edition)
- *United States v. Sullivan*, N.D. Cal. (October 2022 conviction); 9th Cir. (March 2025 affirmance)
- *SEC v. SolarWinds and Brown*, S.D.N.Y. (July 2024 partial dismissal; November 2025 dismissal with prejudice); Harvard Corporate Governance Forum analysis (December 2025)
- Proofpoint, *Voice of the CISO* (2024 and 2025 editions)
- Aon, *Individual Protection for Public Company Chief Information Security Officers* (2025)
- ISC2, *2025 Cybersecurity Workforce Study* (December 2025)
- PwC, *2026 Global Digital Trust Insights* (3,887 executives across 72 countries)
- World Economic Forum, *Global Cybersecurity Outlook 2026* (with Accenture, January 2026)
- National Association of Corporate Directors, *Director's Handbook on Cyber-Risk Oversight*, 5th Edition (April 2026), with companion *2025 NACD Public Company Board Practices Survey*
- NIST, *AI Risk Management Framework (AI RMF 1.0)* (January 2023)
- NIST, *Cybersecurity Framework Profile for Artificial Intelligence (NISTIR 8596)* — Preliminary Draft (December 2025)
- NIST, *NIST Updates NVD Operations to Address Record CVE Growth* (April 15, 2026); see also Help Net Security, *NIST admits defeat on NVD backlog, will enrich only highest-risk CVEs going forward* (April 16, 2026)

- Google Threat Intelligence Group, *Adversaries Leverage AI for Vulnerability Exploitation, Augmented Operations, and Initial Access* — H1 2026 (May 2026)
- AISLE, *AI Cybersecurity After Mythos: The Jagged Frontier* (April 8, 2026)

APPENDIX B

Who's on the Hook

†

A boardroom quick-reference on personal accountability for cybersecurity

The window from late 2023 to mid-2026 turned out to be the most consequential period in the history of executive accountability for cybersecurity. Three shifts that used to be theoretical are now in force, and they apply on both sides of the Atlantic. The law no longer treats cybersecurity as an IT-operations matter, the disclosure clock has compressed to hours-or-days and personal exposure for named officers has moved from theoretical to reality.

In Europe, the board must personally approve and oversee the cybersecurity program, not just receive briefings about it. In the United States, the New York financial-services regulator requires the CEO and the CISO to co-sign an annual statement, under their own names, attesting to compliance. The UK has rolled out a board-level declaration on the effectiveness of all material controls, including cyber, starting fiscal year 2026. The pattern is global and converging.

A single incident routinely starts seven or eight clocks at once. Your General Counsel's decision tree is no longer a nice-to-have document. It is a board-level governance artifact.

The FTC has bound a CEO personally for ten years. The Ninth Circuit affirmed the criminal conviction of a CISO. Germany has set hard numerical personal-liability caps in its national law. There is no longer a credible reading of the legal landscape in which "I left that to the security team" is a defense.

Chapter One carried the personal-stakes arc: the Sullivan, Brown, and Rellas cases, the regulations with teeth, the insurance gaps, the privilege architecture. This appendix sits next to that chapter as a working reference. The role-by-role map below shows where personal accountability lands on a typical org chart. The notification-clock table shows how many different clocks a single incident starts. The five questions at the end are the ones to take to your General Counsel.

If your General Counsel wants the underlying statutes and case names, the note at the end of this appendix has them.

Who owns what

Personal accountability for cybersecurity now lands in specific places on the org chart. The boundaries vary by jurisdiction, but in the major Western regimes the lines look like this.

The board. The board owns oversight. That word now means something specific: approving the cybersecurity program, reviewing the company's risk appetite, ensuring management is allocated the resources to deliver, and being trained well enough

to ask the right questions. In Europe, that training duty is personal and non-delegable. In the UK, the board signs a positive declaration on the effectiveness of all material controls, cyber controls included. In Delaware, where most large U.S. public companies are incorporated, the board has a fiduciary duty to oversee mission-critical risks, and the courts now treat cybersecurity as mission-critical for any company that depends on its systems to operate.

The CEO. The CEO sets the tone and signs the certifications. Sarbanes-Oxley puts the CEO's signature on internal-controls statements that, increasingly, depend on cybersecurity. The New York financial-services rules require the CEO to co-sign the annual cybersecurity-compliance certification with the CISO. The FTC has shown, with the Drizly consent order, that it will bind a CEO personally for ten years, beyond the company, beyond the tenure. Public statements about cybersecurity posture flow from the CEO's office, and securities fraud claims tend to follow when those statements diverge from internal reality.

The CFO. The CFO owns the materiality determination: the decision about whether an incident is big enough that the company has to disclose it. The CFO also owns cyber-insurance procurement, the financial-impact estimates that feed disclosure decisions, and the loss-accrual analysis that gets reflected in financial statements. Sarbanes-Oxley certifications under the CFO's signature now sit in tension with cybersecurity events: a

clean financial statement that relies on compromised systems is a problem in waiting.

The CISO. The CISO sits at the intersection of every personal-liability vector and has the smallest safety net. The Uber and SolarWinds cases established that a CISO can be charged personally: criminally for breach concealment, civilly for misleading public statements. The New York rules name the CISO on the annual joint certification with the CEO. European financial-services rules authorize individual fines and management bans. Most CISO engagement letters now include explicit indemnification, named-insured status on the company's directors-and-officers policy, severance protection, and access to independent counsel paid by the company. If your CISO's contract doesn't include those, the question is why not.

The General Counsel. The GC owns the privilege architecture, the notification decision tree, and the litigation hold. The two-track investigation structure Chapter One describes (separate forensic vendors, separate engagement letters, narrow distribution under counsel control) has to be built before the breach, not after. The GC also owns the multi-regulator notification cascade, and a single incident may trigger filings across seven or eight regimes simultaneously.

The CIO, the CTO, and the Chief Operating Officer. Operational accountability for executing the cybersecurity program rests here. In the UK, financial-services firms typically allocate the Senior Manager Function for technology and cyber to one named individual; that person is personally liable if the

firm contravenes the rules and they didn't take reasonable steps. In Europe, the management body has to designate a senior member to oversee third-party technology arrangements. The pattern is consistent: someone's name has to be on each piece of the program.

How fast the law expects you to talk

A serious cyber event typically triggers parallel reporting obligations across multiple regimes. The table below is a working approximation for the regimes most likely to apply. Specific facts will shift specific clocks; your General Counsel should already have a decision tree that covers every jurisdiction where you do business.

If your company...	Who you must tell	How fast
Trades on U.S. public markets	SEC (Form 8-K, Item 1.05)	4 business days after the materiality determination
Operates U.S. critical infrastructure	CISA (CIRCIA)	72 hours · 24 hours if you paid ransom
Is regulated by New York financial services	NYDFS	72 hours · 24 hours if you paid ransom
Holds health information on 500 or more individuals	HHS Office for Civil Rights	60 days
Holds consumer financial information	FTC (Safeguards Rule)	30 days if 500 or more consumers are affected
Has European customers	Each EU country's data-protection regulator (GDPR)	72 hours
Operates in an EU critical sector	National cyber regulator (NIS 2)	24-hour heads-up · 72-hour detail · 1-month final
Is an EU financial entity	Financial regulator (DORA)	~4 hours after classification · 24h · 72h · 1 month
Has UK customers	Information Commissioner (UK GDPR)	72 hours

Has Canadian customers	Federal Privacy Commissioner (PIPEDA)	"As soon as feasible"
Has Quebec customers	Commission d'accès à l'information (Law 25)	"With diligence"
Is a federally regulated Canadian bank or insurer	OSFI	24 hours

Add to that: state attorneys general in every U.S. state where affected consumers reside (clocks vary by state), state insurance commissioners under the model law adopted in most states (typically 60 days), and California's privacy authority for residents covered by the CCPA. A single incident affecting customers across the U.S. and Europe will routinely trigger ten or more parallel filings. That is why the decision tree has to be drafted in advance, not in the first hour of the incident.

Five questions for your General Counsel

If you do nothing else after reading this appendix, schedule a thirty-minute meeting with your General Counsel and ask these five questions.

First, *where is our cybersecurity-disclosure decision tree, and when was it last reviewed?* The tree should specify which clocks apply, which thresholds trigger which filings, who decides materiality, who signs the disclosures, and what counsel reviews each notification before it goes out. If the answer is "we'll figure it out when something happens," that is the answer.

Second, *who is our named outside counsel for a cyber-incident response, and have we engaged them on a retainer?* If the answer

requires a procurement cycle, the cycle hasn't started yet. Major-firm incident-response groups are calendar-constrained; the time to retain is now.

Third, *do we have a two-track forensic vendor arrangement, and which vendor is on which side?* If we only have one vendor and they handle both operational remediation and post-incident analysis, privilege over the post-incident report is at risk before the breach happens. The fix is structural, not cosmetic.

Fourth, *what does our directors-and-officers policy actually cover, and who is named on it?* Specifically, is the CISO named on the Side A layer, and what are the criminal and conduct exclusions? If the policy was renewed without a cyber-specific review in the last two years, it was renewed under outdated assumptions.

Fifth, *what is the board's training cadence on cybersecurity, and is it documented?* European regulators expect training records to be available on request. U.S. shareholders bringing derivative actions look for the same evidence. A board that cannot show its training cadence is a board that cannot show its oversight.

If any of those questions produces a long pause, you have your priority list for the next quarter.

†

A note for counsel: This appendix translates the underlying legal regime into plain English for non-lawyer readers. The principal authorities sitting behind these descriptions (and the ones

counsel should consult directly when specific advice is required) include SEC Form 8-K Item 1.05 and the rules at 17 CFR §229.106 (Regulation S-K); EU Directive 2022/2555 (NIS 2), Articles 20–23 and 32(5)(b); EU Regulation 2022/2554 (DORA), Article 5; GDPR Articles 32–34; NYDFS 23 NYCRR Part 500, including §500.4(d) and §500.17(b); the Caremark line of Delaware fiduciary cases (*In re Caremark*, *Stone v. Ritter*, *Marchand v. Barnhill*) and *In re McDonald's Corporation*; UK Companies Act §§172/174 read with the Senior Managers and Certification Regime and Provision 29 of the UK Corporate Governance Code; Germany's BSIG n.F. §38 statutory liability caps; *In re Capital One Consumer Data Security Breach Litigation* and *Wengui v. Clark Hill*; FTC consent orders against Drizly (2023) and Marriott (2024); *SEC v. SolarWinds Corporation and Brown* (S.D.N.Y., dismissed with prejudice November 2025); and *United States v. Sullivan* (N.D. Cal., affirmed Ninth Circuit March 2025).

APPENDIX C

Threat Intelligence Resources

†

An executive reference on knowing your enemy

There is no one-size-fits-all defense across industries. The threat groups that go after a regional hospital are not the same groups that go after a defense contractor. Their motives differ, as do their tactics, tools, and protocols. If your security program is designed against a generic catalog of "bad things that happen on the Internet," it is almost certainly designed to defend against the wrong things.

The good news, and it is real news, not consolation, is that the infrastructure for knowing who is actually coming for you is mature, public, and largely free. Government agencies publish attributed advisories. Industry consortiums share intelligence in real time among members. Commercial firms publish annual reports that draw on telemetry no individual enterprise could ever match. The security community maintains a shared catalog of attacker behavior that any defender can read. None of this existed at this maturity a decade ago. The executive question is what is your team doing with the intelligence available to them?

Chapter Eight carried the defensive arc and introduced the principle: know your enemy. This appendix sits next to that chapter as a working reference. The Sources section below explains the four categories of threat intelligence that matter to a senior executive. The ISAC directory shows where your industry's threat-sharing community already lives. The case studies are four named, government-attributed examples of how industry-specific targeting works in practice. The five questions at the end are the ones to take to your CISO.

If your security team cannot name the top three threat groups most likely to come at your industry, and the specific tactics, tools, and protocols those groups employ, they have some homework to do.

The Sources

Useful threat intelligence comes from four places, and the most effective security programs draw on all four.

Government. The Cybersecurity and Infrastructure Security Agency (CISA), often jointly with the FBI and the National Security Agency, publishes attributed advisories on active threats. These are the documents that name the actor group, describe the tactics, list the indicators of compromise, and recommend mitigations. Two CISA products are particularly worth knowing by name. The Known Exploited Vulnerabilities (KEV) catalog is the federal list of software flaws being actively exploited in the wild. It is the prioritization list for patching, full stop. The Joint Cyber Defense Collaborative (JCDC), established in 2021, is the

operational coordination body where CISA, federal partners, and more than three hundred private-sector partners synchronize on active threats. CISA also publishes sector-specific guidance for each of the sixteen designated critical-infrastructure sectors. All of it is at cisa.gov and all of it is free.

Industry. Information Sharing and Analysis Centers (ISACs) are nonprofit, sector-specific membership organizations where companies pool real-time threat intelligence under controlled rules. They were established under Presidential Decision Directive 63 in 1998 and coordinated through the National Council of ISACs, formed in 2003. Twenty-eight sector ISACs exist as of this writing, alongside a closely related category called Information Sharing and Analysis Organizations (ISAOs), authorized under Executive Order 13691 in 2015 for sectors where the ISAC structure was not the right fit. The directory in the next section shows the ones most likely to be relevant to your business.

Commercial. Five major annual threat reports are written for an audience that includes executives. The Verizon Data Breach Investigations Report (DBIR) has been published annually since 2008 and is the most-cited cross-sector statistical baseline in the industry. Mandiant's M-Trends report, now published by Google Cloud, draws on Mandiant's incident-response engagements. Microsoft's Digital Defense Report draws on telemetry from across Microsoft's cloud and identity platforms. The CrowdStrike Global Threat Report draws on CrowdStrike's endpoint sensor network. The IBM X-Force Threat Intelligence

Index draws on IBM's incident-response and dark-web monitoring practice. These reports often disagree about which industry is the most-targeted in any given year. That disagreement is not noise. Different telemetry sources see different attackers, which is precisely why your team should be reading more than one.

Shared vocabulary. MITRE ATT&CK is a free, globally accessible knowledge base maintained by The MITRE Corporation, the federally funded research nonprofit. It catalogs the specific tactics, techniques, and procedures observed in real-world attacks, organized by adversary group and by phase of attack. When your CISO references "MITRE technique T1566" or "T1078," that is the shared, vendor-neutral language that lets defenders map their controls to attacker behavior and compare what one group does versus another. You do not need to memorize the catalog. You should know that it exists and that your team uses it.

ISACs by sector

The table below lists the sector-specific ISACs most likely to be relevant to a typical enterprise. The full member directory and contact information is maintained at nationalisacs.org.

If your business is in...	The ISAC to know
Financial services	FS-ISAC
Healthcare	Health-ISAC (H-ISAC)
Electricity	E-ISAC (operated by NERC)
Oil and natural gas	ONG-ISAC
Natural gas distribution	DNG-ISAC

Water and wastewater	WaterISAC
Automotive	Auto-ISAC
Aviation	Aviation ISAC (A-ISAC)
Maritime	MTS-ISAC
Surface transportation, public transit, over-the-road bus	ST-ISAC
Information technology	IT-ISAC
Communications and telecom	COMM-ISAC
Retail and hospitality	RH-ISAC
Real estate	Real Estate ISAC
Space industry	Space ISAC
Research and higher education	REN-ISAC
State, local, tribal, and territorial government	MS-ISAC
Elections infrastructure	EI-ISAC
Legal services	LS-ISAO

*LS-ISAO is an Information Sharing and Analysis Organization rather than an ISAC; the function is similar.

Membership models vary. Some ISACs are tiered by company size and revenue, with reduced fees or no-cost tiers for smaller members. Some require sponsorship by an existing member. All of them function on the same principle: members share what they are seeing in their environments, under traffic-light protocols that govern how widely the information can be redistributed, and in exchange they receive intelligence the broader public never sees. If your security team is not in your industry's ISAC, that is a gap. If your industry has more than one relevant ISAC, and most of the critical-infrastructure sectors do, you should be in both.

Case studies: how industry-specific targeting works in practice

The four cases below are examples, not a current roster. Each is documented in a published government advisory and each illustrates a different dimension of how named threat groups target specific industries with specific methods.

Scattered Spider, hospitality and casino sector, September 2023. A native-English-speaking, predominantly young, financially motivated group known as Scattered Spider hit MGM Resorts and Caesars Entertainment within ten days of each other. The entry point in both cases was not technical. It was a phone call to the IT help desk, by an attacker who had researched the target employee on LinkedIn and impersonated them well enough to convince the help-desk technician to reset their multi-factor authentication credentials. From there, the attackers moved laterally through Okta and reached cloud infrastructure. MGM disclosed cash-flow impacts of approximately one hundred million dollars in its subsequent SEC filing. Caesars reportedly paid a ransom in the range of fifteen million dollars. CISA and the FBI published a joint advisory in November 2023, AA23-320A, describing the group's tactics in detail. The executive lesson: identity controls and help-desk procedures are the front line of defense for any business whose attackers prefer to phone in rather than break in.

Volt Typhoon, U.S. critical infrastructure, disclosed February 2024. A People's Republic of China state-sponsored group that the U.S. intelligence community has assessed is pre-

positioning for disruptive or destructive cyberattacks against U.S. critical infrastructure in the event of a major crisis or conflict. The targeted sectors named in the CISA/NSA/FBI joint advisory AA24-038A are communications, energy, transportation, and water and wastewater.

The group's defining tactic is what defenders call "living off the land," using legitimate tools that come built into the operating system, rather than custom malware, to evade detection. In some victim environments, the group maintained persistent access for at least five years before discovery. CISA published a companion Fact Sheet for Leaders on March 19, 2024, *Actions for Critical Infrastructure Leaders*, specifically written for an executive audience. The executive lesson: not every attacker wants money or data. Some want quiet, persistent access against the day they may be asked to use it.

Cl0p ransomware gang, cross-sector via MOVEit Transfer, May 2023. A Russian-speaking ransomware-and-extortion group exploited a previously unknown SQL injection vulnerability (later catalogued as CVE-2023-34362) in Progress Software's MOVEit Transfer, a file-sharing product used by thousands of organizations to move large data sets. The exploitation campaign began around May 27, 2023. CISA and the FBI published the joint advisory AA23-158A in June 2023. By late October 2023, the running tally of affected organizations had passed twenty-five hundred and the count of individual records exposed had passed ninety-three million.

The victim list spanned healthcare, finance, government, education, and consumer business, connected only by the fact that they, or one of their vendors, or one of their vendors' vendors, ran MOVEit. The executive lesson: third-party risk is no longer a checkbox on the vendor questionnaire. Your security perimeter now includes the software your vendors use, and the software those vendors' vendors use, and the chain extends further than your team has visibility into.

LockBit, ransomware-as-a-service across sectors, disrupted February 2024. From roughly 2019 through early 2024, LockBit was the most prolific ransomware operation in the world, responsible for thousands of attacks across every major industry. The group ran an affiliate model: a small core team maintained the encryption tooling and the negotiation infrastructure, and dozens of independent affiliates conducted the actual intrusions in exchange for a cut.

The FBI, CISA, and MS-ISAC published the joint advisory AA23-075A, *#StopRansomware: LockBit 3.0*, on March 16, 2023, describing the group's tactics in detail. On February 20, 2024, a multinational law-enforcement coalition led by the UK National Crime Agency and the FBI, Operation Cronos, seized LockBit's primary infrastructure, took down dark-web sites, and indicted multiple members.

The group claimed to have returned to operations within weeks; the disruption nonetheless significantly degraded the operation. The executive lesson: the modern criminal threat is industrialized. The group attacking you is not a person but a supply chain: developers, affiliates, negotiators, money launderers, and increasingly the AI tools that augment each role. Defending against an industry requires understanding the industry, not just the individual breach.

Five questions for your security team

If you do nothing else after reading this appendix, schedule a thirty-minute meeting with your CISO and ask these five questions.

First, *are we members of our industry's ISAC, and who on our team participates in the threat-sharing calls?* Membership without participation produces a logo on the website and nothing else. The value of an ISAC comes from the analysts who read the bulletins, attend the calls, and feed what they learn back into your defenses.

Second, *are we tracking CISA's Known Exploited Vulnerabilities catalog, and what is our service-level commitment for patching items on it?* The KEV catalog is the federal list of flaws being actively exploited right now. Patching items on that list is not a nice-to-have. It is the floor.

Third, *who reads the annual threat reports for our sector, and how does what they read change what we do?* The Verizon DBIR, Mandiant M-Trends, Microsoft Digital Defense Report, CrowdStrike Global Threat Report, and IBM X-Force Index publish every spring. If your team reads them and your program never changes, your team is reading them for entertainment.

Fourth, *can you name the top three threat groups most likely to target our industry, and the tactics each one uses?* If the answer is hesitation, your team is defending against a generic catalog rather than against the specific threats your industry actually faces. The names exist. The advisories are public. The homework can be done.

Fifth, *when did we last update our defenses based on a change in the threat landscape, not on a new framework, a new audit finding, or a new vendor pitch?* This is the question that separates organizations that consume threat intelligence from organizations that act on it. If the answer is "I cannot recall," the intelligence is not flowing into the decisions.

If any of those questions produces a long pause, you have your priority list for the next quarter.

†

A note on sources: The advisories cited in this appendix are all available at cisa.gov: CISA/FBI AA23-320A (Scattered Spider), CISA/NSA/FBI AA24-038A (Volt Typhoon) and the companion Leaders Fact Sheet of March 19, 2024, CISA/FBI AA23-158A (Cl0p / MOVEit), and FBI/CISA/MS-ISAC AA23-075A (LockBit 3.0). The MITRE ATT&CK framework is at attack.mitre.org. The National Council of ISACs member directory is at nationalisacs.org. NIST Special Publication 800-150, *Guide to Cyber Threat Information Sharing*, remains the federal government's primary published guidance on the topic; the current version was issued in October 2016 and the substance (governance, scoping, rules of engagement for sharing) remains evergreen.

APPENDIX D

The Board Conversation

†

A five-minute script for the meeting where the decision actually gets made

The cybersecurity briefing your board has been receiving for the last two years has been accurate. It has also been framed in a way that systematically produces the wrong outcome. The framing treats cybersecurity as a technology risk managed by the security team. That framing tells the board to delegate to the CISO and revisit at the next audit committee meeting. It is the framing that has produced the current condition of most enterprises: the security team identifies what is vulnerable, has no authority to actually apply the fixes, and reports compliance in metrics the board cannot connect to a business outcome.

The reframe is straightforward. We are not talking about a security or technology problem. It is a business continuity and organizational resilience problem and needs to be treated as such. The responsibility for setting priorities shifts from the security and IT teams to executive leadership and the board. The reason it has to shift is operational, not philosophical. The decisions about

risk tolerance and business resilience are decisions the security team cannot make. They belong to the room where this appendix is designed to be delivered.

Chapter Eleven carried the board-conversation arc and made the structural argument for executive engagement. This appendix is the operational companion. The script below is a five-minute briefing format, designed for a single decision moment in a single meeting. The pushback table covers the four responses you should expect, and how to answer each one at peer level. The closing questions are the ones to leave the room with if no other action is taken.

This appendix is not a substitute for a fuller security program review. It is the briefing that produces the authorization for one to begin.

The numbers behind the script

Three figures define the exposure. They are the empirical anchors for every claim the script makes.

Five days. The median time from public disclosure of a software vulnerability to active exploitation by criminal actors. Source: Rapid7 2026 Global Threat Landscape Report; Flashpoint measured the same figure at 745 days in 2020. The trend line is not gradual. It is a collapse.

Five months. The average enterprise time to remediate a known vulnerability. Source: Qualys 2026 Enterprise Patch & Remediation Benchmark, consistent with multiple peer industry surveys. The number has been roughly stable for the last five

years. The exploit window has compressed by a factor of fifty in the same period.

\$10.2 million. The average cost of a US data breach across all causes. Source: IBM Cost of a Data Breach Report 2025, 2.3 times the global average of \$4.44 million. Sector breakdowns from the same report: healthcare averages \$7.4 million, financial services \$5.6 million, industrial \$5.0 million. These figures predate regulatory penalties, class action settlements, and the long-tail reputational cost. The number on the table in a material incident is larger.

The first two figures define the exposure. The third shines a light on what can happen in the time between discovering and fixing. I need to call out a problem with the numbers because it is important. Earlier I said cybersecurity is a business continuity issue, not a technical one. If your supply chain is compromised or your critical business systems go down, how long will it take you to recover? And the bigger question is how long can your business survive total interruption.

Jaguar Land Rover's 2025 shutdown showed what that looks like: a £196 million incident-response bill inside an event the UK's Cyber Monitoring Centre modeled at £1.9 billion once lost production and the supply chain were counted. With frontier AI models threatening our legacy systems and all the security debt we have accumulated over the years, we can't afford business as usual.

Three observable events in the ninety days before this writing shifted these numbers from forecast to present condition. In May

2026, Mandiant, Google's Threat Intelligence Group, confirmed and publicly reported the first zero-day exploit it attributes to AI use in the wild, used by criminal actors against a widely deployed target. On April 15, 2026, the National Institute of Standards and Technology formally announced it could no longer enrich all submitted vulnerabilities and moved to a rationed model. That means the federal database every automated security tool depends on now covers a fraction of the incoming volume. And as discussed in Chapter Seven, Berkshire Hathaway, Chubb, and Travelers have already had AI-related cyber-insurance exclusions approved by state insurance regulators. So, enterprises are feeling the squeeze on both sides. They just lost one of their primary tools for evaluating and prioritizing remediation of new vulnerabilities and at the same time, their insurance carriers are taking away their financial safety net.

The five-minute script

Five minutes. One decision. Six beats, each tied to a clock.

0:00 — Open with the reframe.

"The conversation we have been having about AI and cybersecurity is accurate. The frame is wrong. Patching vulnerabilities is a technology problem. The responsibility for prioritizing and funding the projects shifts from the security team to this room."

0:45 — Land the asymmetry.

"The mean time from a vulnerability becoming public to active criminal exploitation is now five days, and accelerating.

Our mean time to remediate a known vulnerability is five months. Every executive in this room would call that gap a crisis if it appeared in supply chain or operations. It is the same problem."

1:30 — Add the financial anchor.

"The average US breach cost is \$10.2 million before regulatory penalties and class-action exposure. More importantly, read the exclusion clauses in our current cyber-liability policy. If we were breached through a vulnerability that had been publicly known for more than five days, ask our broker this week, in writing, whether we are actually covered. Do not assume the answer is yes."

2:15 — Name the three things that changed.

"Three observable events in the last ninety days shifted this from horizon risk to present condition. The first confirmed criminal AI-built exploit was used in May. The national vulnerability database our security tools depend on moved to a rationed model in April. And our insurer's underwriting model has already changed. AI-related exclusions are being approved now, not after the next major loss."

3:15 — Make the single ask.

"What this board is being asked to authorize is one program decision. Not four investments. One. Fund the capacity to close the response time between knowing and fixing. Not more scanning. We find enough today. The investment is in acting on what we find, faster. Two quarters. The team has scoped it. What

they need from this room is budget authority and cross-functional mandate."

4:15 — Close with the question that forces a decision.

"One question to close on. If our most critical revenue-generating application were compromised today through a vulnerability that had been publicly known for one week, what is our current containment and recovery timeline? If we do not have a confident answer to that question, that is the program we are here to fund."

Do not add slides. Do not reference vendor names. Do not walk the board through a threat landscape briefing. They have heard it. They need a decision frame and a specific ask. The script delivers both in five minutes. If it runs over, the structure has not been respected.

When you get pushback

The four responses you should expect from this script are not objections to overcome. They are the right questions from people whose job is to stress-test the proposal. Answer them straight. The table below is the script for each one.

When they say...	You say...
We have been hearing about this for two years. Why is it urgent now?	Three things shifted that previous briefings did not include: the first confirmed criminal AI-built exploit in May 2026, the move of the national vulnerability database to a rationed model in April 2026, and AI-related cyber-insurance exclusions already approved by state regulators. This is not a trend. It is fundamental change that has a material impact on our current exposure.
We have not had a breach. Is this not still	The exposure is not theoretical. It is

theoretical?	structural and measurable today, independent of whether we have been tested. Breach has to be assumed. The right question is, does our response timeline exceed our exposure window. Right now it does, by roughly four and a half months.
Our security team is handling it. Why does this need board action?	The team can identify what is at risk. They cannot define organizational tolerance for risk, restructure vendor contracts, or create cross-functional authority at the speed this requires. Those decisions are not theirs to make. This is a business continuity question, and the answer belongs in this room.
Our insurance will cover a breach.	Ask our broker this week for a written position on whether our cyber policy covers a breach from a vulnerability that was publicly known for more than five days. Most current policies contain exclusion language for known, unpatched vulnerabilities, and the definition of "known" has materially expanded as AI-generated exploits move into criminal use. We may not have the coverage we believe we have.

These four responses cover roughly ninety percent of the pushback the script will face. The fifth, "the security team has not given us a number to work with," is the one the script is designed to elicit. If a board member raises it, the appropriate answer is: "That is precisely why we are here. The number we are asking you to authorize is the budget required to give the team the capacity to fix the things that reduce the risk. They have scoped it. We need this room's mandate to begin."

Five questions for your next board meeting

If you are the executive delivering this briefing, or sitting in the room when someone else delivers it, these are the five questions to leave with. The first two come directly from the script. The other three are the diagnostic gates that determine whether the program the script is funding has the conditions to succeed.

First, *if our most critical revenue-generating application were compromised today through a vulnerability that had been publicly known for one week, what is our current containment and recovery timeline?* If the answer is hesitation, the program is the answer. If the answer is confident, the program may not need to be funded at the scale proposed, but the confidence itself should be examined for the evidence behind it.

Second, *what specific investments are in motion right now to change the math between a five-day attack window and a five-month response cycle?* If the answer references a vendor proposal, a scanning expansion, or a framework adoption, the question has not been understood. The investment is in remediation capacity, not in finding more things to remediate.

Third, *has our broker confirmed in writing whether our current cyber-liability policy covers a breach from a vulnerability publicly known for more than five days?* This is the insurance question Chapter Nine raises and the script asks the board to authorize. The answer is binary, fast, and consequential. There is no reason not to have it before the next renewal.

Fourth, *do we know how many active AI agents are operating in our production environment, and do we have a governance*

model for them? The benchmark from Chapter Seven (eighty percent of Fortune 500 enterprises run them, ten percent govern them) is the room's check on whether the exposure is inside the perimeter as well as outside it.

Fifth, *is our cyber-risk oversight framework aligned with the NACD 2026 Director's Handbook, and when did the board last document the alignment?* The National Association of Corporate Directors 2026 framework is the current published baseline for board-level cyber-risk oversight. A board that cannot demonstrate alignment is a board that cannot defend its oversight in front of a regulator, a plaintiff, or a successor board reviewing the record.

If any of those questions produces a long pause, the program in the script is the priority for the next quarter.

†

A note on sources: The figures and the script draw on Rapid7's 2026 Global Threat Landscape Report (5-day median time-to-exploit); Flashpoint's 2026 Time-to-Exploit Analysis (745-day-to-44-day exploit-window collapse); Qualys's 2026 Enterprise Patch & Remediation Benchmark (5-month enterprise remediation baseline); IBM's 2025 Cost of a Data Breach Report (\$10.2M US average and sector breakdowns); Google Threat Intelligence Group's H1 2026 Cloud Threat Horizons (first criminal AI exploit confirmation; software vulnerability share of cloud breaches); NIST's National Vulnerability Database Restructuring Announcement of April 15, 2026; Microsoft

Security Blog of February 2026 (Fortune 500 AI agent deployment versus governance); Insurance Thought Leadership and Wiley Law 2026 cyber-insurance market analyses (Berkshire Hathaway, Chubb, and Travelers AI exclusion approvals); and the National Association of Corporate Directors 2026 Director's Handbook on Cyber-Risk Oversight. The five-minute presentation structure draws on Gartner, Deloitte, and NACD guidance on executive board briefings.

APPENDIX E

The AI Tipping Point

†

*A field report from the year the machines took over
finding the flaws*

I have some version of this conversation almost every day now, in different rooms with large global enterprises. The executives across the table have read the headlines. What they want to know is whether the headlines describe their problem, and if so, what the enterprises ahead of them are doing about it. Everyone is nervous. The ones who have actually seen behind the curtain are fully mobilizing.

The Author's Note at the front of this book told the story of the model that started it. Some in the industry have taken to calling it the Mythos moment, after the model that made the change undeniable. I am not particularly attached to the name. It is today's shiny object. There will be more. Tipping point is the better description, because it says what actually happened: a process that had been drifting in one direction for years went over an edge, and the practices built for the old side of the edge stopped working.

Chapter Eight laid out the strategy in three fronts: pay down the backlog, modernize the legacy estate, and build the standing pipeline. This appendix is the field report. It covers what tipped, what the programs look like when real money gets committed, and the questions to ask before your enterprise commits its own.

What tipped

For thirty years, vulnerability management ran on a simple assumption: there will always be more findings than people to fix them, so severity ratings decide what gets attention. Fix the most severe items, log the rest, carry the backlog forward. Every enterprise I have worked with ran some version of that triage. It was the rational response to scarcity of resources and it was a manageable risk.

Frontier models broke both halves of the assumption. Discovery stopped being scarce. When Project Glasswing pointed a frontier model at the open-source software everyone depends on, it surfaced more than ten thousand high-severity flaws in the first month. And severity stopped being stable. A finding rated low in isolation does not stay low when an attacker can afford to try every combination. AI-assisted attackers chain low- and medium-severity weaknesses into attack paths that reach the same systems a single severe flaw would have reached. The backlog your team has been quietly carrying was rated safe under an assumption that is no longer valid. It is not an archive anymore. It is inventory an adversary can shop.

The clock data says the same thing from the other direction. Mandiant's 2026 M-Trends report puts the average time from disclosure to exploitation at negative seven days, meaning criminals are often in before the vendor has shipped a fix. VulnCheck, which tracks exploitation in the wild, counted 884 newly exploited vulnerabilities in 2025, with nearly a third attacked on or before the day their advisory published. Meanwhile the enterprise average for remediating a known vulnerability is still measured in months. You have seen this asymmetry earlier in the book. The tipping point is that it stopped being a trend line and became the operating environment.

One caveat, because a trusted advisor owes you one. The billion-dollar interruptions of the last two years, including the Jaguar Land Rover shutdown in Chapter One, were not AI attacks. They were social engineering and stolen credentials, the same tradecraft as always. Confirmed AI-driven operations exist. Anthropic documented a criminal using its own coding tools to run reconnaissance and extortion across at least seventeen organizations in 2025, and later reported an espionage campaign it says was largely machine-executed, a claim other researchers still dispute. OpenAI, examining the same landscape, concluded that attackers were mostly using AI to run old playbooks faster rather than inventing new ones. Read those three findings together and you get the sober version: the proven catastrophic losses are conventional, the automated-attack capability is real and growing, and the discovery-volume and exploitation-clock data

stand on their own regardless of which vendor headline you believe. The program decision does not depend on the scariest story being true.

What the money is doing

Here is what I am watching enterprises fund, at global companies whose names you would recognize. The business cases going to boards are in the tens of millions of dollars, and they are getting approved, because the JLR arithmetic makes the alternative look worse. Ten million dollars a year against an interruption modeled in the billions is not a hard board conversation. The hard part is scoping the work right. The programs focus on three streams, matching the three fronts from Chapter Eight.

Eliminate the backlog, and stop refilling it. The first program uses AI to work the accumulated findings the way no human team ever could: triage in minutes instead of quarters, generate the fix, test it, and route the exceptions to people. The companion move is upstream. The same models go into the software development lifecycle, reviewing code before it ships, so the pipeline stops manufacturing tomorrow's backlog while the machines drain yesterday's. The enterprises doing this well measure both ends, backlog burn-down and new-defect escape rate, and they staff people on the judgment calls automation cannot make: which fix risks breaking a revenue system, which exception is acceptable, which finding changes the risk picture.

Modernize what obscurity was protecting. The second program is the forklift upgrade work Chapter Eight called out.

The finance and inventory systems at the center of the enterprise have run for decades on code whose original authors are long gone. Two shields kept them safe: modernization cost more than any board would approve, and the code was too obscure to attack. The same model class took down both shields in the same year. A frontier model reads forty-year-old code fluently, which makes those systems reachable, and it rewrites that code at a fraction of what modernization cost in any previous decade, which makes fixing them affordable. This is the program executives resisted longest, because the systems still work and the invoice is large. It is also the one with the least room for a partial answer. You cannot patch your way out of code nobody can maintain.

Build the pipeline that never stops watching. The third program is the end-state: AI agents continuously scanning every code repository, flagging new defects as they appear, generating and testing fixes, with your people supervising the work instead of doing it by hand. Chapter Eight called this the end-state for a reason. Once discovery runs at this pace on both sides, a quarterly scan cycle cannot keep up, no matter how good the people reading the results are.

The sequencing varies. Some enterprises start with the backlog because it is measurable and the wins come fast. Some start with legacy because an assessment scared them. What does not vary, in the rooms where this is going well, is that all three get scoped together and funded as one decision, because they are one problem. Fund the backlog program alone and the legacy estate

stays reachable. Modernize the legacy estate alone and the backlog keeps compounding. The board that funds a third of the answer has bought a third of an answer.

Questions to take into the room

Chapter Two gave you the discipline of asking. These four belong to this decision.

First, *how many findings are sitting in our security backlog today, and what year is the oldest one from?* The number is knowable in an afternoon. Executives who ask it for the first time are rarely comfortable with the answer, and that discomfort is information.

Second, *which systems that support revenue run on code nobody currently on our payroll can maintain, and what would five weeks without any one of them cost us?* Cost it the way JLR's event was costed, all of it, not the incident-response line item.

Third, *where does AI sit in our software development pipeline today: writing code, checking code, or neither?* If your developers use AI to write faster but nothing checks the output at the same speed, you have automated the creation of defects and left their discovery to the adversary.

Fourth, *has anyone brought us the integrated business case for all three programs?* Not three separate proposals in three separate budget cycles. One case, one decision, sequenced across two to three years. At the largest enterprises in the world, that case is being written and approved now. Absence of the case is itself a finding.

This appendix will age. The model names will change, the numbers will move, and some of what is a program today will be plumbing in five years. The questions will not age with it, and neither will the cost of asking them late.

Sources and Further Reading



The citations below are organized by chapter for readers who want to verify specific claims, follow a source to its original publication, or go deeper on a topic. Where a source is cited in multiple chapters, it appears under the chapter where it is first introduced. Appendix A (The Regulatory Frontier) has its own detailed sources section at the end of that appendix.

Introduction

No named sources are cited in the Introduction. The five-day median time from vulnerability disclosure to exploitation and the five-month average enterprise remediation time are sourced in Chapter One and Chapter Five respectively. The seventy-two percent CISO liability-coverage statistic is sourced in Chapter One.

Chapter One: Cyber Risk Is Business Risk

Reports and studies

- Mandiant (Google Cloud), *M-Trends 2026* — annual threat trends report drawing on Mandiant's incident-response engagements. The 28.3

percent figure for CVEs exploited within twenty-four hours of disclosure is from this report.

- Proofpoint, *Voice of the CISO 2024* and *Voice of the CISO 2025* — annual global survey of chief information security officers. The seventy-two percent D&O coverage statistic is from the 2024 edition; the sixty-five percent organizational-protection statistic is from the 2025 edition.
- Aon, *Individual Protection for Public Company Chief Information Security Officers* (2025) — the Side A D&O policy naming CISOs as Insured Persons.

Laws and regulations referenced

- Sarbanes-Oxley Act of 2002 (SOX) — internal controls certification; penalties up to twenty years imprisonment for executives who certify financial statements relying on compromised systems.
- EU Digital Operational Resilience Act (DORA, EU Regulation 2022/2554) — ICT risk management for financial institutions; individual fines up to one million euros.
- EU Network and Information Security Directive (NIS 2, EU Directive 2022/2555) — cybersecurity obligations for essential and important entities; management liability provisions.
- SEC cybersecurity disclosure rules — Form 8-K Item 1.05, requiring disclosure of material cyber incidents within four business days.
- Delaware corporate law — fiduciary duty of oversight extended to senior officers for mission-critical risks, including cybersecurity.
- EU AI Act — risk-tiered AI regulation with penalties reaching tens of millions of euros or a percentage of global revenue; May 2026 Digital Omnibus pushed high-risk AI rules to late 2027.
- U.S. state privacy laws — California (CCPA/CPRA), Colorado, and Connecticut named as examples of the expanding patchwork.

Court cases and enforcement actions

- *United States v. Sullivan*, N.D. Cal. — Joe Sullivan, former CISO of Uber, convicted October 2022 on two federal charges (obstruction of an

FTC investigation and misprision of a felony) related to the 2016 Uber data breach affecting fifty-seven million riders and six hundred thousand drivers; sentenced May 2023; affirmed by the Ninth Circuit, March 2025.

- *SEC v. SolarWinds Corporation and Timothy Brown*, S.D.N.Y. — SEC charged SolarWinds and its former CISO Timothy Brown in October 2023; the court dismissed most claims in July 2024 and the remainder with prejudice in November 2025.
- *In the Matter of Drizly, LLC / James Cory Rellas* — FTC enforcement action (2022–2023); ten-year personal consent order against then-CEO Rellas following a 2020 breach affecting 2.5 million customers.
- *Marriott International* — FTC consent order (December 2024), twenty-year compliance term; parallel forty-nine-state attorneys general settlement of fifty-two million dollars.

Chapter Two: Risk in Plain English

No external sources are cited in Chapter Two. The chapter establishes the Three Questions framework from the author's consulting career.

Chapter Three: Welcome to the Wild West

No external sources are cited by name. The chapter draws on unnamed case studies from the author's consulting work, including a multi-billion-dollar enterprise where the CISO began vibe coding his own solutions.

Chapter Four: The Genie Is Out of the Bottle

Reports and studies

- Google, *Big Sleep AI agent* — discovered the first verified zero-day vulnerability credited to an AI in November 2024, a memory-safety bug in SQLite.
- AISLE, *AI Cybersecurity After Mythos: The Jagged Frontier* (April 8, 2026) — more than one hundred and eighty externally validated CVEs against open-source projects including the Linux kernel and OpenSSL; follow-on test showing twenty-five smaller AI models (as few as 3.5 billion parameters, approximately eleven cents per million tokens) finding the same flagship vulnerabilities.
- DARPA, *AI Cyber Challenge finals at DEF CON* (August 2025) — seven autonomous AI teams processed fifty-four million lines of code in approximately one hundred and forty hours and surfaced eighteen previously unknown real-world vulnerabilities.
- Mozilla and Anthropic (April 2026) — two hundred and seventy-one bugs disclosed in a single evaluation of the Firefox codebase; patches shipped in Firefox 150. Mozilla had handled roughly seventy-three Firefox vulnerabilities total the previous year.
- Google Threat Intelligence Group, *H1 2026 Cloud Threat Horizons* (May 2026) — first documented zero-day exploit attributed to AI use in the wild; exploitation of software vulnerabilities overtook credential abuse as the primary cloud entry vector (44.5 percent of investigations versus under three percent the year before).
- NIST, *NVD Restructuring Announcement* (April 15, 2026) — CVE submissions grew two hundred and sixty-three percent between 2020 and 2025 with a forecast of forty-five percent further growth in 2026; NVD moved to risk-triaged enrichment.

Frameworks

- Lockheed Martin, *Cyber Kill Chain* — the seven-stage attack framework (reconnaissance, weaponization, delivery, exploitation, installation,

command and control, actions on objectives) used to structure this chapter.

Chapter Five: It's Not IF, It's WHEN

Reports and studies

- Flashpoint, *2026 Time-to-Exploit Analysis* — median time from CVE publication to attacker weaponization declined from seven hundred and forty-five days (historical) to forty-four days in 2025.
- Rapid7, *2026 Global Threat Landscape Report* — median time from vulnerability disclosure to inclusion in CISA's Known Exploited Vulnerabilities catalog was five days in early 2026.

Chapter Six: Compliance vs. Security

Frameworks referenced

- NIST AI Risk Management Framework (AI RMF 1.0), January 2023.
- EU AI Act risk-tier classification and Digital Omnibus amendment (May 2026).
- ISO 27001, NIST Cybersecurity Framework, PCI DSS, SOC 2 — referenced as examples of compliance frameworks that may or may not reflect actual security posture.

Chapter Seven: Becoming the Sheriff — AI Governance

Reports and studies

- Microsoft Security Blog (February 2026) — approximately eighty percent of Fortune 500 companies have active AI agents embedded in business operations; only ten percent have a governance model for those agents.

Laws and regulations referenced

- EU AI Act — fines up to thirty-five million euros or seven percent of global annual turnover for prohibited AI practices.
- Italy's EU AI Act implementation (September 2025) — fines up to 1.55 million euros, disqualification from public contracts for up to two years, and a broad delegation to define criminal liability for individuals.

Insurance industry references

- Chubb, Travelers, and Berkshire Hathaway — AI-specific exclusions added to D&O policies with state regulatory approval in early 2026.

Chapter Eight: Building the Defenses

Reports and studies

- FBI, *2025 Internet Crime Complaint Center (IC3) Annual Report* — AI-facilitated fraud added as a standalone category: 22,364 complaints and eight hundred and ninety-three million dollars in attributed losses.

Case studies

- *Scattered Spider / MGM Resorts and Caesars Entertainment* (September 2023) — social engineering via help-desk phone calls; MGM disclosed cash-flow impacts of approximately one hundred million dollars in its SEC filing; Caesars reportedly paid a ransom of approximately fifteen million dollars. CISA/FBI Joint Advisory AA23-320A.
- *Equifax breach* (March 2017) — unpatched Apache Struts vulnerability; breach of one hundred and forty-seven million Americans; seven-hundred-million-dollar settlement; CEO, CIO, and CISO all lost their positions.
- *UK energy firm deepfake voice fraud* (2019) — first publicly reported corporate wire fraud attributed to AI voice cloning; two hundred and twenty thousand euros transferred.
- *Arup deepfake video conference fraud* (January 2024) — twenty-five-point-six million dollars transferred across fifteen wire transfers.

- *Ferrari deepfake defense* (July 2024) — CEO Benedetto Vigna defeated an attempted deepfake voice attack by asking a verification question.
- *Twitter / Ahmad Abouammo insider threat* (2014–2022) — Saudi Arabian government adviser recruited two Twitter employees to access Saudi dissident data; Abouammo convicted on six federal counts in 2022, sentenced to forty-two months.
- *KnowBe4 North Korean operative* (July 2024) — applicant using a stolen American identity passed four video interviews and a full background check; caught within twenty-five minutes of laptop delivery. Justice Department indicted fourteen North Korean nationals in December 2024 for infiltrating more than sixty American companies; eighty-eight million dollars generated over six years.
- *Coinbase contractor bribery* (May 2025) — overseas contractors bribed; twenty-million-dollar ransom demanded; estimated remediation cost of one hundred and eighty to four hundred million dollars.
- *Project Glasswing* (spring 2026) — more than ten thousand high- and critical-severity vulnerabilities surfaced in the first month.

Chapter Nine: Budget — "Do I Need to Be an A?"

Legal doctrine

- *Caremark* doctrine (Delaware) — the fiduciary standard under which board members and senior officers may be held personally liable for failure to oversee mission-critical risks, including cybersecurity.

Statistics

- Cyber insurance premium increases of fifteen to twenty percent for companies that cannot demonstrate specific controls, with possible denial of coverage.

Chapter Ten: When Bad Things Happen — Incident Response

No new external sources are introduced. The chapter draws on the unnamed case studies from Chapters One and 5 and references the Sullivan case (sourced in Chapter One). Regulatory disclosure timelines are mapped in Appendix B.

Chapter Eleven: Talking to Your Board

No new external sources are introduced. The chapter applies the frameworks and statistics established in earlier chapters to the board communication context.

Epilogue: The Never-Ending Journey

No new external sources are introduced. Statistics referenced (vulnerability timelines, NIST NVD, AISLE findings) are sourced in Chapters Four and 5.

Appendix A: The Regulatory Frontier

See the Sources section at the end of Appendix A for the full list of sources cited in that appendix.

Appendix B: Who's on the Hook

Legal sources

The accountability tables and notification-clock timelines in this appendix draw on the following regulatory texts:

- SEC Form 8-K Item 1.05 / 17 CFR §229.106 (Regulation S-K)

- EU Directive 2022/2555 (NIS 2), Articles 20–23 and 32(5)(b)
- EU Regulation 2022/2554 (DORA), Article 5
- GDPR Articles 32–34
- NYDFS 23 NYCRR Part 500, including §500.4(d) and §500.17(b)
- UK Companies Act §§172/174
- UK Senior Managers and Certification Regime
- UK Corporate Governance Code, Provision 29
- Germany BSIG n.F. §38 (NIS 2 transposition)
- CIRCIA (Cyber Incident Reporting for Critical Infrastructure Act) — seventy-two hours; twenty-four hours if ransom paid
- HIPAA / HHS Office for Civil Rights — sixty days for breaches affecting five hundred or more individuals
- FTC Safeguards Rule — thirty days if five hundred or more consumers affected
- PIPEDA (Canada) — "as soon as feasible"
- Quebec Law 25 — "with diligence"
- OSFI (Canadian banks/insurers) — twenty-four hours

Court cases

- *In re Caremark International Inc. Derivative Litigation* — established the Delaware board-oversight standard.
- *Stone v. Ritter* — refined the Caremark standard for bad-faith failure of oversight.
- *Marchand v. Barnhill* — expanded Caremark to mission-critical risks (food safety; cybersecurity by analogy).
- *In re McDonald's Corporation* — extended fiduciary duty to senior officers within their areas of responsibility.
- *In re Capital One Consumer Data Security Breach Litigation* — shareholder derivative action following the 2019 data breach.

- *Wengui v. Clark Hill* — law firm held liable for cybersecurity failures resulting in client data exposure.

Appendix C: Threat Intelligence Resources

Reports and annual threat assessments

- Verizon, *Data Breach Investigations Report (DBIR)* — published annually since 2008; the most-cited cross-sector statistical baseline in the industry.
- Mandiant (Google Cloud), *M-Trends* — annual threat trends report drawn from Mandiant's incident-response engagements.
- Microsoft, *Digital Defense Report* — annual report drawing on telemetry from Microsoft's cloud and identity platforms.
- CrowdStrike, *Global Threat Report* — annual report drawn from CrowdStrike's endpoint sensor network.
- IBM, *X-Force Threat Intelligence Index* — annual report drawn from IBM's incident-response and dark-web monitoring practice.
- NIST, *Special Publication 800-150: Guide to Cyber Threat Information Sharing* (October 2016).

Government advisories cited in case studies

- CISA/FBI Joint Advisory AA23-320A, *Scattered Spider* (November 2023).
- CISA/NSA/FBI Joint Advisory AA24-038A, *Volt Typhoon* (February 2024); companion CISA Leaders Fact Sheet (March 19, 2024).
- CISA/FBI Advisory AA23-158A, *Cl0p / MOVEit Transfer* (June 2023).
- FBI/CISA/MS-ISAC Advisory AA23-075A, *#StopRansomware: LockBit 3.0* (March 16, 2023).

Frameworks

- MITRE Corporation, *ATT&CK* — free, globally accessible knowledge base cataloging tactics, techniques, and procedures observed in real-world attacks, organized by adversary group and attack phase.

- CISA, *Known Exploited Vulnerabilities (KEV) Catalog* — the federal prioritization list for patching actively exploited vulnerabilities.
- Traffic Light Protocol (TLP) — the information-sharing classification used by ISACs and other threat-intelligence communities.

Case study statistics

- MGM Resorts: approximately one hundred million dollars in cash-flow impacts (subsequent SEC filing).
- Caesars Entertainment: ransom reportedly in the range of fifteen million dollars.
- Cl0p / MOVEit: more than 2,500 affected organizations and ninety-three million individual records exposed by late October 2023.
- Volt Typhoon: persistent access in some U.S. critical-infrastructure environments for at least five years.

Appendix D: The Board Conversation

Reports and studies

- Rapid7, *2026 Global Threat Landscape Report* — the five-day median disclosure-to-exploitation figure used in the board briefing script.
- Flashpoint, *2026 Time-to-Exploit Analysis* — the seven-hundred-and-forty-five-day historical baseline.
- Qualys, *2026 Enterprise Patch & Remediation Benchmark* — the five-month average enterprise remediation time.
- IBM, *Cost of a Data Breach Report 2025* — average U.S. data breach cost of 10.2 million dollars; global average of 4.44 million dollars; sector breakdowns (healthcare 7.4 million, financial services 5.6 million, industrial 5.0 million).
- Microsoft Security Blog (February 2026) — Fortune 500 AI agent deployment versus governance gap.
- NACD, *Director's Handbook on Cyber-Risk Oversight*, 5th Edition (April 2026).

Further Reading

For readers who want to go deeper, the following resources provide ongoing coverage of the topics in this book:

Regulatory tracking

- OECD AI Policy Observatory — oecd.ai — live database tracking more than nine hundred national AI policies across seventy-plus countries.
- IAPP, *US State Privacy Legislation Tracker* — updated quarterly.
- Stanford HAI, *AI Index Report* — published annually; Chapter Six covers policy and governance.

Threat intelligence (free)

- CISA Alerts and Advisories — cisa.gov/news-events/cybersecurity-advisories
- CISA Known Exploited Vulnerabilities Catalog — cisa.gov/known-exploited-vulnerabilities-catalog
- MITRE ATT&CK — attack.mitre.org
- National Council of ISACs directory — nationalisacs.org

Annual threat reports

- Verizon *Data Breach Investigations Report* — enterprise.verizon.com/resources/reports/dbir/
- Mandiant *M-Trends* — cloud.google.com/security/resources
- CrowdStrike *Global Threat Report* — crowdstrike.com/global-threat-report/
- Microsoft *Digital Defense Report* — microsoft.com/security/business/microsoft-digital-defense-report
- IBM *X-Force Threat Intelligence Index* — ibm.com/reports/threat-intelligence

Board governance

- NACD, *Director's Handbook on Cyber-Risk Oversight* — nacdonline.org

- World Economic Forum, *Global Cybersecurity Outlook* — published annually with Accenture.

About the Author



Chris Thatcher has spent more than thirty years in cybersecurity, working from every seat at the table. He started as an IT director and consultant at a Big Five accounting firm, where the audit work grounded him in the consulting mindset that has defined his career. He went on to lead security practices at large global system integrators and sell solutions from some of the largest security technology vendors in the market. He has spent the last ten years in professional services, helping large enterprise clients solve complex business problems securely, with a recent focus on responsible AI adoption and the acceleration of security operations capabilities with agentic AI.

Chris served in the United States Marine Corps Reserve and spent eight years in the golf business as a teaching pro before beginning his career in technology.

Through all of it, one observation has stayed constant: communication is everything. The executives who make the business decisions about cybersecurity are almost never getting the information they need in a language they can use. This book exists to help with the translation.

When he isn't working with clients, he is spending time with his family. This project renewed his passion for writing. He is building things with AI every day and he enjoys playing No Limit Texas Hold 'em.

Chris lives in Wellington, Florida. He can be reached at chris@marquepublishing.com.